

Cortex XDR

Rafael González

March 2026

Índice

1. Introduction	7
2. Automatización	7
2.0.1. MarketPlace	8
2.0.2. Gestión de paquetes de contenido	9
2.0.3. Playbooks	9
2.0.4. Scripts	10
2.1. Work Plan and Playbook Tasks	11
2.1.1. Tareas de los playbooks	13
2.1.2. Pregutnas de la sección más interesantes	14
2.2. Trabajando con listas	15
2.2.1. Preguntas más interesantes	16
2.3. Creación y administración de trabajos	16
2.3.1. Preguntas interesantes	17
2.4. Características de automatización	18
2.4.1. Automating Playbooks	18
2.4.2. Quick Action	19
2.4.3. Pregutnas interesantes	20
3. Administración de casos	21
3.1. Trabajando con incidencias	21
3.1.1. Preguntas interesantes	22
3.2. Trabajando con casos	22
3.2.1. Preguntas interesantes	24
3.3. Response Action	25
3.3.1. Action center	25
3.3.2. Endpoint Response Actions	26
3.3.3. Preguntas interesantes	27
3.4. Advanced Response Actions	27
3.4.1. Remote Scripts Execution	28
3.4.2. Enabling Cortex EDL (External Dynamic List) Service	30
3.4.3. Preguntas interesantes	30
3.5. Exclusiones y excepciones	31
3.5.1. Exclusión de incidencias	31
3.5.2. Excepción y perfiles de excepción	31
3.5.3. Excepción de incidencias	32
3.5.4. Excepciones globales	33
3.5.5. Preguntas interesantes	33
3.6. Análisis integrado	34
3.6.1. Log Stitching (Unión de registros)	34
3.6.2. Motor de análisis	35
3.6.3. Preguntas interesantes	35
3.7. Creando y administrando Queries	36
3.7.1. Administración de Queries	38

3.7.2.	Preguntas interesantes	39
3.8.	Reglas básicas	40
3.8.1.	Reglas IOC	40
3.8.2.	Reglas BIOC	41
3.8.3.	Custom Prevention Rules	42
3.8.4.	IOC/BIOC suppression rules	42
3.8.5.	Reglas de correlación	42
3.8.6.	Preguntas interesantes	43
3.9.	Alertas y detección	43
3.9.1.	Cortex Threat Detection Strategy	43
3.9.2.	Casos de uso en cortex y pseudocodigo	44
3.9.3.	Cortex Threat Detection Tools	45
3.9.4.	Analíticas de Cortex	45
3.9.5.	Preguntas interesantes	46
3.10.	Administración de casos	46
3.10.1.	Cases in Cortex	47
3.10.2.	Casos SLAs (Service Level Agreement)	48
3.10.3.	Investigando artefactos y activos	49
3.10.4.	Preguntas interesantes	50
3.11.	Análisis y colaboración	50
3.11.1.	War Rooms	50
3.11.2.	Command Line Interface	51
3.11.3.	Context Data	52
3.11.4.	Preguntas interesantes	52
3.12.	Forensics	52
3.12.1.	Características forenses	52
3.12.2.	Preguntas interesantes	53
4.	Administración de la plataforma	55
4.1.	Portafolio de Cortex overview	55
4.1.1.	Problemas actuales	55
4.1.2.	Cortex XDR	55
4.1.3.	Cortex XSOAR	56
4.1.4.	Cortex XSIAM	56
4.1.5.	Cortex Cloud	56
4.1.6.	Preguntas interesantes	57
4.2.	Componentes de Cortex	57
4.2.1.	Cortex Activation and Access	57
4.2.2.	Preguntas interesantes	58
4.3.	Consola de administración	58
4.3.1.	Elementos de la consola de administración	59
4.3.2.	Preguntas interesantes	60
4.4.	Dashboards y reportes	60
4.4.1.	Preguntas interesantes	61
4.5.	Cumplimiento normativo	62
4.5.1.	Preguntas interesantes	62

4.6.	Administración de acceso y plataforma	62
4.6.1.	Servicios de la infraestructura	62
4.6.2.	Control de acceso	63
4.6.3.	Preguntas interesantes	64
4.7.	Bring your own key (BYOK)	64
4.7.1.	Arquitectura y flujo de trabajo	65
4.7.2.	Preguntas interesantes	67
4.8.	Multitenancy	67
4.8.1.	Modelos de licencia multitenant	68
4.8.2.	Proceso de activación de un Child Tenant	70
4.8.3.	Preguntas interesantes	70
4.9.	Cortex enterprise operaciones multitenant	71
4.9.1.	Visibilidad Multitenant	71
4.9.2.	Preguntas interesantes	72
5.	Quering	74
5.1.	Introducción a XQL	74
5.1.1.	Creando XQL Queries	74
5.1.2.	Dataset	76
5.1.3.	Preguntas interesantes	77
5.2.	Sintaxis básica	77
5.2.1.	Preguntas interesantes	79
5.3.	Construyendo bloques	79
5.3.1.	Preguntas interesantes	84
5.4.	Funciones	84
5.4.1.	Uso de funciones en queries XQL	85
5.4.2.	Preguntas interesantes	89
5.5.	Manipulación de Objetos con JSON	89
5.5.1.	Accediendo a datos JSON con funciones de extracción	90
5.5.2.	Accediendo a datos de un fichero JSON usando el método sugar	91
5.6.	Tipos de datos	93
5.6.1.	Data Types in Alter Stage Assignments	94
5.6.2.	Data Types in Filter	94
5.6.3.	Preguntas interesantes	94
5.7.	Operadores	95
5.7.1.	Operadores de operación y booleanos	95
5.7.2.	Operadores de string y rangos	96
5.7.3.	Preguntas interesantes	97
5.8.	Visualizar los resultados de una query	97
5.8.1.	Preguntas interesantes	99
5.9.	Dataset Join	99
5.9.1.	Tipos de Join	101
5.9.2.	Preguntas interesantes	106
5.10.	Parseando reglas (revisar)	108
5.10.1.	Preguntas interesantes	109

5.11. Call Function Usage	109
5.11.1. Preguntas interesantes	109
5.12. Cortex Cloud: Búsqueda por gráficos	110
5.12.1. Preguntas interesantes	112
6. Enterprise Runtime Security	113
6.1. Protección y administración de un endpoint	113
6.1.1. Protección a los endpoints	113
6.1.2. Administración de un endpoint	114
6.1.3. EndpointAgents	116
6.1.4. Endpoint Support	117
6.1.5. Preguntas interesantes	117
6.2. Cortex Runtime Security	117
6.2.1. Introducción de agentes	117
6.2.2. Conceptos clave y administración sana	119
6.2.3. Resolución de problemas: Metodologías y herramientas	121
6.2.4. Trabajando con technical support	122
6.2.5. Preguntas interesantes	123
6.3. Malware Protection	124
6.3.1. Portable Executables and DLL Examination	124
6.3.2. Comportamiento de protección de amenazas (BTP)	125
6.3.3. Motor de inspección de paquetes de red	126
6.3.4. Otros módulos de protección	127
6.3.5. Endpoint Scanning	127
6.3.6. iOS Malware Protection Modules	128
6.3.7. Preguntas interesantes	128
6.4. Exploit Protection	129
6.4.1. Técnicas de explotación y mecanismos de defensa	129
6.4.2. Endpoint Protection Module	130
6.4.3. Perfiles de prevención	130
6.4.4. Trabajando con procesos protegidos	131
6.4.5. Preguntas interesantes	131
6.5. Cortex Profiles, Policy Rules, and Optimization	132
6.5.1. Perfiles de prevención	132
6.5.2. Control de dispositivos y control de excepciones	133
6.5.3. Policy rules	134
6.5.4. Agent Settings Profiles	134
6.5.5. Restrictions Profiles	135
6.5.6. Tuning and optimization	136
6.5.7. Preguntas interesantes	136
7. Data Ingestion	138
7.1. Data Source	138
7.1.1. Tipos de fuentes de datos	139
7.1.2. Data Onboarder	140
7.1.3. Preguntas interesantes	140

7.2.	Trabajando con dominios	141
7.2.1.	Componentes clave	141
7.2.2.	Case Domains	141
7.2.3.	Preguntas interesantes	142
7.3.	Trabajando con datasets	143
7.3.1.	Parsing rules	144
7.3.2.	Dataset Management View	144
7.3.3.	Preguntas interesantes	145
8.	Broker VM	146
8.1.	Broker VM resumen	146
8.1.1.	Broker VM Applets and Services	146
8.1.2.	Preguntas interesantes	148
8.2.	Broker VM set up	148
8.2.1.	Install Broker VM	149
8.2.2.	Configurar Broker VM	149
8.2.3.	Activate Broker VM Applets	149
8.2.4.	Broker VM Clusters	149
8.2.5.	Preguntas interesantes	150
8.3.	Cortex XSIAM: Broker VM Management	150
8.3.1.	Broker VM Configuration Details	150
8.3.2.	Broker VM Logs	151
8.3.3.	Reboot Broker VM	151
8.3.4.	Broker VM Live Terminal	151
8.3.5.	Preguntas interesantes	151
9.	Inventario	153
9.1.	Descubrimiento y Gestión de Activos de Red	153
9.1.1.	Inventario Unificado de Activos	153
9.1.2.	Configuración de red	153
9.1.3.	Evaluación de Vulnerabilidades	154
9.1.4.	Preguntas interesantes	154
10.	Licencias y Add On	156
10.0.1.	Módulos de seguridad en Cortex Cloud	156
10.0.2.	Módulos de Cortex XDR	157
10.0.3.	Módulos Cortex XSIAM	157
10.0.4.	Preguntas interesantes	157
10.1.	Cortex ITDR	158
10.1.1.	Identity Threat Protection	158
10.1.2.	ITDR Use Cases	160
10.1.3.	Preguntas interesantes	160
10.2.	Advanced Email Security	161
10.2.1.	Arquitectura y Flujo de Datos	161
10.2.2.	Issue Generation	162
10.2.3.	Preguntas interesantes	163

1. Introduction

Cortex XDR es una solución avanzada de detección y respuesta extendida (XDR) diseñada para ofrecer protección, detección y respuesta integral frente a amenazas cibernéticas. Va más allá de la seguridad tradicional de endpoints al proporcionar visibilidad completa en redes, endpoints, nubes, fuentes de terceros e identidades.

Este documento se trata de unos apuntes/resumen del curso oficial de PaloAlto. Enlaces:

- <https://www.paloaltonetworks.com/services/education/palo-alto-networks-xdr-analyst>
- <https://learn.paloaltonetworks.com/learn/learning-plans/455/palo-alto-networks-certified-xdr-analyst>

Por tema de copyright se han tenido que borrar todas las imágenes de las capturas del curso.

2. Automatización

La automatización es el proceso donde se utilizan los flujos de trabajo y herramientas automatizadas para optimizar y agilizar diversas tareas de seguridad y operaciones de seguridad dentro de Cortex.

El flujo de trabajo es el siguiente:

1. Creación de una incidencia
2. Activación de un playbook (las incidencias activan playbooks)
3. Ejecución de un *workflow*: el playbook genera tareas predefinidas como parte del flujo de trabajo de respuesta a incidentes
4. Análisis de datos: se realiza mediante filtros (aislan la información más importante) y transformadores (convertir tiempos)
5. Colaboración y comunicación: notificar e involucrar a los analistas
6. Ejecución de tareas y sub-playbooks: según lo definido en el playbook. Por ejemplo, tarea puede ser ejecutar un script para analizar malware.
7. Actualización de campos de incidencia: en función de los resultados de las tareas
8. Cierre o escalado de incidencia
9. Logging y reporting: Cortex registra cada acción del ciclo de vida de la incidencia y genera informes

10. **Análisis posterior:** Cortex continua utilizando los datos para detectar patrones y actualizar threat intelligence.

Los componentes claves para la automatización son los siguientes:

1. **MarketPlace:** destino para mejorar las capacidades de operaciones de seguridad
2. **Playbooks:** motor de automatización central de Cortex. Orquestan una serie de tareas, condiciones, bucles, comandos... para agilizar y mejorar los procesos de investigación y respuesta.
3. **Filtros y transformadores:** permite a los usuarios manipular, extraer y presentar los datos en formato JSON.
4. **Scripts:** sirve para ejecutar acciones a través de comandos

2.0.1. MarketPlace

Es el centro donde se gestionan los paquetes de contenido que mejoran la seguridad del contenido como playbooks, scripts, etc... También ayuda a optimizar la gestión de casos y activos.



Figura 1:

Los paquetes de características incluyen:

- **Integraciones:** conectan plataformas externas de seguridad y gestión de alertas con Cortex. Esta conexión permite que estas plataformas generen eventos, los cuales se transforman en incidencias dentro de Cortex, iniciando procesos de seguridad automatizados.
- **Playbooks y scripts**

- Tipos de incidencia y campos: sirven para categorizar y priorizar las incidencias dentro de Cortex y proporcionan información detallada sobre estos.
- Reglas: permite automatizar la detección de amenazas potenciales mediante:
 - Reglas de correlación: analiza múltiples eventos de diversas fuentes utilizando un motor XQL
 - Data model Rules: normaliza y enriquece los datos. Crea un esquema estandarizado con tipos de datos predefinidos y mapeo de datos de tareas a este esquema.
 - Reglas de parseo: procesa datos entrantes, eliminando información innecesaria.
- Dashboards: representación visual de los datos en tiempo real
- Reportes: representación estadística de los datos en tiempo real

2.0.2. Gestión de paquetes de contenido

Los usuarios pueden explorar, instalar y gestionar sin problemas paquetes de contenido. Aspectos clave:

- Búsqueda y navegación
- Actualizaciones (no se actualizan solos, tiene que hacerlo los administradores).
- Historial de versiones
- Dependencias
- Instalación de paquetes de contenido
- Eliminación
- Actualización de paquetes de contenido
- Revertir a versiones anteriores

2.0.3. Playbooks

Un **Playbook** es un motor de automatización de Cortex, orquestando una secuencia de tareas, condiciones, automatizaciones, comandos y bucles.

El ciclo de vida de un playbook es el siguiente:

1. Investigación y respuesta: definir el flujo lógico de una investigación
2. Diseñar casos de uso: consideraciones clave como acciones, bucles, condiciones y criterios de solución

3. Crear y actualizar el ciclo de vida del playbook
4. Manejo de incidencias: asegurarse que el playbook esté alineado con el caso de uso
5. Definir un flujo lógico
6. Criterio de recomendación
7. Mejora continua

Desarrollo de Playbooks: Los playbooks son una serie de tareas, condiciones, automatizaciones, comandos y bucles que se ejecutan en un flujo predefinido para ahorrar tiempo y mejorar la eficiencia y los resultados del proceso de investigación y respuesta. Son el núcleo del sistema Cortex porque permiten automatizar numerosos procesos de seguridad, incluida la gestión de investigaciones y tickets.

Las respuestas de seguridad que anteriormente se gestionaban de forma manual también pueden estructurarse y automatizarse. Por ejemplo, una tarea de un playbook puede analizar la información contenida en un incidente, ya sea un correo electrónico o un archivo adjunto en PDF.

Tipos de playbooks:

- Tareas manuales: requieren intervención humana
- Tareas condicionales: el flujo de trabajo del playbook depende de condiciones basadas en parámetros
- Tareas de comunicación: facilita interacción con usuarios
- Tareas de automatización: remedian incidencias automáticamente

Unas buenas prácticas es dividir playbooks en sub-playbooks, actualizar scripts o eliminar tareas no utilizadas.

2.0.4. Scripts

Los **scripts** permiten ejecutar acciones específicas a través de comandos. Se encuentra en *Investigación & Responde > Automation > Scripts*.

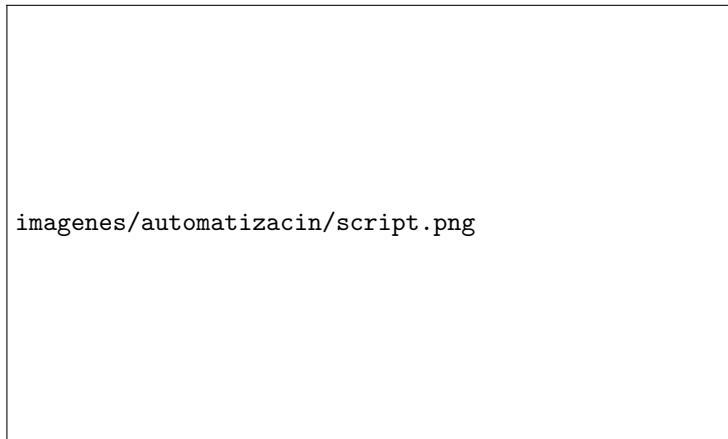


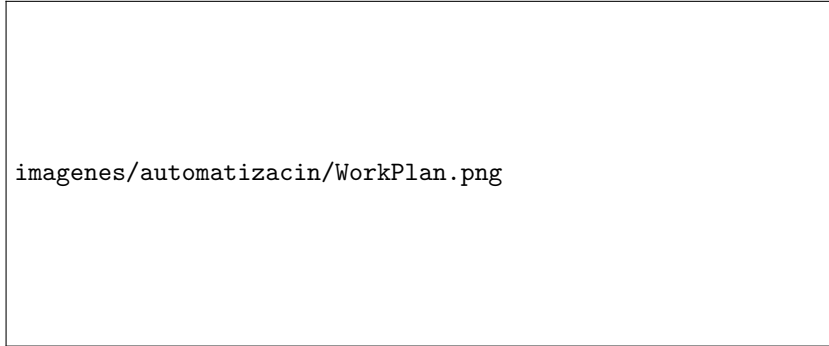
Figura 2:

Para gestionar los scripts hay que realizar lo siguiente:

- Detachment y attachment de scripts son funcionalidades clave.
- Cuando se instala un paquete de contenido, se adjunta un script, haciéndolo no editable
- Para modificar un script, hay que crear un duplicado o separarlo. En ese caso, dejara de recibir actualizaciones
- Se puede buscar por el nombre y ver la configuración
- Aprovecharse de scripts integrados (*Out-of-the-Box*), principalmente dentro de *Base and Common Scripts* content pack.

2.1. Work Plan and Playbook Tasks

Un **Work Plan** es una parte de las incidencias y contiene los playbooks que están programados para ejecutarse para dicha incidencia. Para visualizar los Work Plan hay que ir a *Cases & Issues* > *Cases*.

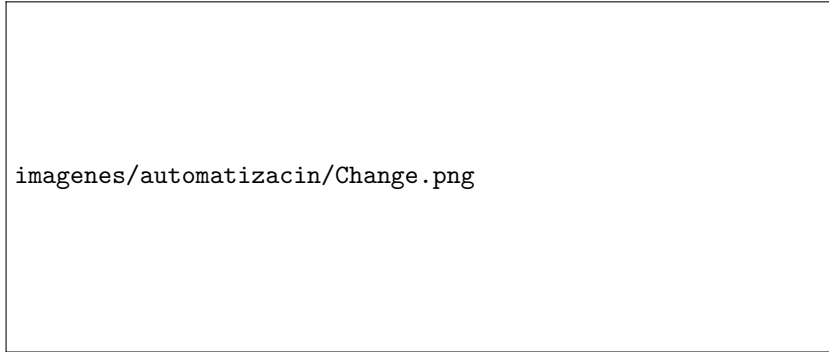


imagenes/automatizacin/WorkPlan.png

Figura 3:

Se puede realizar las siguientes opciones:

- Cambiar de playbook que se ejecute para un evento



imagenes/automatizacin/Change.png

Figura 4:

- Ver la ejecución de un playbook
- Ejecutar otra vez
- Zoom

Para la gestión de playbooks tenemos lo siguiente:

- Supervisión y administración de los mismos
- Bucles de sub-playbooks: creación de bucles dentro de un playbook utilizando sub-playbooks basandose en condicionales **For each input / Built in**
- Playbook polling (sondeo): se emplea cuando se espera que concluya un host remoto.

- Gestión de campos de incidencia: proceso iterativo. El script `set issue` juega un papel fundamental para establecer y actualizar los fields.
- Playbook debugger: herramienta para construir y solucionar problemas de los playbooks.

2.1.1. Tareas de los playbooks

Las **tareas** son partes fundamentales de los playbooks. Son los bloques de construcción fundamentales. Para crear una tarea:

1. *Investigation & Response > Automations*
2. Seleccionar/crear un playbook. Luego click en *Playbooks Blank Tasks*
3. Seleccionar tipo de tarea y el script
4. Click en Save

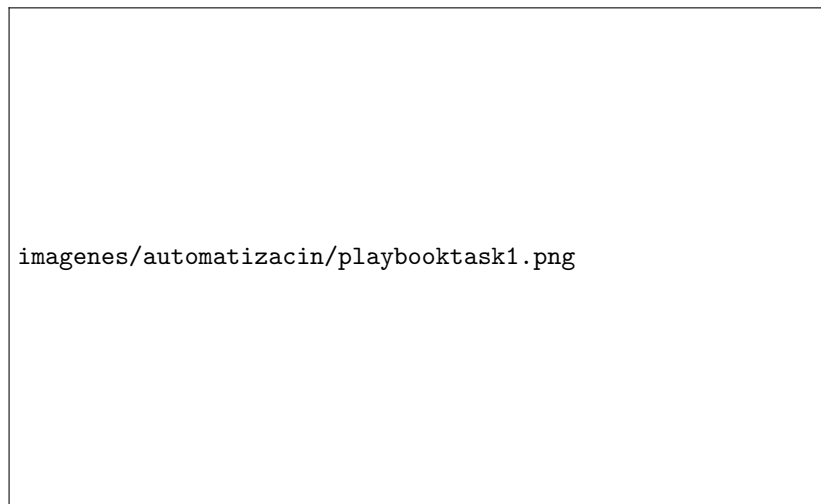


Figura 5: Caption

Se pueden administrar las tareas de manera más eficiente mediante los metadatos (importante comprender los de cada playbook), versión actual y ejecución y gestión de tareas. Existen diferentes campos e iconos según el tipo de tarea y de dato.

Existen cuatro tipos de tareas:

1. Standar: desde tareas manuales, como crear un caso o escalar un caso existente, hasta tareas automatizadas, como asignar analistas a los casos o enriquecer indicadores
2. Conditional: sigue un camino en función de los datos de entrada

3. Data Collection (interactuar con los usuarios, como si fuera una encuesta)
4. Section header (agrupa varias tareas bajo un mismo título)

En la siguiente imagen se pueden ver los iconos de cada tarea:

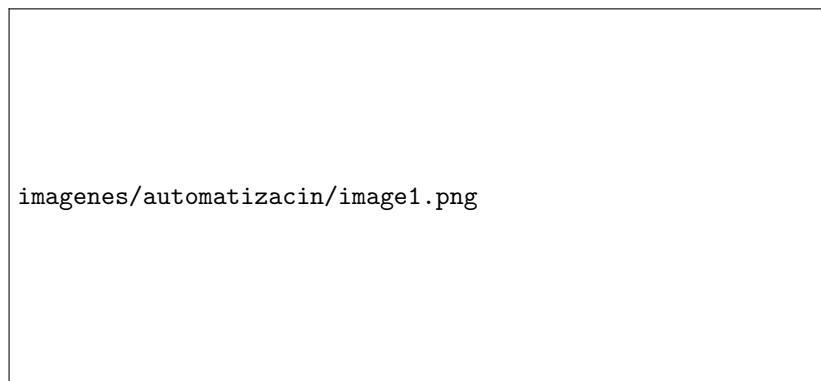


Figura 6: Caption

Inputs: datos que se generan en incidencias o integraciones externas.

Outputs: datos generados durante la ejecución del playbook.

Indicator extraction: característica para identificar indicadores de distintas fuentes de texto. Existen tres modos:

1. None: los indicadores no se extraen automáticamente. Usa esta opción cuando no quieras evaluar más a fondo los indicadores.
2. inline: extracción síncrona
3. out-of-band: extracción asíncrona, en paralelo con otras acciones.

Extending context: mejora las capacidades de la plataforma, permitiendo a los usuarios enriquecer y personalizar la información dentro de las tareas o a través de línea de comandos (*Extend issue > Advanced*)

Filtros: extrae datos relevantes para su uso posterior. Se clasifican según su funcionalidad (booleano, fecha, string, number, general, unknown)

Transformadores: convierte o representa valores. Pueden ser de fecha, generales o personalizados.

2.1.2. Preguntas de la sección más interesantes

1. *What is the benefit of using field mapping in Cortex playbooks?*

To populate issue fields with output values

2. *A playbook can be exported from a Work Plan in which file format?*

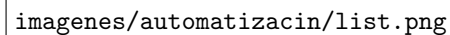
PNG

2.2. Trabajando con listas

Una **lista** es un contenedor para almacenar datos y se utiliza en playbooks y tareas. Se accede a estos datos mediante `{}`. Algunos ejemplos comunes son:

- Permitir y bloquear listas
- Input de scripts y playbooks
- Importar datos externos en una lista
- Definir una plantilla HTML
- Priorizar Casos de Respuesta

Para crear una lista hay que ir a *Settings > Configurations > Object Setup > Lists > Add List*. Luego, se pone el nombre y tipo de contenido y se copia/escribe la lista de objetos deseados a la izquierda.



imagenes/automatizacin/list.png

Figura 7:

Algunos comandos para gestionar las listas desde la CLI (parte inferior, *War Room*) son:

- `!createList` para crear una lista

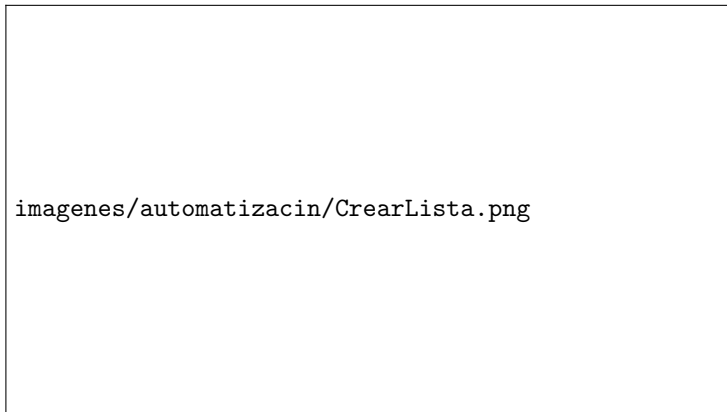


Figura 8:

- `!getList "ListName='...'"` para extraer datos
- `!removeFromList ListName="..."listData="..."` para eliminar
- `!setList listName="..."listData="oldValue, NewValue"`
- `!addToList listName="..."listData=valor`

2.2.1. Preguntas más interesantes

1. *Which menu option on the Lists page do you use to make changes to a list?*

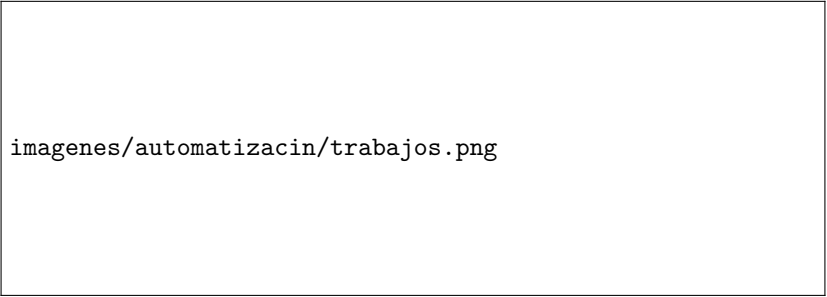
Edit

2. *What playbook option gives you the ability to create and manage lists in playbooks?*

Scripts

2.3. Creación y administración de trabajos

Los **trabajos** permiten la orquestación y automatización de diversas tareas de seguridad. Al configurar un trabajo se puede ejecutar un playbook en respuesta a eventos específicos o desencadenados (trigger).



imagenes/automatizacin/trabajos.png

Figura 9:

Existen dos tipos:

1. **time-triggered job**: permite programar la ejecución de tareas en un momento predeterminado o en intervalos regulares.
2. **feed-triggered job**: se ejecuta cuando se producen cambios en todos los feeds o en feeds específicos de selección.

Para ver los trabajos: *Chart Panel* o *Table view* o *Detailed view*.

Existen las siguientes opciones para administrar un trabajo (en *Table and Summary Views*):

- Edit
- Run Now
- Disable (Job Status a este estado) (evitar que el trabajo se ejecute la próxima vez. Esto no afectará al trabajo que ya está en ejecución)
- Enable (Job Status a este estado) (para ejecutar el trabajo la próxima vez)
- Pause
- Resume
- Abort
- Delete

2.3.1. Preguntas interesantes

1. Which type of job can be used to create a list of indicators at the end of each day?

Time-triggered

2. Which Jobs page option is used to stop a running job?

Abort

3. Which view of the Jobs page shows information about any cases created by the job?

Detailed View

4. Which option can you use to halt a running job?

Pause

5. When you create a new job, in which section of the configuration panel can you specify a playbook?

Basic information

2.4. Características de automatización

Reduce el número de tareas repetitivas y necesidad de intervención manual. El analista define condiciones y, si se cumplen, se ejecutarán unas tareas específicas. Los componentes clave son:

- Triggers: condiciones que ejecutarán un playbook o quick actions
- Jobs
- Integration
- Quick action: es una única tarea de automatización

2.4.1. Automating Playbooks

Las **Reglas de automatización** definen cuando y como un playbook debería ejecutarse basado en incidencias o criterios. Existen tres tipos de triggers en las reglas de automatización:

1. Issue-Based triggers: Se activan automáticamente cuando se generan nuevas incidencias que cumplen criterios específicos
2. Sub-playbook triggers: Cuando un playbook está anidado dentro de otro, se activa automáticamente como un paso dentro del flujo de trabajo principal
3. Manual triggers: Los playbooks también pueden ejecutarse manualmente desde la vista de incidencias o casos por usuarios autorizados. Esto es especialmente útil para investigaciones puntuales



imagenes/automatizacin/rule.png

Figura 10: Creación de una regla

La **automatización de trabajos** ejecuta playbooks de forma recurrente, basandose en tiempo y feeds. Enfoque proactivo. Más adecuados para tareas de segundo plano que no dependen de una incidencia específica.

Se debe integrar de manera correcta un playbook integrado (out-of-the-box) a nuestro caso de uso concreto.

2.4.2. Quick Action

Las **Quick Action** son componentes de automatización ligeros diseñados para realizar tareas repetitivas y rápidas que no requieren la lógica de un playbook.

Existen tres tipos:

1. Manuales: Las Acciones Rápidas pueden ejecutarse manualmente desde la tabla de incidencias haciendo clic derecho sobre una incidencia y seleccionando Ejecutar automatización.
2. Rule trigger: Las Acciones Rápidas pueden integrarse en reglas de automatización, lo que permite que se activen según condiciones definidas, al igual que los playbooks.
3. Tareas en playbooks: Las Acciones Rápidas también pueden incluirse como tareas individuales dentro de playbooks más grandes

Para lanzar una quick action manual se va a *Issues* y:

1. Se filtra y selecciona la incidencia
2. *Run automation*: por ejemplo, para listar las quick actions disponibles
3. *Sen Issue Summary email*

Para automatizar quick actions con reglas:

1. Crear una nueva regla de automatización (*Automation Rules > Case Configuration > Add Automation Rule*)
2. Definir una regla y establecer condiciones
3. Filtrar para no dar falsos positivos
4. Añadir quick action para completar la regla
5. Seleccionar y configurar la quick action
6. Create

2.4.3. Preguntas interesantes

1. In the Playbook Catalog, why might some users not see a specific playbook?

The playbook is not compatible with their Cortex product

2. What happens when you duplicate an out-of-the-box playbook into your Org playbooks section?

It can be edited and customized

3. Which of the following actions is available directly from the playbook editor interface?

Set up integration instances

4. Before you can use an integration command in an automation rule, what must you do?

Connect an integration instance

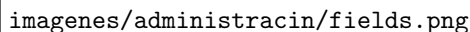
3. Administración de casos

3.1. Trabajando con incidencias

Aquí van algunas definiciones clave:

- Una **incidencia** es una notificación de datos para reportar una actividad sospechosa o evento (Cases and Issues > Issues).
- Un **caso** es un objeto contenedor para agrupar incidentes relacionados, así como otros datos relacionados con ataques.
- Un **log** es cualquier recopilación de datos en pares nombre-valor; los valores pueden no ser atómicos, sino múltiples.
- Un **incidentes correlacionados (Stitched Issues)** es un incidente mejorado por Cortex, que se correlaciona automáticamente con registros para proporcionar mejor visibilidad del ataque.
- El **propietario del Grupo de Causalidad (CGO)** es el proceso identificado como la causa raíz de un ataque; el iniciador.
- La vista de **Causalidad (Causality View)** es el nombre de una página de la consola de administración especializada en el análisis de causalidad de incidentes, en particular de incidentes correlacionados.

Un incidencia tiene atributos como: categoría, Issue ID, Action, Name, Status, severity o Description. Se pueden ver los valores de estos atributos en formato JSON (`Debug issue`).



imagenes/administracin/fields.png

Figura 11:

La **regla de marcado de incidencias** sirve para priorizar una incidencia. Para hacerla: *Cases & Issues > Case Configuration > Starred Issues > + Add Staring Configuration*.

Los **Campos destacados de una incidencia** son los usados para localizar y priorizar incidencias con valores específicos. Para añadir los valores a los campos: *Cases & Issues > Case Configuration > Featured Fields*.

Se pueden añadir etiquetas a casos e incidencias para poder filtrar mejor y se puede cambiar el estado o severidad de un incidente.

3.1.1. Preguntas interesantes

1. *What happens when both a starring rule and an exclusion meet the same criteria?*

The exclusion rule has precedence

2. *What is the common term between stitched issues and statistics?*

Correlation

3. *Where does an issue's name come from?*

The module that triggered the issue, i.e Behavioral Threat

4. *What is a stitched issue?*

An enhanced issue automatically correlated with logs

5. *Which two options are considered Featured Issue Fields? (Choose two.)*

User and Host

3.2. Trabajando con casos

Un **caso** representa un único ataque. Debido a su naturaleza única, incluye diversos componentes que se originan a partir de la misma causa raíz, como atacantes, herramientas, procesos y una combinación de malware y exploits. También tienen un identificador único llamado CaseID.

Los componentes de un incidente son los siguientes:

- Caso (agrupa incidencias, arifactos y activos relacionados)
- Issue (cada issue tiene su propia ID)
- Activos (endpoints y usuarios afectados)
- Artefactos (atributos de los atacantes)

Vinculación de incidencias a casos coincidentes: Cortex vincula las incidencias a los casos cuando estas llegan. El proceso básico de vinculación es:

1. Extracción de atributos
2. Buscar casos coincidentes utilizando los atributos
3. Vincular si se encuentra caso. Crear si no se encuentra

Cortex genera un caso si:

- Un caso tiene muchas incidencias (limitadas por umbral)
- Una incidencia no encuentra caso coincidente

Para ver los casos hay que ir a *Cases*. Hay dos partes:

1. List pane: muestra los casos basados en un filtro

2. Details pane: muestra en detalle la instancia seleccionada

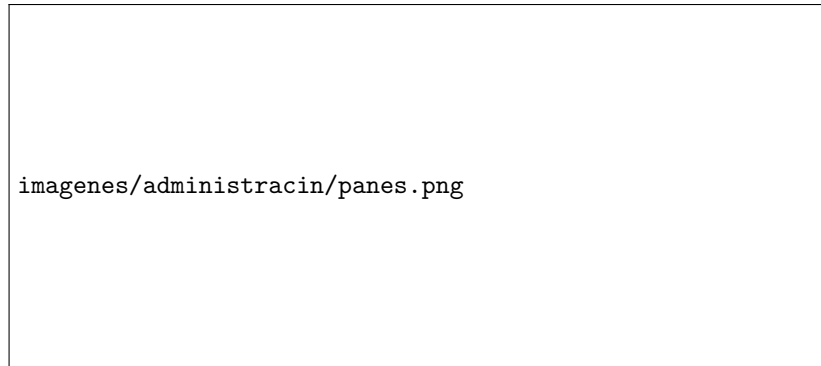


Figura 12:

Se pueden priorizar y resaltar automáticamente tus casos utilizando reglas en la página de configuración de casos de la consola de administración. Todas las reglas funcionan a nivel de incidencia, y no directamente a nivel de caso. Sin embargo, modificar las incidencias de un caso también modifica el caso en sí. Por ejemplo, cuando una incidencia se marca con estrella, el caso que contiene esa incidencia también se marca con estrella. Alternativamente, puedes marcar con estrella un caso directamente en la página de Casos.



Figura 13:

Se puede priorizar cada caso para saber su urgencia o seriedad. Para ello,

existe el **Case Scoring** que es un valor numérico asignado a un caso para indicar la gravedad o urgencia del mismo. Las puntuaciones de los casos ayudan a los investigadores a priorizar emergencias. Hay tres métodos:

1. Manual
2. Rule-Based Score
3. SmartScore

Existe una jerarquía de reglas de puntuación. Cada regla tiene una regla padre. Si llega una incidencia, si cumple con la regla padre, obtiene su puntuación. Si además cumple más subreglas, las suma.

SmartScore de Cortex es un motor de puntuación de casos impulsado por inteligencia artificial (IA), diseñado para combatir la fatiga de alertas en los equipos de ciberseguridad. Los equipos de seguridad se enfrentan a un volumen abrumador de incidencias, lo que dificulta distinguir las amenazas críticas de las falsas alarmas. Esta fatiga de alertas conduce a una menor productividad y a un mayor riesgo de pasar por alto incidentes de seguridad reales.

SmartScore utiliza inteligencia artificial (IA) y aprendizaje automático para generar puntuaciones de riesgo fiables para los casos de seguridad. Tiene en cuenta:

- Análisis de contexto
- Evaluación de características a nivel de caso
- Comparación de prevalencia estadística
- Subpuntuaciones basadas en modelos

El sistema mejora continuamente al aprender de los cambios en el entorno y de la retroalimentación de los analistas, lo que garantiza su eficacia continua a medida que evolucionan los escenarios de amenazas.

3.2.1. Preguntas interesantes

1. *In Cortex, what is an artifact?*

An attribute of attacking objects, such as filenames, file signers, processes, domains, and IP addresses

2. *How does Cortex handle cases with too many issues?*

It auto-limits the number of issues in a case to prevent starvation of other case.

3. *Which incident attribute is read-only?*

ID

4. *What constitutes insights in Cortex?*

Informational issues

5. *Which Cortex incident scoring method takes precedence?*

Manual

6. Which type of issues are displayed in the Issues table within the Issues & Insights tab?

High and medium severity issues

7. What is the correct action to take to close Cortex cases?

Resolve

3.3. Response Action

Se pueden iniciar tres tipos de acciones:

1. Respuesta inmediata, como archivo en cuarentena o parar la ejecución de un proceso
2. Investigación profunda
3. Mantenimiento y administración, como desinstalar o mejorar los agentes de Cortex de los endpoints

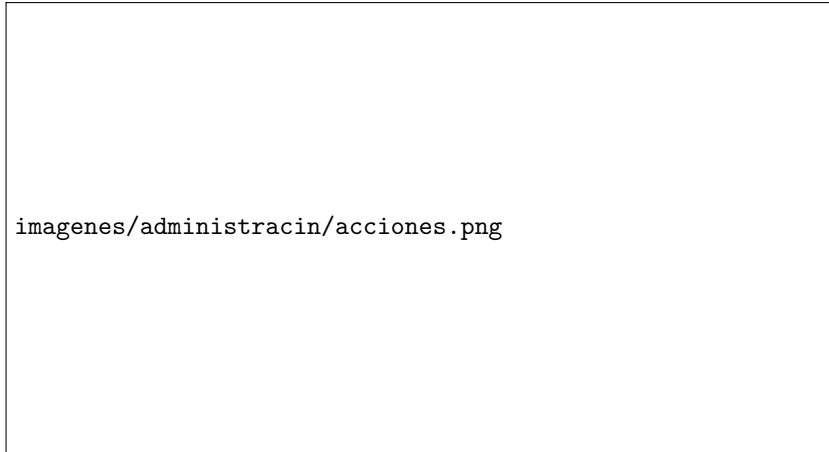
Los objetivos de las acciones de respuesta son los procesos, ficheros, endpoints (como aislar equipos) y redes (como bloquear IPs o dominios).

Cortex utiliza WebSockets para enviar las acciones (funciona mejor que HTTP). Se pueden iniciar acciones de respuesta desde *Action Center Page* o *Shortcut Menu* (**Endpoints** > **All endpoints**).

Se pueden limitar el acceso a acciones usando roles (*Setting* > *Configuration* > *Access Management* > *Roles*).

3.3.1. Action center

El **Action Center** contiene listas de objetos modificados por acciones completadas con éxito, como las listas de archivos en cuarentena, archivos bloqueados y permitidos, y endpoints aislados. Algunas de las acciones son:



`imagenes/administracin/acciones.png`

Figura 14:

Los estados de una acción se puede ver en la tabla **All Actions**, columna **Status** y son los siguientes:

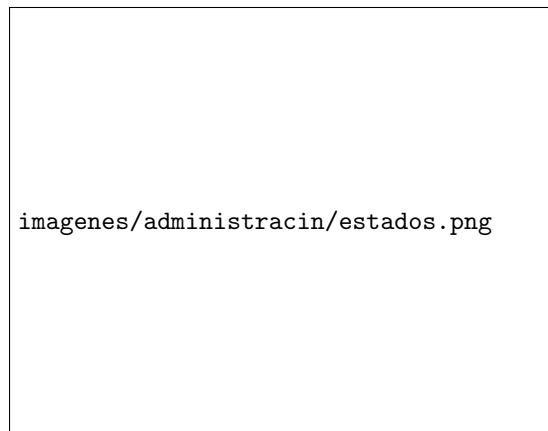


Figura 15:

Se pueden realizar acciones de seguimiento sobre una acción como restaurar un fichero, mover to allow list un hash de un fichero o una dirección IP o cancelar endpoint isolation.

3.3.2. Endpoint Response Actions

Se puede aislar el endpoint malicioso del resto de la red, permitirle solo unos procesos y cancelar el aislamiento.

Live Terminal Response Action para responder e investigar más a fondo una alerta asociada con un endpoint, inicia una sesión de Terminal en Vivo que establece una conexión con estado con el endpoint. Se pueden hacer las siguientes tareas:

- Task Manager para investigar o administrar procesos
- File Explorer para investigar o administrar archivo y realizar tareas como eliminarlas o recuperarlos.
- Línea de comando
- Python

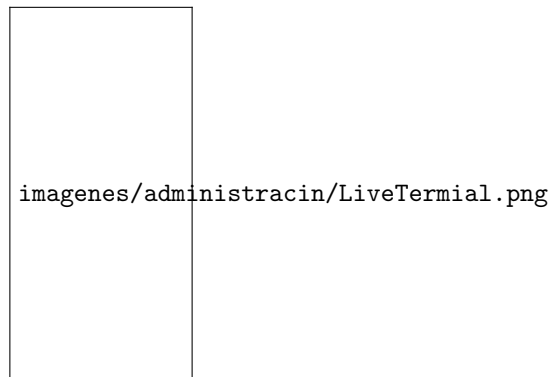


Figura 16:

3.3.3. Preguntas interesantes

1. *When does a response action expire?*

When an action times out before at least one targeted endpoint starts running the action

2. *On which page in the management console can you verify the signed-in user's Cortex role?*

The About page

3. *Which option is an example of instance-initiated actions available via the Cortex XDR WebSocket?*

Terminate a process

4. *Once an Endpoint has had Disable Capabilities initiated, how can it be reversed?*

Uninstall and reinstall the agent on the Endpoint

5. *Which Response Action can be taken from the Cortex management console?*

Isolate Endpoint

3.4. Advanced Response Actions

Algunas acciones de respuesta de Cortex requieren licencias, autorizaciones y configuraciones adicionales. Estas acciones incluyen sugerencias de remediación, ejecuciones remotas de scripts y EDL.

Para realizar estas acciones, se deben cumplir unos requisitos:

1. Autorización: algunos scripts solo los pueden ejecutar unos roles específicos
2. Configuración adicional
3. Compatibilidad con el sistema operativo

Las **Acciones de sugerencias de remediación** permiten revertir los cambios realizados por procesos maliciosos. Por ejemplo, puedes revertir archivos y

claves del registro modificados de forma maliciosa. Además, ten en cuenta que debe estar habilitada la recopilación mejorada de datos del endpoint. Estas acciones se encuentran en varios sitios:

- Pulsando botón derecho en process node dentro del Casuality View
- Actions menu of Causality View
- Los tres puntos en el menu of a case

La **Lista de sugerencias de remediación** se da al iniciar las sugerencias de remediación, se abre un cuadro de diálogo que muestra una tabla con entradas que presentan eventos de procesos maliciosos.

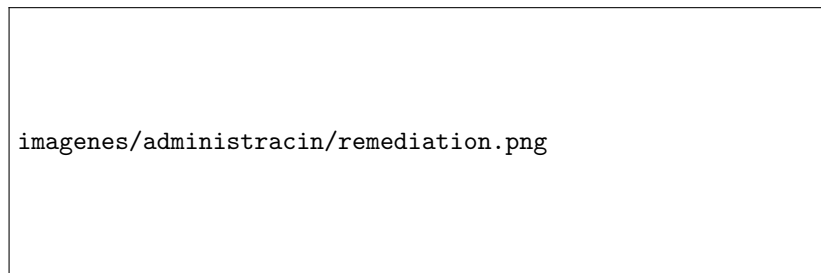


Figura 17: Caption

La columna **Remediación sugerida** muestra posibles acciones de remediación, incluida la remediación manual en los casos en los que Cortex no puede proporcionar una acción de remediación automática. Algunas remediaciones sugeridas son:

- Delete, Restore, or Rename File
- Delete or Restore Registry Value
- Terminate Causality
- Manual Remediation

3.4.1. Remote Scripts Execution

Puedes cargar y ejecutar de forma remota scripts en Python v3.7 *Investigation & Response > Response > Action Center > Agent Scripts Library*.

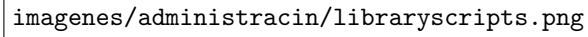
A rectangular box containing the text "imagenes/administracin/libraryscripts.png" in a monospaced font.

Figura 18: Caption

También se puede mapear el input y output de un script.

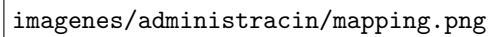
A rectangular box containing the text "imagenes/administracin/mapping.png" in a monospaced font.

Figura 19: Caption

Para ejecutar un script hay que hacer los siguientes pasos:

1. Haz clic derecho sobre un script en la Biblioteca de Scripts y selecciona Ejecutar para ejecutar el script.
2. En el paso Choose, introduce la entrada para tu script según lo definido durante la carga y haz clic en Next. En este ejemplo específico, IP (STRING) es el parámetro de la función (el punto de entrada del script) y 192.168.1.2 es el valor asignado a ese parámetro IP.



Figura 20: Caption

3. Seleccionar el endpoint
4. Ejecutar
5. Supervisar la acción Endpoint Script Execution desde All Actions en el Action Center. Revisa las columnas de la tabla All Actions y verifica: ACTION TYPE: Endpoint Script Execution y STATUS: Completed Successfully
6. Ver detalles

3.4.2. Enabling Cortex EDL (External Dynamic List) Service

Las **EDL (External Dynamic Lists)** son fundamentales para bloquear direcciones IP y nombres de dominio potencialmente dañinos. Una EDL es un tipo de lista de bloqueo en la que cada entrada, en una nueva línea, representa una dirección IP o un nombre de host que debe ser bloqueado.

El servicio de EDL de Cortex se accede mediante: *Settings > Configurations > Integrations > External Dynamic List Integration.*

Se pueden añadir IPs o dominios maliciosos a una EDL mediante *Action Center > External Dynamic List.*

A medida que agregas direcciones IP y dominios maliciosos a las listas EDL desde múltiples páginas, Cortex mantiene tus adiciones en dos listas accesibles desde *Investigation & Response > Response > Action Center > Currently Applied Actions > External Dynamic List..*

3.4.3. Preguntas interesantes

1. *What is a prerequisite for performing remediation suggestion actions in Cortex?*

- Enhanced endpoint data collection
- 2. *What is a key requirement for running remote scripts in Cortex?*
- Specific permissions for script execution
- 3. *Which log or data type is required by the Remediations Suggestions action?*
- Enhanced endpoint data
- 4. *What is an entry point in the context of Cortex Remote Script Executions?*
- Function name
- 5. *What settings can be edited on the **Integrations >External Dynamic List Integration** page in the management console?*
- Authentication
- 6. *Which entity best represents a typical consumer of Cortex EDL service?*
- PAN-OS NGFW device
- 7. *Which type of Cortex profile has a key setting that can affect how the Remediations Suggestions action works?*
- Agent Settings
- 8. **Where can the Remediation Suggestions action be found?**
- Causality Instance

3.5. Exclusiones y excepciones

3.5.1. Exclusión de incidencias

Una **regla de exclusión de incidencias** permite suprimir incidencias (issues) en Cortex. Para ver las ya creadas vamos a *Settings > Exceptions Configuration*.

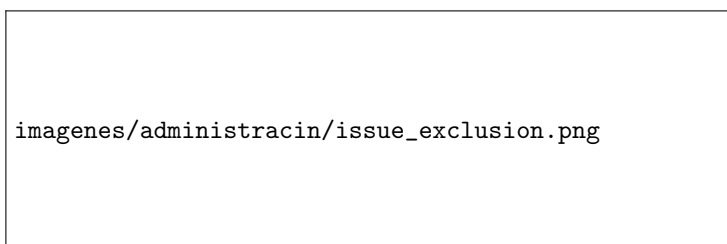


Figura 21: Caption

Casos e incidencias excluidas: el estado de un caso se ve afectado al excluir incidencias asociadas a dicho caso. Si el 100 % de las incidencias restantes de un caso se excluyen, el estado del caso cambiará automáticamente a **Resuelto**. Si se excluye menos del 100 % de las incidencias restantes de un caso, el estado del caso no cambiará automáticamente.

3.5.2. Excepción y perfiles de excepción

Una **exclusión** evita que las incidencias aparezcan en la consola de Cortex, pero los módulos continúan proporcionando protección. La protección sigue acti-

va, aunque ya no se generan incidencias relacionadas. Las exclusiones se utilizan para silenciar falsos positivos ruidosos.

Una **excepción** desactiva completamente la protección subyacente. Por lo tanto, no se generan incidencias porque la protección ha sido eliminada. Es decir, una exclusión silencia una incidencia mientras que una excepción elimina la protección. Existen varios tipos de excepciones.

En la consola de administración de Cortex, los **perfiles de excepciones** permiten personalizar la configuración de seguridad en los endpoints mediante la creación de excepciones específicas. Por ejemplo, se puede crear un perfil para cada sistema operativo.

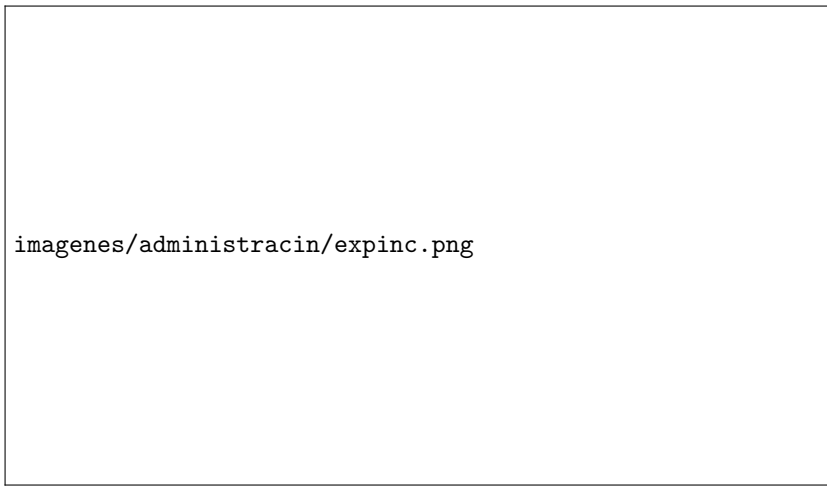
Una **excepción de proceso** para deshabilitar módulos específicos de Exploit Protection (EPM) y Malware Protection (MPM) en determinados procesos (*Settings > Exceptions Configuration > Legacy Agent Exceptions*).

Las **excepciones de soporte** son creadas para un cliente específico por el equipo de soporte con el fin de sobrescribir la configuración predeterminada de los módulos de protección.

El **análisis avanzado** se refiere al proceso automatizado de análisis de volcados de memoria en la nube. Esta función permite que las instancias de Cortex recuperen, carguen y analicen automáticamente volcados de memoria mediante un servicio de análisis en la nube. Los resultados obtenidos de este análisis proporcionan información clave sobre posibles amenazas.

3.5.3. Excepción de incidencias

Gestionar las incidencias de manera eficiente es fundamental para mantener una ciberseguridad sólida, y puedes optimizar este proceso mediante la creación de **excepciones de incidencias**.



imagenes/administracin/expinc.png

Figura 22: Caption

3.5.4. Excepciones globales

Las **excepciones globales** son una herramienta poderosa para gestionar incidencias y políticas en todos los endpoints. Se aplican de manera incondicional a todos los endpoints. Esto significa que, una vez configurada una excepción global, afecta a cada endpoint sin necesidad de reglas de política específicas.



Figura 23: Caption

3.5.5. Preguntas interesantes

1. *What is a key difference between an exclusion and an exception in Cortex?*
Exclusions suppress issues but maintain protection, while exceptions disable protection entirely.
2. *Which type of exception is received in JSON files?*
Global Exception
3. *What happens when an Advanced Analysis exception is created due to a benign verdict?*
The Endpoint Protection Manager (EPM) that terminated the process is disabled.
4. *How can you apply a specific exception to all Cortex instance endpoints?*
Create the exception in Global Exceptions
5. *How do you create an issue Exception?*
Right-click on an issue and select Create Issue Exception
6. *In which way can you create an Issue Exclusion?*
Create a new exclusion rule
7. *If an application on a single endpoint is crashing due to one of the Cortex XDR protection modules, which action would resolve it?*

Create an Exception Rule in that Endpoint's Exception Policy

3.6. Análisis integrado

3.6.1. Log Stitching (Unión de registros)

Una **incidencia** son creadas para enviar un comportamiento sospechoso. Mientras que un **log** es cualquier tipo de dato, no necesariamente un potencial ataque.

El **log-stitching** es la correlación entre logs y issues. Esto mejora la información proporcionada por las incidencias. Por ejemplo, puede añadir timelines o una cadena de casualidad (Cortex puede regenerar información de causalidad que muestra las interacciones entre procesos y recursos relacionadas con un ataque en forma de gráficos causales jerárquicos).

Recopilación Mejorada de Datos del Endpoint (EED): los agentes Cortex XDR Pro para Endpoints, también conocidos como Pro Agents, pueden recopilar registros de Enhanced Endpoint Data (EED) en los endpoints.

El agente XDR realiza tareas continuas como:

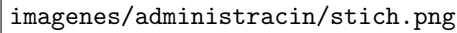
- Monitoreo del sistema operativo (OS)
- Muestreo de datos
- Recopilación y almacenamiento local
- Compresión
- Carga de información a la nube

Los registros recopilados se envían cada cinco minutos a la instancia de Cortex a la que el agente está conectado. Para acceder directamente a los datos recopilados, puedes crear consultas mediante el Query Builder en la consola de administración o utilizar XQL.

Puedes verificar el estado de la recopilación de registros y del log stitching revisando los atributos de la incidencia que se muestran en formato JSON.

Los datos que se recogen van desde operaciones de procesos hasta operaciones de red.

Stitched Issues in the Issues Table: se puede identificar las incidencias unificadas en la tabla de incidencias comprobando los atributos relacionados con la causalidad, como el nombre del propietario del grupo de causalidad (CGO), el firmante del CGO y el ID de causalidad (CID), que muestra el estado de la unificación.



imagenes/administracin/stich.png

Figura 24: Caption

Se puede verificar el estado de la recopilación de registros y de la unificación de registros revisando los atributos de la incidencia mostrados en formato JSON.

3.6.2. Motor de análisis

El CAE (**Cortex Analytics Engine**) (**ANALYTICS**) detecta y responde a amenazas ocultas posteriores a una intrusión que han evadido las defensas de red, antes de que comprometan los sistemas.

El proceso mediante el cual el motor analítico detecta anomalías usando analítica de comportamiento es el siguiente:

- Aprendizaje de comportamiento normal
- Comparar este comportamiento con otras actividades

El Motor de Analítica puede generar una incidencia para cualquiera de las siguientes tácticas de ataque, según lo definido por las tácticas de MITRE ATT&CK (por ejemplo, execution, persistence...).

El Motor de Analítica organiza sus actividades de analítica de comportamiento en unidades llamadas **detectores**. Cada detector está especializado en tipos específicos de ataque y genera un tipo de incidencia analítica cuando se detectan anomalías o comportamientos sospechosos.

Puedes ir a este motor de análisis de Cortex en *Settings > Configurations > Cortex – Analytic*.

3.6.3. Preguntas interesantes

1. *What type of data does Enhanced Endpoint Data (EED) provide in Cortex?*

Detailed endpoint data for deeper analysis

2. *Where does Cortex store the enhanced endpoint data log?*

The Cortex Instance

3. *What type of logs can be viewed directly from the Cortex management console?*

Issues audit logs

4. Which action is found under the Investigate Causality Chain right-click menu of stitched issues?

Open Timeline

3.7. Creando y administrando Queries

Las amenazas potenciales se investigan mediante threat hunting y la identificación de leads. Un **lead** es el primer indicio o punto de contacto con una amenaza potencial. Este indicio puede obtenerse de incidencias, información de amenazas y usuarios y endpoints.

Una incidencia (Issue) es una notificación inmediata que está disponible de forma directa. Cortex destaca por detectar y presentar estas incidencias con precisión, lo que permite actuar con rapidez. Mientras que un lead es un posible indicador de amenaza que requiere mayor análisis y definición.

El **threat hunting** es el proceso de análisis que usa Cortex para encontrar amenazas escondidas en los datos de Cortex mediante herramientas de investigación. Hay que seguir el siguiente orden:

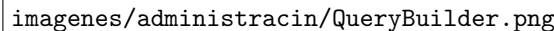
1. Query builder (para buscar leads)
2. Casuality and timeline (investigación más a fondo)
3. BIOCs (crear alertas basadas en atributos)

Utiliza **Query Builder** para crear consultas que busquen amenazas desconocidas en los datasets de Cortex. Dado que la consola de administración no proporciona una tabla dedicada para los registros (logs), las consultas de búsqueda son la única forma de visualizar los logs dentro de los datasets.

Existen dos tipos de queries:

1. Templated-Based Query: incluyen campos y conjuntos de campos predefinidos según la plantilla seleccionada. Puedes especificar valores para estos campos y añadir otros adicionales para refinar la búsqueda
2. XQL Queries: se puede buscar cualquier atributo de registro disponible en los conjuntos de datos, así como correlacionar registros utilizando XQL

Se pueden realizar en la página de Query Builder (*Investigation & Response > Search > Query Builder*).



imagenes/administracin/QueryBuilder.png

Figura 25:

Las **plantillas de consulta incluyen** campos y conjuntos de campos predefinidos según la plantilla seleccionada. Puedes especificar valores para estos campos y añadir otros campos para refinar la búsqueda. Para empezar con las consultas, puedes crear una plantilla de consulta vacía sin valores especificados. Los resultados de la consulta incluirán todos los campos del conjunto de campos específico de la plantilla. Puedes refinar la consulta y ejecutar consultas posteriores para acotar tu búsqueda.

En Cortex, puedes investigar las conexiones entre procesos, procesos hijos y endpoints mediante la creación de consultas (queries). Por ejemplo, puedes construir una consulta para buscar procesos que se hayan ejecutado en un endpoint específico.

En el **Legacy Query Builder**, una entidad es un tipo específico de dato que puedes consultar, como: Process, File, Network, Image Load, Registry, Event Log, Network Connections, Authentications o All Actions. Creas consultas sobre estas entidades y especificas el tipo de acción que deseas buscar dentro de cada una. Por ejemplo:

- En una consulta de File, puedes especificar el tipo de actividad del archivo, como create, read o delete.
- En una consulta de Registry, puedes seleccionar acciones como Key Create o Value Set.

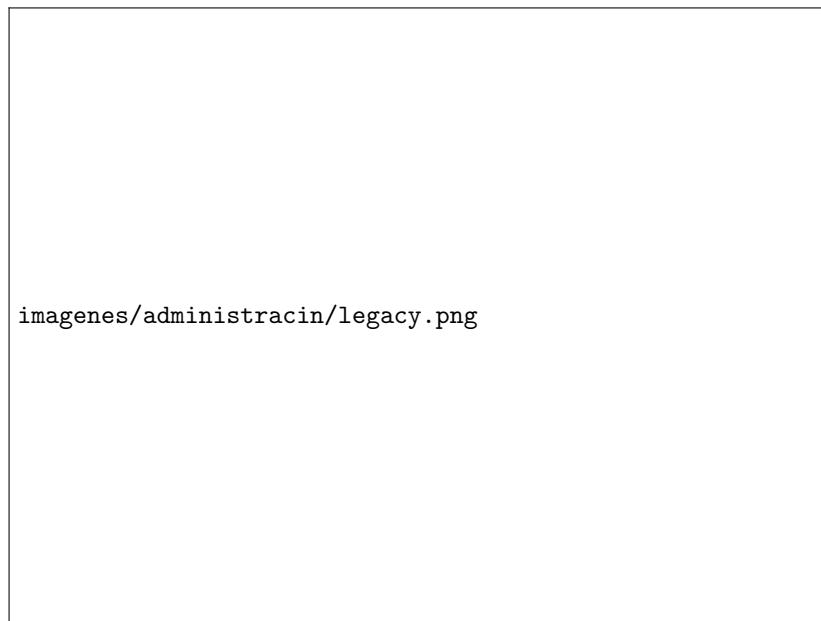


Figura 26:

3.7.1. Administración de Queries

La página **Query Center** de la consola de administración muestra una tabla con las consultas ejecutadas. Desde allí puedes gestionar tus consultas (*Investigation & Response > Search > Query Center*). Cada query tiene una acción (Query Action) dando click derecho sobre una query.



Figura 27:

Por ejemplo, al seleccionar “Show Results” en el menú contextual, puedes ver la consulta y su resultado con mayor detalle.



Figura 28:

La página **Scheduled Queries** muestra una tabla con las consultas programadas filtradas. Los atributos de las consultas programadas se presentan en columnas, que pueden configurarse desde el menú de ajustes de la tabla. El **Query ID** es el identificador único en la tabla de Scheduled Queries, mientras que el **Execution ID** es el identificador único en la tabla de Query Center.

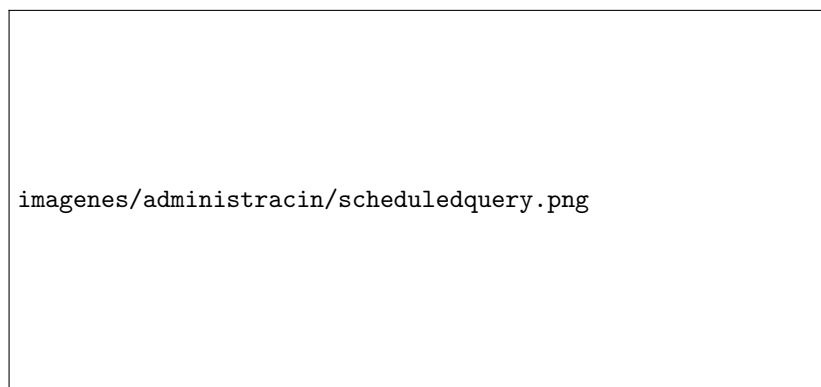


Figura 29: Caption

3.7.2. Preguntas interesantes

1. *What type of queries can be created using the Query Builder?*

Simple form-based queries and XQL queries

2. *On which Cortex management console page can you rerun a query?*

Query Center

3. *If a query is not displayed in the Query Center after you build it in the Query Builder, which condition is the most likely cause for it not to be displayed?*

The query is scheduled and has not run yet.

4. *Which of the following best describes a "lead" in the context of threat management?*

A potential indicator requiring further investigation.

5. *Which of the following is a function of the Legacy Query Builder?*

Searching on specific entities like files and processes

6. *How does Query Builder's template-based approach assist users?*

It allows users to create effective queries without using XQL.

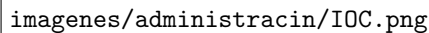
3.8. Reglas básicas

Reglas Basadas en Indicadores de Amenaza Personalizados (Rules Based on Custom Threat Indicators): puedes crear tus propias reglas en Cortex especificando las características de los indicadores de amenaza (threat indicators) como criterios de la regla. Ten en cuenta que una forma de identificar indicadores de amenaza es buscar leads en los datasets de Cortex o indicadores de amenaza pueden obtenerse de fuentes confiables de inteligencia de amenazas (threat intelligence).

La **coincidencia de reglas (rule matching)** se basa en dos componentes: la condición de la regla (**rule condition**) y los flujos de logs entrantes (**incoming log streams**) almacenados en los datasets. Las reglas se evalúan comparando sus condiciones con los datos que ingresan y se almacenan en los datasets.

3.8.1. Reglas IOC

Las **reglas IOC** de Cortex están diseñadas para detectar malware conocido y simple. En la consola de administración, puedes crear y gestionar reglas IOC desde: *Threat Management > Detection Rules > IOC*.



imagenes/administracin/IOC.png

Figura 30:

Los atributos clave estas reglas son:

1. Indicator: por ejemplo, el nombre del fichero, el hash, una dirección IP...
2. Type: tipo de indicador de amenaza

3. Day of expiration
4. Reputation: nivel de confiabilidad de la regla IOC, y va desde Completamente confiable hasta No se puede evaluar la confiabilidad.

3.8.2. Reglas BIOC

Las **reglas BIOC** se crean para detectar amenazas avanzadas basado en el comportamiento (*Threat Management > Detection Rules > BIOC*).

Los atributos clave son:

- Global rule ID
- Name
- Type
- Behavior: condición por la que se extrae esta incidencia del flujo de datos
- Severity
- Number of issues
- Source
- MITRE ATT&CK Tactic

Agregar una **regla BIOC** consta de dos pasos consecutivos: definir la condición de la regla y establecer un nombre para la regla (se hace de manera similar a hacer una query, desde el XQL Builder o desde las plantillas). Especificar otros parámetros de la regla, como los campos relacionados con la incidencia (issue-related fields).

La siguiente captura muestra la forma de un fichero de tipo BIOC:

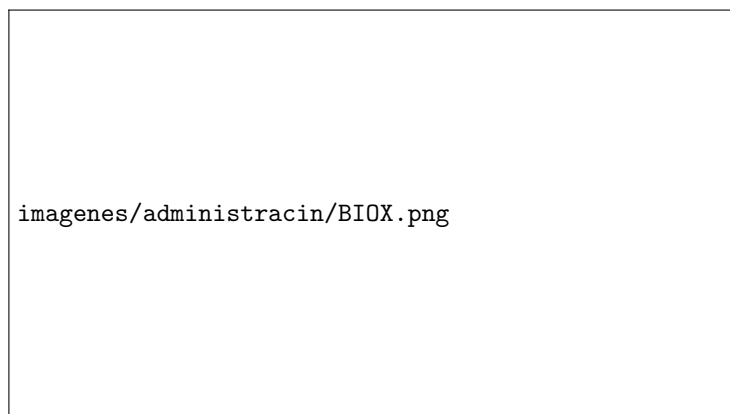


Figura 31:

3.8.3. Custom Prevention Rules

Las **Reglas de prevención personalizadas** son reglas de BIOC que son transferidas a los endpoints usando perfiles restringidos.

Gestión Separada de Prevención y Detección: para ofrecer mayor granularidad, Cortex permite gestionar la detección de forma separada de la prevención al deshabilitar una regla BIOC.

3.8.4. IOC/BIOC suppression rules

Puedes crear una **regla de supresión IOC o BIOC** para definir condiciones bajo las cuales no debe producirse coincidencia desde: *Settings > Exceptions Configuration > IOC/BIOC Suppression Rules*.

Aunque puedes deshabilitar una regla IOC o BIOC directamente desde el menú contextual, las reglas de supresión permiten definir excepciones de manera más detallada.

3.8.5. Reglas de correlación

Las **reglas de correlación** son una funcionalidad avanzada de Cortex que permiten detectar amenazas complejas mediante el análisis de correlaciones entre múltiples eventos provenientes de diversas fuentes de datos basado en XQL.

Los componentes clave de las reglas de correlación son:

- Time Schedule
- Issue Suppression Settings (elimina fatiga)
- Resulting Actions
- Issues Fields Mapping
- MITRE ATT&CK Association

Para garantizar un **rendimiento** y una **eficacia** óptimos, las reglas de correlación cuentan con ciertas limitaciones y capacidades de monitoreo:

- Deshabilitación Automática de Reglas debido al Alto Volumen
- Dataset correlations_auditing: puedes supervisar la ejecución de las reglas utilizando el dataset correlations_auditing, que proporciona información sobre el rendimiento y los resultados de las reglas
- Limitaciones de Consultas y Gestión de Errores: ayuda a identificar y resolver errores, mostrando el número de errores detectados y permitiendo filtrar para visualizar solo las reglas con errores

La gestión continua de las reglas de correlación es esencial para mantener una estrategia eficaz de detección de amenazas. Algunas acciones son:

- Visualización y gestión de reglas

- Filtrado y búsqueda de reglas
- Monitoreo del rendimiento de las reglas
- Actualización de las asociaciones con MITRE ATT&CK

3.8.6. Preguntas interesantes

1. *Which type of Cortex rule causes Detection type alerts to be generated?*
BIOC
2. *Which attribute is among the attributes of an IOC rule?*
Reputation
3. *What functionality does Cortex provide for managing lookup datasets through correlation rules?*
Adding entries to lookup datasets
4. *Which type of Cortex rule can use threat indicators from trusted threat intelligence streams?*
IOC
5. *Which attribute uniquely identifies an IOC rule in the IOC Rules table?*
Indicator
6. *Which Cortex dataset can BIOC rules be checked against?*
cloud_audit_log
7. *Which of the following is a scope for IOC/BIOC Suppression Rules?*
Specific BIOCs

3.9. Alertas y detección

3.9.1. Cortex Threat Detection Strategy

Cortex desempeña un papel fundamental al mejorar la capacidad de una organización para detectar y responder eficazmente a las amenazas de seguridad, combinando protección de endpoints, seguridad de red e inteligencia avanzada de amenazas. Actúa como la piedra angular de una estrategia moderna de detección de amenazas, permitiendo a las organizaciones identificar, investigar y mitigar de forma proactiva una amplia variedad de amenazas de ciberseguridad.

Las **reglas de detección** permiten identificar indicadores específicos de amenaza y patrones de actividad maliciosa. Normalmente, constan de un conjunto de condiciones que deben cumplirse para que se identifique una posible amenaza. Por ejemplo, una regla de detección puede generar una incidencia si un usuario intenta acceder a un recurso sensible fuera del horario laboral.

Las **issues** son notificaciones generadas cuando se detectan eventos o condiciones de seguridad específicas, como posibles amenazas o anomalías. Funcionan como indicadores tempranos de problemas de seguridad o actividad inusual en el entorno, destacando eventos que se desvían del comportamiento normal.

Mientras que los **cases** representan una clasificación de nivel superior de los eventos de seguridad. Suelen agrupar múltiples issues relacionados y abordan problemas de seguridad más amplios. Su función principal es organizar y coordinar eventos que, en conjunto, constituyen una brecha o incidente significativo.

3.9.2. Casos de uso en cortex y pseudocódigo

Un **caso de uso** puede ser cualquier elemento que aporte valor en materia de seguridad, comenzando por la prevención como objetivo principal y extendiéndose hasta la telemetría que proporciona visibilidad y conocimiento del entorno.

En el contexto tradicional de un SIEM (Security Information and Event Management), esta tecnología está diseñada para generar alertas cuando se eluden políticas, directrices o controles de seguridad, lo que podría permitir la ocurrencia de un ataque. El caso de uso es la descripción de aquello sobre lo que el SIEM debe generar una alerta.

Los casos de uso tienen que estar bien definidos, donde a veces es mejor tener varias reglas que una sola compleja.

El **pseudocódigo** es un lenguaje o notación de programación de alto nivel e informal que utilizan programadores y desarrolladores para planificar y describir algoritmos o la lógica de un programa. No está destinado a ser ejecutado por una computadora; su propósito es expresar la lógica del programa de una manera más legible y estructurada para las personas, antes de escribir el código en un lenguaje de programación específico.

En Cortex, la clave está en definir pasos de alto nivel (pseudocódigo) sobre qué debe monitorearse y protegerse, expresándolo de una forma que sea fácilmente comprensible para todas las partes interesadas, desde personal no técnico hasta expertos en seguridad.

Cortex Query Language (XQL) es un lenguaje de consulta diseñado para consultar datos ingeridos en Cortex. Se utiliza para investigar y analizar eventos de seguridad de red y de endpoints. XQL estructura las consultas en etapas, donde cada etapa realiza una operación específica. Las etapas se separan mediante el carácter de tubería (`|`).

Los componentes de este lenguaje son:

- Stages: realizan operaciones específicas durante la ejecución de una consulta. Por ejemplo, la etapa *dataset* especifica el conjunto de datos sobre el cual se ejecutará la consulta.
- Funciones: sirven para convertir datos en el formato deseado.
- Operadores (por ejemplo, booleanos)

XQL es un lenguaje de consulta que permite buscar información contenida en una amplia variedad de fuentes de datos. De forma predeterminada, puedes realizar consultas sobre los registros sin procesar de Cortex XDR utilizando el dataset `xdr_data`.

Al trabajar con XQL, es común desarrollar un conjunto de comandos frecuentes que facilitan la creación de consultas más avanzadas. Uno de ellos es el comando `alter`, que permite crear nuevos campos dentro de una consulta. Por ejemplo: `| alter X=.example one", B=.example two"`

Se puede acceder al entorno de desarrollo XQL desde el Query Builder (*Investigation & Response > Query Builder*) o desde el Query Center (*+New XQL*).

3.9.3. Cortex Threat Detection Tools

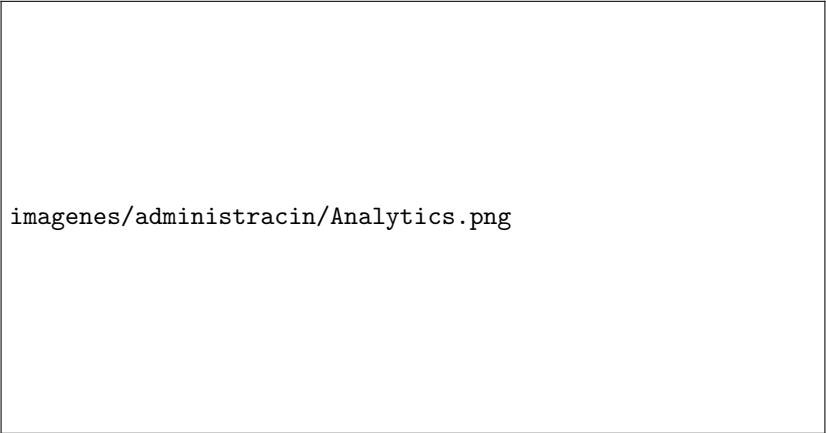
Mediante las reglas:

- **IOCs:** es una pieza de información o un patrón que indica la presencia o posible presencia de actividad maliciosa dentro de un sistema o red. Se utiliza en ciberseguridad para detectar e identificar amenazas, lo que permite a los profesionales de seguridad responder y mitigar el impacto de un ataque. Los IOCs pueden generarse a partir de diversas fuentes, incluidas fuentes de inteligencia de amenazas, investigación de seguridad y análisis interno
- **BIOCs:** diseñadas para identificar indicadores de compromiso de comportamiento, que abarcan diversas tácticas, técnicas y procedimientos utilizados por posibles amenazas. Al comprender los distintos tipos de comportamiento que pueden detectar las reglas BIOC, puedes configurar eficazmente reglas que se alineen con los objetivos de seguridad de tu organización. Este conocimiento te permite identificar y responder de forma proactiva a posibles amenazas basándote en sus comportamientos observables, en lugar de depender únicamente de indicadores de compromiso tradicionales como hashes o firmas
- **Correlation Rules:** ayudan a analizar correlaciones de múltiples eventos provenientes de varias fuentes utilizando el motor basado en XQL. Permiten crear reglas programadas y generar incidencias a partir de estas reglas dentro de un intervalo de tiempo y una programación definidos

3.9.4. Analíticas de Cortex

Cortex Analytics implica el uso de datos, algoritmos avanzados y técnicas de machine learning para detectar, analizar y responder de manera proactiva a amenazas y anomalías de seguridad en un entorno de red.

La **analítica** es un enfoque poderoso que permite a las organizaciones detectar, analizar y responder eficazmente a las amenazas. Actúa como un guardián vigilante de los activos digitales, monitoreando continuamente la actividad de la red y proporcionando información que ayuda a proteger contra una amplia variedad de amenazas cibernéticas. En esencia, la analítica de seguridad empresarial aprovecha datos y algoritmos sofisticados para identificar anomalías, desviaciones y patrones que puedan indicar posibles brechas de seguridad o actividades maliciosas dentro de la red.



imagenes/administracin/Analytics.png

Figura 32:

3.9.5. Preguntas interesantes

1. *What are the three rules that play a key role in Cortex threat detection and response? (Choose three.)*

Indicators of compromise, Correlation Rules and Behavioral indicators of compromise

2. *What are two useful Cortex analytics use cases? (Choose two.)*

Insightful threat hunting and Advanced threat detection

3. *What is the primary purpose of Behavioral Indicators of Compromise (BIOC's)?*

To focus on the behavior and actions of attackers

4. *Which aspect of threat detection does Cortex primarily focus on?*

Lateral movement

3.10. Administración de casos

Un **case** es la agrupación de distintos artefactos, activos e issues que se originan a partir de un único evento o ataque. Es una forma de organizar y gestionar la información relacionada con la seguridad dentro de la plataforma Cortex.

¿Cómo crea Cortex un Case? Cortex utiliza reglas predefinidas para determinar qué issues deben asociarse a un case específico. Estas reglas consideran diversos atributos del issue, tales como: la fuente del issue, el tipo de issue o el período de tiempo en que ocurrió.

Si varios issues forman parte de la misma cadena de causalidad y ya existe un case abierto para ellos, se agrupan dentro de ese case existente. En caso contrario, se crea un nuevo case para los issues entrantes.

La **gestión de casos** en Cortex implica revisar y responder a los incidentes de seguridad de manera eficiente. Cortex proporciona diversas funcionalidades

y herramientas para:

- Clasificar (triage) los casos según su criticidad.
- Investigar los eventos, artefactos y activos asociados.
- Gestionar el ciclo de vida del case hasta su resolución.

3.10.1. Cases in Cortex

Los casos se pueden ver en *Cases and Issues > Cases*. En la vista detallada hay más información acerca de los casos.



Figura 33: Caption

Las diferentes vistas de case permiten investigar y ejecutar acciones sobre los casos, tales como: actualizar los detalles del case, asignar o modificar la puntuación (score), cambiar el estado, resolver el case y realizar otras acciones de gestión.

Campos Personalizados, Layouts y Reglas de Layout en Cases En Cortex es posible crear:

- Campos personalizados de case
- Layouts personalizados de case
- Reglas de layout

Los **layouts personalizados** pueden incluir tanto campos estándar (out-of-the-box) como campos personalizados. Los layouts se aplican a los casos según reglas de layout, que determinan cuándo y cómo se asigna cada diseño. Para utilizar estas funcionalidades, es necesario tener configurado el control de acceso basado en roles (RBAC) para campos, tipos y layouts.

Para crear un campo personalizado, navega a *Settings > Configurations > Object Setup > Cases > Fields*. Pulsa *+ New Field* para añadir un campo nuevo.



Figura 34:

Los **layouts personalizados de case** permiten definir qué campos y botones se muestran para distintos tipos de casos. Para hacerlo, navegar a *Settings > Configurations > Object Setup > Cases > Layouts* y *+ New Layout*.

Los layouts de case se aplican según **reglas de layout**. Al usar una regla de layout, puedes asignar un layout personalizado en función de ciertos criterios del case (por ejemplo, un layout específico para casos con alta severidad). Navegar a *Settings > Configurations > Object Setup > Cases > Layout Rules*.

3.10.2. Casos SLAs (Service Level Agreement)

Cortex permite a las organizaciones realizar un seguimiento eficiente de los **Indicadores Clave de Desempeño (KPIs)** asociados a los casos mediante la funcionalidad **Case SLAs**.

Esta característica proporciona información en tiempo real sobre el rendimiento operativo y favorece la alineación con los objetivos establecidos, ayudando a las organizaciones a supervisar y evaluar sus KPIs.

Case SLAs permite asociar SLAs específicos a casos individuales. Estos pueden visualizarse, filtrarse y ordenarse fácilmente directamente desde la vista de Casos, facilitando su seguimiento y gestión.

Un SLA puede definir, por ejemplo:

1. Tiempo máximo para asignar un case

2. Tiempo máximo para responder a un incidente
3. Tiempo máximo para resolver un case

3.10.3. Investigando artefactos y activos

Cortex proporciona herramientas potentes para investigar y analizar distintos tipos de **artifacts y assets**, tales como:

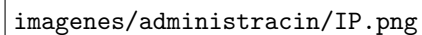
- Direcciones IP
- Activos de red
- Hashes de archivos y procesos

Esta funcionalidad agiliza el proceso de investigación, permitiendo a los analistas correlacionar información rápidamente y tomar decisiones de forma más eficiente.

Por ejemplo, si queremos analizar una dirección IP, la vista de IP Address en Cortex simplifica el proceso de investigación y respuesta relacionado con direcciones IP. Ofrece un resumen consolidado de toda la información disponible sobre una IP específica dentro de un período determinado:

- Últimas 24 horas
- Últimos 7 días

Esta vista integral permite evaluar rápidamente si una dirección IP está asociada con actividad maliciosa.



imagenes/administracin/IP.png

Figura 35: Caption

3.10.4. Preguntas interesantes

1. *How does Cortex group issues into cases?*

Using predefined rules that consider issue attributes

2. *Which view in Cortex provides a consolidated summary of all available information about a specific IP address?*

IP Address View

3. *How does the `.Executions` tab in Cortex help analysts investigate issues?*

It shows the entire process execution chain leading to the issue

4. *How do external integrations within Cortex enhance the threat investigation process?*

By displaying WildFire-issued verdicts for Key Artifacts in each case

5. *Why is case management important?*

To maintain the confidentiality, integrity, and availability of data and systems

6. *What feature allows you to assign a case layout based on the case?*

Layout rules

7. *Which two are the thresholds for cases in Cortex?*

30 days after the case was created and 14 days since the last issue in the case was detected

8. *What feature allows you to assign a case layout based on the case?*

Layout rules

3.11. Análisis y colaboración

3.11.1. War Rooms

Los **War Rooms** en Cortex centralizan todas las acciones de investigación, registros y colaboración relacionados con los playbooks.

Pueden entenderse como una línea de tiempo interactiva de la respuesta automatizada a un case, donde se registra cada acción y decisión tomada.

Los analistas pueden utilizar los War Rooms para:

- Agregar comentarios
- Colaborar con miembros del equipo
- Ejecutar comandos manuales mediante la CLI

Cada case y cada issue tiene su propio War Room:

- El **War Room del case** ofrece una visión completa de la investigación, facilitando la colaboración y la ejecución de playbooks.
- El **War Room del issue** proporciona una vista más enfocada, mostrando un resumen del case, los issues maliciosos y los artifacts relacionados.

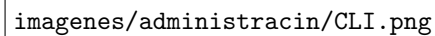
El contexto de los datos está en formato JSON.

3.11.2. Command Line Interface

La función de CLI gráfica se encuentra en la parte inferior de la interfaz de War Rooms. Permite ejecutar comandos y scripts directamente desde el entorno de investigación.

La CLI también es compatible con la funcionalidad ChatOps de la plataforma y es un componente fundamental para:

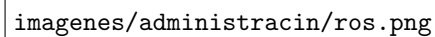
- Probar automatizaciones personalizadas
- Depurar scripts
- Desarrollar y validar playbooks personalizados



imagenes/administracin/CLI.png

Figura 36:

Hay que usar ! para empezar los comandos que son automáticos y @ para comunicarte con otros miembros del equipo (ChatOps).



imagenes/administracin/ros.png

Figura 37:

3.11.3. Context Data

Los **datos de contexto**, a menudo denominados “contexto”, se almacenan para cada incidencia y/o caso.

El contexto de una incidencia o caso es un repositorio en formato JSON para los datos de salida de automatizaciones, integraciones y comandos de playbooks. El contexto también almacena todos los datos asociados con la creación de la incidencia o caso. Sirve para capturar o compartir datos

3.11.4. Preguntas interesantes

1. Which statement describes the Case War Room?

There is a unique Case War Room for each available active case.

2. Which of the following is a War Room available in Cortex?

Issue War Room

3. Which of the following is a use for context data?

Capture issue and command data in structured format

4. Which of the following is a place you can find the Command Line Interface (CLI)?

The bottom of the Case War Room

3.12. Forensics

Después de un ataque, la recopilación e investigación sobre el mismo se llama forense. Se puede acceder en Cortex desde **Investigation & Response > Forensics**.

Los pasos a seguir para crear un caso forense son los siguientes:

1. Crear una investigación: una investigación consiste en recoger datos de uno o más endpoints.
2. Crear colecciones. Hay dos tipos de colecciones:
 - a) Hunt Collection: recolecta artefactos de diferentes endpoints. Puedes crear uno y luego ver los datos.
 - b) Triague Collection: va más profundo que hunt, su objetivo son los datos más útiles de un endpoint.
3. Cerrar la investigación

3.12.1. Características forenses

- Permisos: Editar o Ver
- Añadir búsquedas personalizadas
- Configurar la UTM zona horaria
- Se puede exportar datos

3.12.2. Preguntas interesantes

1. *You are investigating a potential phishing attack and need to identify which users across your Windows workstations may have executed a specific suspicious file attachment. You want to search for this activity across many endpoints to determine the breadth of the potential compromise. Which type of collection is best suited for searching for a specific activity across a large number of hosts to find out where and when it occurred?*

Hunt collection

2. *After completing an investigation into a data exfiltration event, you need to ensure the collected forensic evidence is saved securely for long-term retention or potential offline analysis. How can you typically save the forensic data from a completed investigation collection for these purposes?*

Export the data using the available download or export icons

3. *You have initiated a Triage collection on an endpoint. You check the collection status and you see a list of actions performed by the search, including artifact type, path, status, and details. What does the 'Status' field primarily indicate for these actions?*

The ingestion status and whether the action timed out, failed, or succeeded

4. *You are reviewing the results of a Hunt collection focused on process execution and you notice an executable running from a user's temporary directory that appears suspicious based on external threat intelligence. You want to highlight this finding for other analysts collaborating on the investigation. How can you mark this for further investigation and collaboration?*

Right-click the item and choose "add to investigation timeline" to flag it with a tag.

5. *You are preparing to conduct a forensic investigation in XSIAM to document the timeline of activities related to an incident that spans across different geographical locations with varying time zones. What time zone setting is generally recommended for forensic investigations to avoid timeline issues, such as those caused by daylight savings?*

Coordinated Universal Time (UTC)

6. *You are unable to set up user permissions. What do you need enabled in order to do so?*

Scope-Based Access Control (SBAC)

7. *A critical issue indicates potential malware execution on a few key servers. As a SOC analyst, you need to perform a deep dive analysis on these specific endpoints to gather detailed system information, including full file listings and registry hives, to understand the full scope of activity on these hosts. Which type of collection should you create within an investigation to achieve this goal?*

Triage collection

8. *Your team has completed the analysis for an investigation and is ready to finalize it. You need to close the investigation in Cortex. After you close an investigation, what happens, and what option do you have regarding its deletion?*

It enters a 'closed pending' status and will be automatically deleted after 24 hours, but you have the option to reopen it during this grace period

9. *You are reviewing an investigation that contains multiple Hunt and Triage collections and you want to quickly see flagged artifacts across all collections, view a consolidated timeline of events, and identify key findings such as potentially compromised endpoints, users, or malware. Which features or tabs within the investigation view consolidate and present this summarized analysis information?*

The Issues, Timeline, and Key Assets and Artifacts tabs.

10. *You are attempting to create a new investigation in the Cortex Forensics add-on, but the option to create an investigation is not available to you. What is the most likely reason you are unable to create an investigation?*

You do not have a role with forensics permissions set to view or edit.

4. Administración de la plataforma

4.1. Portafolio de Cortex overview

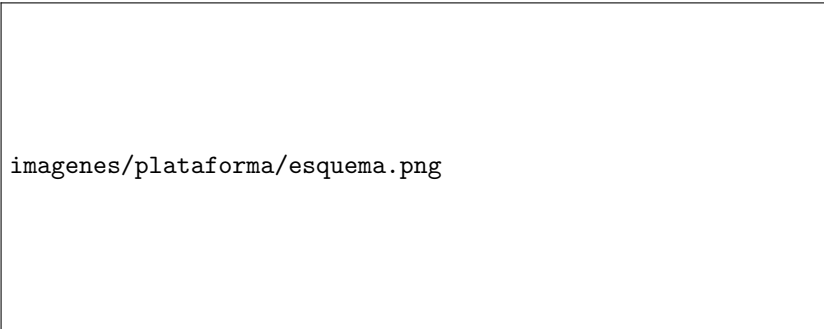
4.1.1. Problemas actuales

Los **silos de datos** son colecciones de información aisladas dentro de una organización que impiden su intercambio efectivo entre departamentos o sistemas.

El principal problema es que existe demasiada información, demasiados silos y poca visibilidad, lo que dificulta la detección de ataques en tiempo real. Por ejemplo:

- Los datos de red se envían al sistema de Network Traffic Analysis (NTA).
- Los datos de endpoints se almacenan en XDR.
- Algunos registros se envían al SIEM (Security Event and Incident Management).
- Los datos de identidad se encuentran en otra plataforma distinta.

Este ejemplo muestra cómo la automatización puede potenciar a los analistas del SOC al reducir la carga de ingestión y procesar grandes volúmenes de datos, transformándolos en las recomendaciones más relevantes y accionables.



imagenes/plataforma/esquema.png

Figura 38:

4.1.2. Cortex XDR

Cortex XDR mejora las capacidades de seguridad mediante funcionalidades únicas, como la eliminación de silos de datos y el uso de analítica global para la detección de amenazas. Es líder en prevención de amenazas, detección, investigación y capacidades de respuesta. Puede prevenir amenazas conocidas y desconocidas, detectar amenazas avanzadas (IA + BIOC) o reducir el tiempo de investigación.

4.1.3. Cortex XSOAR

Cortex XSOAR es una plataforma de orquestación, automatización y respuesta de seguridad (SOAR) que unifica la gestión de casos, la automatización, la colaboración en tiempo real y la gestión de inteligencia de amenazas, dando soporte a los equipos de seguridad a lo largo de todo el ciclo de vida del caso.

Alguno de los casos de uso típicos son:

- Respuesta a phishing
- Investigación y remediación de malware
- Administración de incidencias de vulnerabilidades
- Administración de inteligencia de amenazas
- Seguridad en red
- Seguridad en cloud

4.1.4. Cortex XSIAM

Además de lo aprendido sobre Cortex XDR y Cortex XSOAR, es posible que también estés familiarizado con otras categorías de productos de seguridad, como:

- Attack Surface Management (ASM)
- Threat Intelligence Management (TIM)

Cortex XSIAM integra todos los componentes clave utilizados en un SOC moderno, ofreciendo una plataforma unificada para gestionar todas las necesidades de seguridad de una organización. Su objetivo es consolidar detección, análisis, automatización, inteligencia y gestión de exposición en un único entorno operativo.

4.1.5. Cortex Cloud

Para afrontar los crecientes desafíos de seguridad que enfrentan las organizaciones en la nube, la plataforma Cortex ofrece **Cortex Cloud**, una plataforma unificada de seguridad en la nube que integra las capacidades de Cortex y Prisma Cloud.

Esta integración proporciona seguridad integral y en tiempo real, abarcando desde el código, pasando por la infraestructura en la nube, hasta el SOC.

4.1.6. Preguntas interesantes

1. *Which statement describes the main challenge that most Security Operations Centers (SOC) face when using traditional SOC tools?*

Sorting through multiple data silos manually to identify threats

2. *Which Cortex XSOAR use case provides the most value to Security Operations Center (SOC) teams?*

Automating phishing responses

3. *What is the most notable way in which Cortex XSIAM uses machine learning (ML) and artificial intelligence (AI)?*

Applies pattern recognition on large amounts of ingested data and positions the analyst to make important high-level decisions

4. *Which statement best describes how Cortex XSIAM can help save costs for organizations?*

Consolidates multiple security products into a single platform

5. *Which Cortex XDR function has the largest impact in reducing investigation time of security incidents?*

Stitches data from multiple sources together to form a unified story

4.2. Componentes de Cortex

4.2.1. Cortex Activation and Access

Una **instancia** de Cortex se crea por cada tenant, que puede representar una organización, una empresa o un equipo. La instancia se crea en Google Cloud Platform (GCP) mediante un proceso de activación de instancia. La activación de instancia y la activación del tenant hacen referencia a la misma tarea.

Las organizaciones suelen beneficiarse de mantener múltiples instancias. Una práctica común recomendada es crear instancias separadas para entornos de prueba y de producción. La activación de una instancia de Cortex requiere una licencia en forma de número de serie.

Los usuarios de Cortex pueden interactuar con sus instancias mediante la consola de gestión de Cortex, la interfaz de programación de aplicaciones (API) de Cortex y diversas integraciones externas.

Debes estar autenticado y autorizado para poder interactuar con las instancias de Cortex.

Los clientes de Palo Alto Networks pueden acceder al **Portal de Soporte al Cliente** para realizar todas las tareas relacionadas con los productos, como crear un caso de soporte, registrar un dispositivo, gestionar activos como licencias y números de serie, y descargar software y actualizaciones dinámicas.

Puedes utilizar **Cortex Gateway** para gestionar tus instancias de Cortex, lo que incluye:

- Activar nuevas instancias
- Visualizar y acceder a instancias autorizadas
- Controlar la autorización de las instancias mediante RBAC

Con **RBAC (Role-Based Access Control)** puedes otorgar permisos a los usuarios asociándolos a roles. Además de los roles predefinidos, es posible crear roles personalizados que pueden utilizarse en todas las instancias.

4.2.2. Preguntas interesantes

1. In which communication protocol does each request occur independently, without any information about previous requests?

Stateless

2. What is the primary role of the Cortex Management Console?

Investigating security incidents, managing policies, updating agents, and generating reports

3. In which two locations is instance admin rights granted for Cortex products?

Cortex Gateway and Cortex Console

4. What is the purpose of the Cortex Gateway?

Managing Cortex roles, instance activation, and RBAC-based authorization

5. Which URL do you use to access the Cortex Gateway to view or activate your tenants?

<https://cortex-gateway.paloaltonetworks.com/signin/>

6. Which condition is required to access a Cortex instance?

Access to the Cortex Gateway has been established.

7. What are the three ways users can interact with their Cortex XDR instances?

The management console, the API, and external integrations

4.3. Consola de administración

Se utiliza la consola de administración para interactuar con las instancias. Se puede acceder directamente a la consola de administración de Cortex desde Cortex Gateway o utilizando el Fully Qualified Domain Name (FQDN) especificado durante la activación de la instancia.

Para autenticarte, introduce tu usuario y contraseña del Customer Support Portal (CSP) y asegúrate de tener asignados los roles adecuados de la aplicación Cortex.

Las secciones principales del panel de navegación son:

- Dashboard & Reports
- Cases and Issues
- Investigation and Response (search, automation, response y forensics)
- Threat Management
- Posture Management
- Inventory (activos y endpoints)

- Modules
- Marketplace

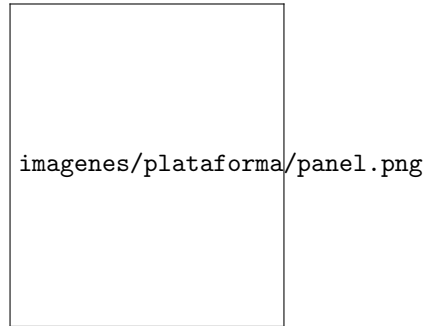


Figura 39:

Para configurar una instancia en Cortex, hay que navegar a *Settings > Configurations*. Ahí se pueden configurar medidas de seguridad para el usuario, como session expiration o user expiration.

Para Personalizar el administrador de Dashboards y crear una Plantilla de Informe hay que navegar a **Dashboards & Reports > Customize > Dashboards Manager** para visualizar, editar, deshabilitar, duplicar o eliminar dashboards.

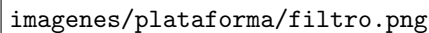
También se puede buscar widgets, crear nuevos widgets y editar widgets personalizados a partir de consultas de **XQL Search**.

4.3.1. Elementos de la consola de administración

La mayoría de las páginas en la consola de administración de Cortex presentan objetos como endpoints, incidencias y políticas en **formato tabular**. Estas páginas comparten una apariencia común que muestra acciones relacionadas con la tabla, como ordenar, filtrar, actualizar y exportar.

No todas las páginas de la consola de administración presentan una lista. Por ejemplo, el Dashboard muestra información resumida mediante widgets.

Por ejemplo, desde este formato de tabla se puede filtrar la información, como se puede ver en la siguiente captura:



imagenes/plataforma/filtro.png

Figura 40:

Se pueden añadir columnas desde los 3 puntos que hay arriba a la derecha.

4.3.2. Preguntas interesantes

1. *What is the primary function of the Cortex management console?*

Accessing and navigating dashboards, reports, incident responses, detection rules, asset management, and endpoint management

2. *Which tab allows you to hide or display selected columns in a management console table?*

Layout

3. *What is one of the methods mentioned for filtering entries within a management console table?*

Pivoting from the contents of a specific data cell

4. *How are new custom widgets created for a dashboard in the Cortex console?*

By creating and saving an XQL Search query

5. *What console feature allows you to create a shortcut to a frequently visited page in the navigation pane?*

Adding the page to the Favorites section

6. *Which is the default landing page when opening the Cortex Management Console?*

Dashboards

7. *In the Session Security Settings, what does the "Allowed Sessions" feature control?*

Restricts user access by IP address or domain

8. *How are new custom widgets created for a dashboard in the Cortex console?*

By creating and saving an XQL Search query

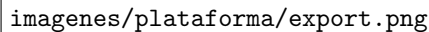
4.4. Dashboards y reportes

La vista **Dashboards and Reports** proporciona acceso a dashboards e informes predeterminados (OOTB) y a funcionalidades de personalización. Se pueden gestionar los dashboards desde *Dashboards & Reports > Dashboard Manager*. Donde se puede gestionar uno ya existente, crear un report o generarlo desde **Report Templates**.

Se pueden crear, buscar o editar widgets a partir de XQL queries siguiendo los siguientes pasos:

1. Pulsar el icono + para empezar a crear un widget XQL
2. Añadir nombre y descripción (query XQL)
3. Guardarlo

Cortex permite exportar e importar dashboards y plantillas de informes en formato JSON. Esto facilita la transferencia de configuraciones entre diferentes entornos, lo cual resulta útil para procesos de incorporación (onboarding), migración, copias de seguridad y uso compartido en general.



imagenes/plataforma/export.png

Figura 41:

4.4.1. Preguntas interesantes

1. Which is a component of the Dashboards & Reports section of Cortex?
Widget Library
2. Which component is where to set the default dashboard?
Dashboard Manager
3. Which component is used to edit custom widgets?
Widget Library
4. Which component can view existing reports that have been run?
Reports
5. Which component contains widgets that summarize information about endpoints in graphical or table format?
Dashboards
6. Which component is used to edit templates?
Report template

4.5. Cumplimiento normativo

El **cumplimiento (compliance)** es la adhesión a normativas. Las normativas son creadas por leyes, organismos gubernamentales o entidades que buscan establecer un estándar en un sector o industria específicos.

El cumplimiento puede aplicarse de varias maneras, como ser impuesto por entidades certificadas, validado mediante la recopilación de evidencias o proporcionado mediante una certificación respaldada por informes.

Los auditores recopilan evidencia para validar que se están cumpliendo los requisitos. Cada auditor determina qué evidencia es aceptable; sin embargo, la evidencia recopilada por un auditor puede no satisfacer las necesidades de otro.

Las organizaciones deben preocuparse por el cumplimiento porque están legalmente obligadas a ello, y el incumplimiento puede derivar en consecuencias no deseadas. **XSIAM** facilita el cumplimiento al proporcionar **dashboards** e **informes** fáciles de interpretar. Las consultas eficientes en XQL extraen información de fuentes de datos relevantes para generar tablas u otras visualizaciones que pueden utilizarse como evidencia durante auditorías.

4.5.1. Preguntas interesantes

- 1. Which entity enforces compliance regulations?*
Certified auditors
- 2. Where can you download the compliance content?*
Marketplace
- 3. What are three possible consequences for not following compliance regulations?*
Fines and penalties, Potential jail time and Forced leadership departure
- 4. Where can customers submit a form to receive a security compliance report about Palo Alto Networks?*
Enterprise portal

4.6. Administración de acceso y plataforma

4.6.1. Servicios de la infraestructura

Una **instancia de Cortex** requiere servicios de infraestructura que deben estar asociados a regiones específicas. Además, necesita servicios de infraestructura en la nube de Cortex proporcionados por Palo Alto Networks, que pueden ser incluidos u opcionales. Por ejemplo:

- **WildFire** es un servicio incluido que proporciona inteligencia de amenazas mediante el análisis en tiempo real de archivos desconocidos y veredictos listos para usar para archivos conocidos
- **CIE** es un servicio opcional que proporciona información de identidad a Cortex al extraer datos de los directorios de la organización

Se puede administrar la infraestructura de Cortex desde las siguientes herramientas:

- Customer Support Portal (CSP)
- Cortex Gateway
- Palo Alto Networks Hub.

Cloud Identity Engine (CIE), anteriormente conocido como Directory Sync Service, es un servicio en la nube que proporciona acceso de solo lectura a la información de directorio local (on-premises) de las organizaciones. El directorio puede ser Azure Active Directory (AD). El servicio es utilizado por una instancia de Cortex para acceder a datos de identidad.

imagenes/plataforma/cloud.png

Figura 42: Caption

4.6.2. Control de acceso

Los roles se gestionan mediante Cortex Gateway o la consola de administración de Cortex. Ambos ofrecen páginas y acciones para administrar roles y permisos, pero presentan diferencias.

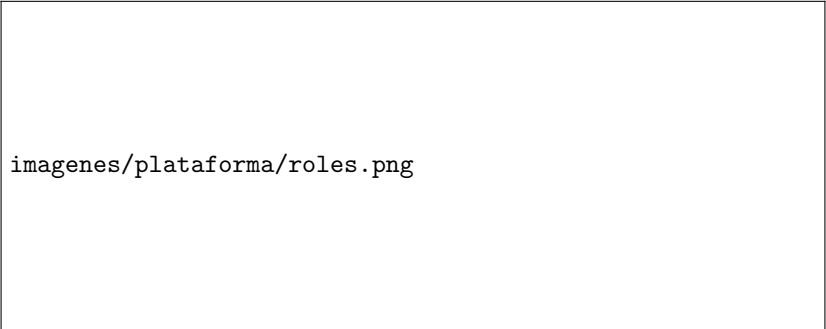
- **Cortex Gateway:** permite gestionar roles y permisos para múltiples instancias de Cortex vinculadas a la misma cuenta CSP.
- **Consola de Administración de Cortex:** permite gestionar roles y permisos únicamente para la instancia actual de Cortex.

Se puede crear un nuevo rol navegando a *Settings > Configurations > Access Management > Roles*.

Palo Alto Networks proporciona roles predefinidos de Cortex como:

- El **Account Admin** tiene privilegios completos sobre las cuentas CSP y puede activar nuevas instancias de Cortex en la cuenta.
- El **Instance Administrator** tiene privilegios completos sobre una instancia específica de Cortex que ya ha sido activada por un Account Admin. No puede crear nuevas instancias.

SBAC restringe el acceso de los usuarios a las áreas funcionales de la consola de administración según el alcance (**scope**) definido. Para configurar el SBAC hay que navegar a *Settings > Configurations > Access Management > Users*.



imagenes/plataforma/roles.png

Figura 43: Caption

4.6.3. Preguntas interesantes

1. *A CIE deployment consists of a cloud-based CIE instance and which other component that connects to domain controllers on-premises?*

On-premises Windows agents

2. *How is user access typically restricted when using Scope-Based Access Control (SBAC) within the Cortex management console?*

By console functional area and scope

3. *Which regional service does Cortex use to receive organizational units?*

Cloud Identity Engine

4. *Which of the following actions does an Instance Administrator have to configure the tenant?*

Assign Cortex roles to user accounts.

5. *What is the geographical deployment requirement for a Cortex instance and its associated infrastructure services?*

They must be bound to the same specific region to ensure data locality.

6. *How are scopes managed in Cortex SBAC?*

Tags

4.7. Bring your own key (BYOK)

BYOK (Bring Your Own Key) permite a los usuarios de Cortex utilizar sus propias claves para cifrar los datos del tenant en reposo. Esta funcionalidad es especialmente beneficiosa para organizaciones que operan en industrias altamente reguladas, ya que les otorga un mayor control sobre el acceso y la encriptación de los datos.

Por defecto, todos los datos se cifran en reposo utilizando un **sistema dedicado de gestión de claves (KMS)**. El sistema proporciona controles estrictos de acceso a las claves y auditoría, y cifra los datos de los usuarios en reposo de acuerdo con los estándares de cifrado AES-256.

Las **capacidades de BYOK** fueron diseñadas para ofrecer un mayor control, reemplazar la necesidad de un KMS externo y reducir los riesgos externos.

Además, BYOK incluye funciones como la rotación de claves (una vez al año), importar llaves de encriptación asimétricas y los registros de auditoría para mejorar la seguridad general y facilitar el cumplimiento de las normativas.

Los **requisitos de BYOK** son:

- Licencias y disponibilidad
- La organización tienen que generar una clave simétrica de 32 bytes
- Se tiene que completar el proceso en 3 días

4.7.1. Arquitectura y flujo de trabajo

La arquitectura de BYOK consta de dos componentes: un KMS dedicado y un conjunto de claves simétricas para cifrar los datos. Esta arquitectura mejora la seguridad general de los datos al minimizar la dependencia de factores externos.

- **KMS dedicado.** Cortex BYOK utiliza un KMS dedicado en el tenant de GCP (Google Cloud Platform) de la organización. Esto significa que, en entornos multi-tenant, cada tenant tiene su propia instancia de KMS y sus propias claves, que se gestionan de manera independiente. Por lo tanto, se debe generar e importar una clave simétrica para cada tenant que se utilice.
- **Dos claves de cifrado.** Cortex BYOK utiliza dos claves para cifrar los datos en reposo. Una clave es para BigQuery y la otra es para todos los demás servicios dentro del tenant. Aunque se puede generar una sola clave para ambos, como buena práctica de seguridad se recomienda generar dos claves separadas para cada servicio.

El **flujo de trabajo** de importación de claves garantiza que el material de la clave —los datos utilizados para realizar el proceso de cifrado y descifrado— se envuelva de forma segura para su protección durante la transmisión. Este material de clave puede presentarse en diversas formas, como una frase de contraseña, una cadena de caracteres generada aleatoriamente o una clave criptográfica derivada de una contraseña. Es fundamental proteger el material de la clave, ya que es el componente esencial para garantizar la seguridad de los datos cifrados.

Esto significa que el acceso a la clave de envoltura está estrictamente limitado únicamente al ámbito del trabajo de importación. Esta restricción asegura que solo el personal o los procesos autorizados puedan acceder y utilizar el material de la clave, minimizando el riesgo de acceso no autorizado o uso indebido. Como resultado, la confidencialidad e integridad del material de la clave están mejor protegidas.

Los pasos para importar la llave (key) son los siguientes:

1. Generar una nueva clave: el administrador genera una nueva clave simétrica y crea un trabajo de importación que define el anillo de claves (Key Ring) de destino y la clave para el material de clave importado.
 - La clave pública se utiliza para envolver la clave que se va a importar.
 - La clave privada se almacena dentro de Google Cloud y se utiliza posteriormente para desenvolver la clave importada.
2. Descargar el *Key Ring*.
3. Encriptar la llave simétrica con la llave privada del *Key ring*.
4. Subir la nueva llave.

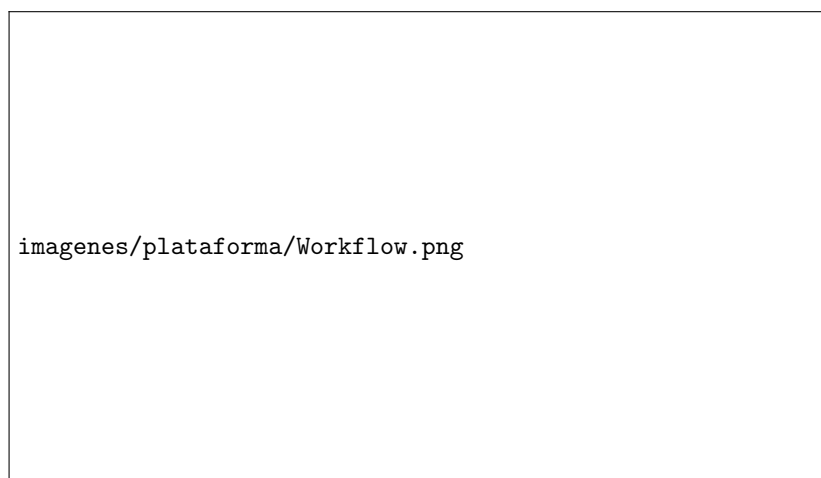


Figura 44:

BYOK se configura durante el proceso de activación del tenant. Antes de iniciar este proceso, recuerda revisar los requisitos para asegurarte de que se complete correctamente.

BYOK simplifica la **gestión de claves de cifrado**, incluyendo prácticas fundamentales como la **rotación** y la **deshabilitación de claves**, que son esenciales para la seguridad de los datos. La rotación de claves implica reemplazarlas periódicamente para minimizar el impacto en caso de que se vean comprometidas y reducir el riesgo de acceso no autorizado. La deshabilitación de claves es crucial para revocar el acceso de inmediato o mitigar el riesgo asociado a claves comprometidas, garantizando que personas o sistemas no autorizados no puedan utilizarlas para acceder a datos sensibles.

Estas prácticas mejoran significativamente la seguridad general, se alinean con los requisitos de cumplimiento normativo y protegen eficazmente contra accesos no autorizados y posibles brechas de datos.

4.7.2. Preguntas interesantes

1. *What are the two services being utilized to encrypt tenant data?*
BigQuery and Other services
2. *What is the requirement when importing an encryption key for BYOK?*
32-byte, symmetric, and unencoded key in binary format
3. *What is the recommended number of symmetric keys to generate during the activation of BYOK?*
2
4. *What capabilities does BYOK have that benefits organizations in terms of compliance?*
Supports key rotation and audit logs
5. *When disabling keys, which statement is true?*
It renders the tenant inaccessible and non-operational
6. *How does the architecture of BYOK reduce external risks for organizations?*
By utilizing a dedicated key management system (KMS)
7. *Why is BYOK considered beneficial for organizations in regulated industries?*
Enhances control over data encryption

4.8. Multitenancy

El **multitenancy** es una arquitectura de software en la que una única instancia de una aplicación atiende a grupos independientes de usuarios, conocidos como tenants.

En operaciones de seguridad, el multitenancy permite a los **Proveedores de Servicios de Seguridad Gestionados (MSSP)** (Managed Security Service Providers) y a grandes empresas administrar múltiples clientes o compañías subsidiarias desde una plataforma central, garantizando al mismo tiempo la segregación de los datos.

Este diagrama de alto nivel muestra a un administrador gestionando tenants secundarios desde una sola consola, también denominada **tenant principal**. Un ejemplo de función administrativa puede ser un analista de un centro de operaciones de seguridad que supervisa los incidentes de seguridad de todos los tenants secundarios, o administradores de cuentas que incorporan un nuevo tenant secundario, como una empresa subsidiaria de una gran organización.



`imagenes/plataforma/multitenant.png`

Figura 45:

Cortex XDR y XSIAM cuentan con dos tipos de tenants:

- El **tenant principal (main tenant)** actúa como el punto central de administración del entorno multitenant. Los administradores utilizan el tenant principal para acceder y gestionar los tenants secundarios, asignar licencias, configurar usuarios y roles, y supervisar la seguridad general.
- Un **tenant hijo (child tenant)** representa a un cliente individual o a un entorno subdividido dentro del sistema multitenant. Cada tenant secundario tiene su propia instancia aislada de Cortex XSIAM, con almacenamiento de datos y configuraciones dedicadas que no son accesibles desde otros tenants secundarios.

4.8.1. Modelos de licencia multitenant

Existen dos tipos de modelos de licenciamiento: licenciamiento propiedad del cliente (Customer-Owned) y licenciamiento centralizado (central).

1. **Customer-Owned:** este modelo se caracteriza porque cada tenant adquiere sus propias licencias de XSIAM. Una vez que todos los tenants han adquirido sus licencias, la vinculación se configura manualmente entre un tenant padre (normalmente un MSSP) y los tenants secundarios (clientes del MSSP).



Figura 46:

2. **Central:** este modelo permite que el proveedor de servicios padre (normalmente una gran empresa) adquiera una licencia para el tenant principal, así como un conjunto de recursos para los tenants secundarios (subsidiarias de la empresa). Las capacidades de recursos incluyen:
 - Número de tenants secundarios
 - Número de empleados
 - Capacidad de ingesta de datos en gigabytes por día (GB/día)



Figura 47:

4.8.2. Proceso de activación de un Child Tenant

Los **child tenants** se pueden añadir desde Cortex Gateway a través de una cuenta con roles de administrador.

4.8.3. Preguntas interesantes

1. What is a benefit of the central licensing model from the perspective of a large enterprise using the Cortex XSIAM multi-tenant environment?

It provides a way for the enterprise administrators to dynamically allocate the central license across multiple subsidiaries.

2. Which statement describes a valid operation between a Cortex XSIAM main tenant and its child tenant?

The main tenant administrator can manage configurations such as setting user roles of the child tenants.

3. Which statement about Cortex XSIAM multitenancy is most accurate?

It is a software architecture that allows a central main tenant to manage the security operations of one or more child tenants.

4. How is the Cortex Gateway used during the Cortex XSIAM tenant pairing process?

It is a webpage used to initiate the pairing process.

5. Which organization is most likely to purchase and manage a parent tenant of Cortex XSIAM?

A managed security service provider

4.9. Cortex enterprise operaciones multitenant

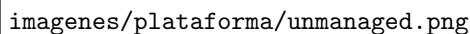
Los tenants padre cuentan con capacidades clave respecto a sus tenants secundarios, específicamente en visibilidad y configuración de seguridad:

- La **visibilidad** permite a los tenants padre ver, consultar e investigar incidentes o problemas de seguridad en sus tenants secundarios.
- La **configuración de seguridad** es la capacidad del tenant padre para aplicar configuraciones de seguridad en los tenants secundarios según sea necesario.

Cuando se establece un emparejamiento (*pairing*) por primera vez, las cinco áreas de seguridad tienen el valor predeterminado de no gestionadas (unmanaged) y no hay configuraciones de seguridad aplicadas al tenant secundario.

Para iniciar acciones de seguridad en un tenant secundario, es necesario crear una configuración de seguridad. Las acciones de seguridad se gestionan mediante configuraciones creadas en Cortex XSIAM y posteriormente asignadas a cada tenant secundario. Cada acción requiere su propia configuración y su respectiva asignación al tenant secundario.

Desde *Settings > Configurations > Tenant Management*, puedes determinar si las cinco configuraciones de seguridad están gestionadas o no gestionadas en el tenant secundario.



imagenes/plataforma/unmanaged.png

Figura 48: Caption

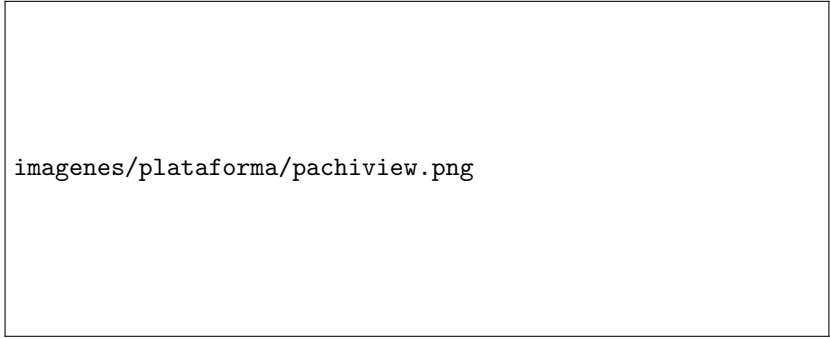
XSIAM Multitenancy está diseñado para permitir que los tenants padre ejecuten playbooks de los tenants secundarios, así como visualizar los layouts (diseños) de los tenants secundarios.

Cortex XSIAM también permite a los MSSP gestionar el contenido en los tenants secundarios mediante el uso de repositorios de contenido remotos.

4.9.1. Visibilidad Multitenant

En la consola de administración de Cortex XSIAM, el tenant padre tiene acceso a las vistas y a los datos de los tenants secundarios.

Los tenants secundarios mantienen control total sobre sus configuraciones de seguridad, a menos que el tenant padre las establezca explícitamente en estado gestionado desde la configuración de gestión de tenants.



imagenes/plataforma/pachiview.png

Figura 49:

Estas son las áreas de seguridad que el tenant padre puede visualizar en un tenant secundario:

- Incidentes
- Alertas
- Constructor de Consultas (Query Builder)
- Centro de Consultas (Query Center)
- Vista de Causalidad (Causality View)
- Vista de Línea de Tiempo (Timeline View)
- Análisis Forense (Forensics)
- Playbooks

Determinar el nivel de control que el tenant padre ejercerá sobre el tenant secundario debe formar parte de la configuración inicial del entorno multitenant, y las configuraciones de seguridad del tenant secundario deben evaluarse de manera periódica. Los dos pasos que hay que seguir para aplicar configuraciones de seguridad sobre un child tenant son: crear una configuración y aplicarla al hijo.

4.9.2. Preguntas interesantes

1. *True or False? Child visibility is the primary security capability of parent tenants.*

False, Both visibility and security configurations are key capabilities of the parent tenant.

2. *What state changes in a child tenant when a security configuration becomes managed?*

The area becomes read-only for a child.

3. *What are some of the specific security configurations that can be applied from parent tenants to child tenants?*

BIOC rules, alert policies, endpoint prevention profiles, and allow/block lists

4. *What is the primary function of a parent tenant in the Cortex XSIAM platform?*

To oversee operational functions for child tenants

5. *How can security configurations for child tenants be managed from the parent tenants?*

As managed or unmanaged

6. *What field may be added to XQL result views when you are querying multiple child tenants to differentiate them better?*

Tenant

7. *Which of the following child tenant areas can parent tenants view?*

Incidents, alerts, causality graphs, queries, and forensics

5. Quering

5.1. Introducción a XQL

Cortex Query Language (XQL) está diseñado para utilizarse con datos XML en Cortex. Permite a los usuarios consultar y manipular datos XML de manera flexible y extensible, lo que hace que las consultas sean fáciles e intuitivas.



Figura 50:

Saber cómo crear consultas XQL es importante para una variedad de tareas críticas en Cortex. Esto incluye tanto tareas reactivas, como realizar investigaciones de casos, como tareas proactivas, como crear reglas de detección.

Las amenazas potenciales se investigan mediante **threat hunting** y la identificación de indicios. Las consultas XQL permiten realizar búsquedas complejas en conjuntos de datos para analizar eventos y aplicar medidas preventivas.

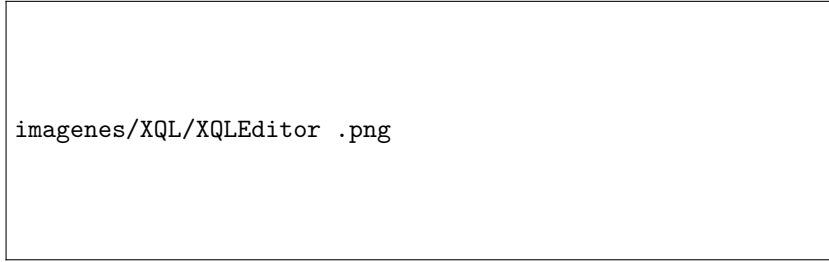
5.1.1. Creando XQL Queries

El **Query Builder** es una herramienta potente que facilita la detección de amenazas al permitir buscar indicadores de compromiso y patrones sospechosos dentro de las fuentes de datos.

Ayuda a ampliar las investigaciones de casos identificando eventos y entidades relacionadas, como actividades asociadas a cuentas de usuario específicas o movimientos laterales dentro de la red.

El Query Builder permite realizar análisis de datos sobre amenazas sospechosas, ayudando a las organizaciones a examinar grandes volúmenes de información para identificar tendencias, anomalías y correlaciones que puedan indicar posibles problemas de seguridad.

El **editor de consultas** en Cortex es una herramienta clave para los analistas de seguridad. Está diseñado para ayudarte a crear y ejecutar consultas que recuperan y analizan datos de distintas fuentes, como registros y eventos. No se limita a escribir comandos; también permite buscar, filtrar y correlacionar datos. Esto es fundamental al investigar incidentes de seguridad, buscar posibles amenazas o identificar patrones en los datos que puedan indicar riesgos.



imagenes/XQL/XQLEditor .png

Figura 51:

Cada consulta XQL se construye utilizando una serie de etapas (**stages**). Una etapa es un paso en el proceso en el que los datos se refinan y filtran hasta obtener los resultados deseados. Una consulta puede tener una o varias etapas, dependiendo de la complejidad del análisis que se esté realizando.

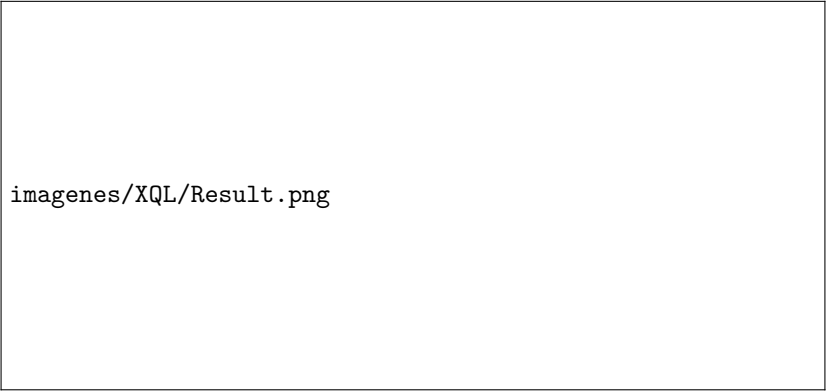


imagenes/XQL/typicalquery.png

Figura 52:

El Query Builder da dos modos para ejecutar las queries: *Run* o *Scheduled Query*.

Cuando ejecutas una consulta de búsqueda, independientemente del tipo, Cortex muestra los resultados de la ejecución en la tabla de Resultados.



imagenes/XQL/Result.png

Figura 53:

5.1.2. Dataset

Cada consulta de **conjunto de datos** en XQL comienza identificando la fuente de datos sobre la que se ejecutará la consulta.

Cada fuente de datos tiene un nombre único y una serie de campos. La consulta especifica la fuente de datos y luego define etapas que identifican los campos de interés y realizan operaciones sobre dichos campos. **xdr_data** es el dataset primario

Los **presets** son subconjuntos del conjunto de datos más amplio disponible en Cortex. Son colecciones seleccionadas de campos especialmente relevantes para analizar e investigar aspectos específicos de los datos de seguridad, como el tráfico de red, la actividad en endpoints, los eventos de autenticación o los registros del sistema.

Existen dos tipos de presets en Cortex: regulares y story.

1. Los **presets regulares** son configuraciones predefinidas que organizan campos relevantes para áreas específicas de actividad de red o de endpoint. Se centran en proporcionar un conjunto completo de campos necesarios para analizar casos de uso comunes de seguridad, como la investigación de tráfico de red, eventos en endpoints, actividades de autenticación o registros del sistema.
2. Los **story presets** son configuraciones especializadas que organizan los campos en esquemas comunes o narrativas conocidas como “historias” (**stories**). Estas historias correlacionan eventos de seguridad relacionados e información contextual para proporcionar una visión coherente de casos de seguridad específicos, patrones de ataque o tendencias de comportamiento observadas en la red o en el entorno de endpoints.

A diferencia de los **presets regulares**, que organizan los campos según categorías generales de datos de seguridad, los **story presets** enfatizan el enfo-

que narrativo, presentando los datos en un formato que resalta la secuencia de eventos, las relaciones entre entidades y posibles escenarios de causa y efecto.

Algunos casos de uso de XQL son:

- Threat hunting (proactivo)
- Case Response (reactivo)
- Construir Widgets personalizados
- Reglas de detección y correlación
- Parseo de reglas

5.1.3. Preguntas interesantes

1. *What type of queries can be created using the Query Builder?*

Simple form-based queries and XQL queries

2. *Which view is used for creating and managing XQL queries?*

Query builder

3. *Which use case involves using XQL for identifying potential security threats?*

Threat hunting

4. *What functionality does the Query Center provide regarding XQL queries?*

Schedules and manages executed queries

5.2. Sintaxis básica

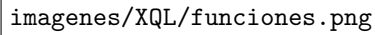
Los elementos que componen XQL son los siguientes:

1. **Stages:** realizan determinadas operaciones durante la evaluación de una consulta. Por ejemplo, la etapa dataset especifica el conjunto de datos sobre el cual se ejecutará la consulta. Entre las etapas más utilizadas se encuentran: dataset, fields, filter, join y sort.

imagenes/XQL/stages.png

Figura 54:

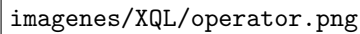
2. **Funciones:** algunas etapas pueden llamar funciones para convertir los datos al formato deseado. Por ejemplo, `current.time()` devuelve la marca de tiempo actual, mientras que `extract.time()` puede obtener la información de la hora dentro de una marca de tiempo. Las funciones pueden requerir o no parámetros de entrada. Las etapas filter y alter son las dos que pueden utilizar funciones para realizar transformaciones de datos.



```
imagenes/XQL/funciones.png
```

Figura 55:

3. **Operadores:** son construcciones similares a funciones, pero difieren en su sintaxis y semántica. Por ejemplo, la suma de los números x e y puede expresarse mediante una función `addition(x, y)` o utilizando el operador `x + y`. Los operadores son tipos específicos de funciones que relacionan operandos. Por ejemplo, el operador `in` es un operador de rango que devuelve un valor booleano.



```
imagenes/XQL/operator.png
```

Figura 56:

Las consultas XQL están compuestas por etapas de XQL, lo que convierte a las etapas en los componentes fundamentales de una consulta XQL.



```
imagenes/XQL/tipic.png
```

Figura 57:

Las consultas XQL se ejecutan sobre **datasets**, que en XQL se denominan fuentes de datos. Cada consulta opera sobre uno o más datasets. Es fundamental que los datasets utilizados en la consulta ya existan durante la fase de diseño, para garantizar que la consulta se compile correctamente.

No existe ninguna restricción en cuanto al número de etapas en una consulta XQL, lo que permite crear consultas potencialmente complejas. El compilador de consultas XQL ignora los saltos de línea, lo que te permite formatear la consulta utilizando saltos de línea para mejorar la legibilidad.

Para comentar se puede hacer de dos opciones:

- Para comentar una línea: `//`
- Para comentar un bloque: `/* Aquí lo comentado */`

XQL **NO** es **Case Insensitivity** (da igual escribir en mayúsculas o minúsculas).

Los **resultados de la consulta** se muestran por defecto en un formato tabular, conocido como tabla de resultados. También puedes visualizar los resultados en otros formatos, como gráficos.

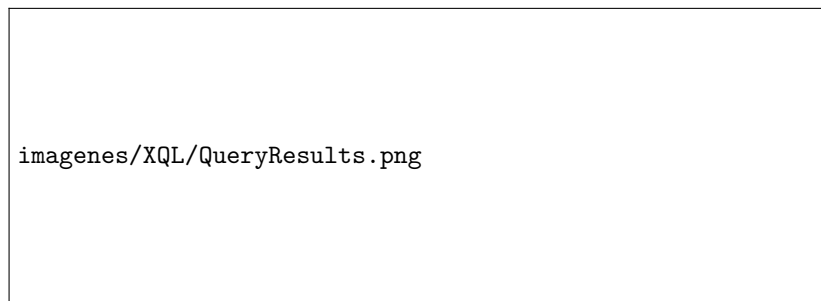


Figura 58:

El editor de consultas de XSIAM muestra el nombre de la consulta, aplica colores al código, resalta errores de sintaxis y ofrece opciones de autocompletado.

También se puede ejecutar una consulta al momento (**run**), programarla (**schedule query**) o guardarla (**save as**).

5.2.1. Preguntas interesantes

1. *Which of the following will result in a run action being disabled?*

There is no dataset associated with the query.

2. *Which XQL component handles the grammar and language of its elements?*

Syntax

3. *Where is the Query Builder located within the Cortex XDR or XSIAM Console?*

Incident Response ¿Query Builder

5.3. Construyendo bloques

Las **etapas** (stages) son los bloques básicos que conforman una consulta XQL. Una consulta XQL está compuesta por una o más etapas separadas por una barra vertical (|), que es el símbolo delimitador de etapas.

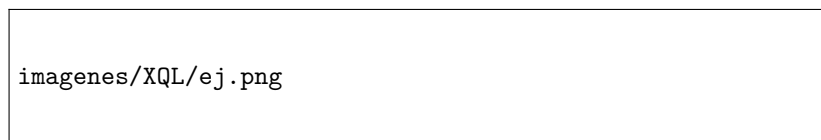


Figura 59:

Todas las etapas requieren ciertos parámetros para funcionar. El tipo y el orden de los parámetros varían según la etapa. Los siguientes ejemplos muestran el uso de parámetros en XQL.

- **Dataset**

La etapa **dataset** necesita una asignación.

```
dataset = xdr_data

dataset in (xdr_data, onelookup)
```

- **Filter**

La etapa **filter** requiere una expresión booleana que se evalúa en tiempo de ejecución.

```
filter actor_process_image_name = "powershell.exe"
```

- **Fields**

La etapa **fields** requiere una lista de campos separados por comas.

```
fields event_type, event_sub_type as SUBTYPE
```

- **Limit**

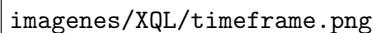
La etapa **limit** requiere un número entero.

La **etapa config** establece dos parámetros clave que afectan la forma en que el motor de consultas XQL interpreta y ejecuta una consulta; esta etapa es opcional. Debe ser la primera etapa de una query. Hay dos tipos:

1. El parámetro **compile-time**, case-sensitive acepta un valor booleano (true o false) y fuerza que las comparaciones de cadenas sean sensibles o no a mayúsculas y minúsculas.

```
config case_sensitive = true | false
```

2. El parámetro **timeframe** es un parámetro de ejecución (runtime) que establece el intervalo de tiempo para la evaluación de la consulta, lo que significa que el motor de XQL solo considera los registros creados dentro de ese rango.



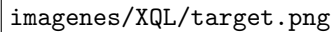
imagenes/XQL/timeframe.png

Figura 60: Caption

Al ejecutar una consulta XQL en Cortex XSIAM, se procesan registros provenientes de una fuente de datos específica llamada **dataset**. La etapa dataset es una instrucción opcional para que el motor XQL procese los registros de datos seleccionados. Si no se especifica ningún dataset en la consulta, el motor asociará la ejecución de la consulta con el dataset predeterminado, **xdr_data**.

Para cambiar el dataset predeterminado, navega a: *CONFIGURATIONS > Data Management > Dataset Management*.

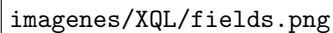
La etapa **target** guarda el conjunto de resultados en un dataset de destino. El dataset de destino puede crearse nuevo o añadirse a uno existente. Si se utiliza, la etapa target debe ser la última en la consulta.



imagenes/XQL/target.png

Figura 61:

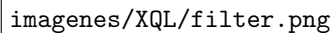
La etapa **fields** especifica una lista de campos que conforman las columnas de la tabla de resultados. Los campos disponibles varían según el dataset utilizado.



imagenes/XQL/fields.png

Figura 62:

La etapa **filter** selecciona los registros (logs) que se incluirán en el conjunto de resultados, determinando así las filas de la tabla de resultados. Cada etapa filter evalúa una expresión booleana para cada registro del dataset, devolviendo true o false. Los registros cuyo resultado sea true se agregan al conjunto de resultados.

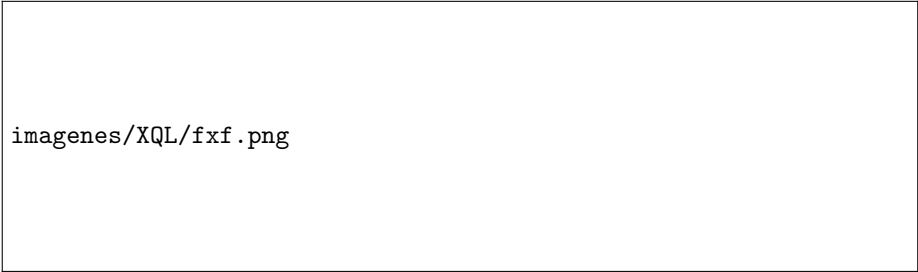


imagenes/XQL/filter.png

Figura 63:

Las etapas filter y fields dan forma al conjunto de resultados:

- La etapa **filter** especifica las filas de la tabla.
- La etapa **fields** especifica las columnas de la tabla.



imagenes/XQL/fxf.png

Figura 64:

La etapa **alter** asigna valores a los campos para su uso en etapas posteriores. Si el campo especificado no existe, esta etapa crea un nuevo campo.

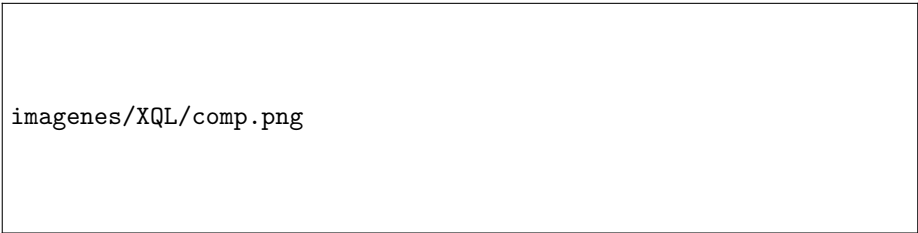


imagenes/XQL/alter.png

Figura 65:

La etapa **comp** realiza funciones de agregación sobre el conjunto de resultados. Esta etapa divide las filas del conjunto de resultados en grupos según la combinación de valores de los campos especificados y, posteriormente, aplica la función de agregación indicada a cada grupo. Las funciones de agregación incluyen: avg, count, earliest, max, min y sum.

```
comp <function> [as <alias>] by <field1>[,<field2>..]
```



imagenes/XQL/comp.png

Figura 66:

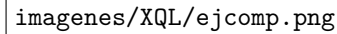
The image shows a rectangular box containing the text `imagenes/XQL/ejcomp.png` in a monospaced font.

Figura 67:

limit: establece el número máximo de entidades en el conjunto de resultados; es decir, la cardinalidad del conjunto.

sort: define el orden de clasificación de las entidades en el conjunto de resultados, por ejemplo: asc (ascendente) o desc (descendente).

dedup: elimina los valores duplicados en los campos especificados dentro del conjunto de resultados.

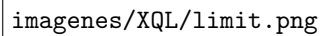
The image shows a rectangular box containing the text `imagenes/XQL/limit.png` in a monospaced font.

Figura 68:

El orden de las etapas es importante en una consulta XQL. El compilador de consultas XQL puede detectar ubicaciones incorrectas de las etapas y mostrar errores de sintaxis.

Por ejemplo, una etapa alter crea un nuevo campo (una variable), `timeDay`. Sin embargo, la etapa fields elimina todos los campos y variables definidos anteriormente. Por lo tanto, Cortex XSIAM muestra el mensaje de error *timeDay no es un valor válido* en la última etapa filter.

imagenes/XQL/orden.png

Figura 69:

5.3.1. Preguntas interesantes

1. Which stage selects a subset of logs based on criteria during XQL query execution?

Filter

2. Which stage erases all the fields and variables defined before it?

Fields

3. Which function does the Timeframe parameter perform in an XQL query?

It indicates that only logs included within a specific timeframe will be evaluated.

5.4. Funciones

Las **funciones en XQL** realizan acciones sobre sus argumentos y devuelven un valor como resultado. Proporcionan un nivel de abstracción para quien las utiliza, lo que permite simplificar operaciones complejas.

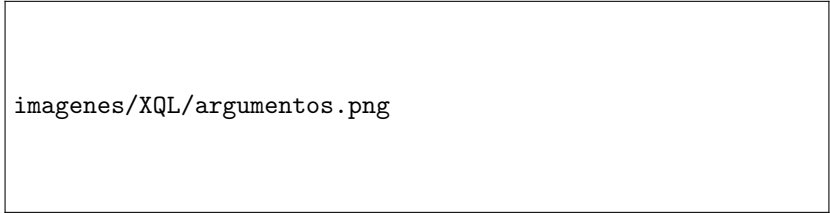
En los lenguajes de programación, las funciones pueden considerarse una extensión de los operadores, que a su vez pueden verse como funciones especializadas. Tienen la siguiente estructura:

```
<return-value> = func_name([<comma-separated-argument-list>])
```

Algunas funciones típicas son:

- `extract_time(hora, variable)` and `current_time()`
- `round()` and `divide()`
- `len()`

En XQL, los **argumentos** de una función, también conocidos como parámetros, se especifican como una lista separada por comas y encerrada entre paréntesis. Estos argumentos pueden ser obligatorios u opcionales, y algunas funciones pueden aceptar un número variable de argumentos. Cuando una función admite tanto argumentos obligatorios como opcionales, los argumentos obligatorios deben colocarse antes que los opcionales.



imagenex/XQL/argumentos.png

Figura 70:



imagenex/XQL/ejfun.png

Figura 71:

La **verificación de tipos de datos** es fundamental en dos aspectos clave al utilizar funciones en XQL:

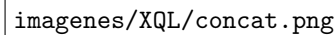
1. **Tipos de datos esperados.** Los tipos de datos de los argumentos pasados a una función coincidan con los tipos de datos esperados.
2. **Retorno de un único valor.** Verificar que la función devuelva un solo valor de un tipo declarado. El tipo declarado puede ser un tipo simple, como string o number, o un tipo contenedor, como un array de strings o de números.

5.4.1. Uso de funciones en queries XQL

Existen los siguientes tipos de funciones:

- Las **funciones matemáticas** en XQL incluyen las funciones aritméticas básicas; funciones de redondeo (`round(x)`) o truncamiento (`floor(x)`); la función de potencia (`pow(x,y)`); y funciones para trabajar con números enteros o de punto flotante.

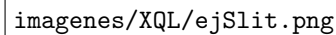
- **Funciones de cadena (strings)** presentes en otros lenguajes de programación, como convertir cadenas a minúsculas y mayúsculas, concatenar dos cadenas y dividir cadenas en subcadenas. Algunos ejemplos son: `len()`, `split()`, `string.count()`...



imagenes/XQL/concat.png

Figura 72: Caption

La función **split()** de XQL divide una cadena en múltiples subcadenas utilizando un delimitador (también conocido como separador). Devuelve un arreglo que contiene las subcadenas. El delimitador es opcional; si no se especifica, se utiliza un espacio () como separador por defecto.



imagenes/XQL/ejSplit.png

Figura 73: Caption

- Las funciones y los operadores en los lenguajes de programación esperan tipos de datos correctos para sus argumentos. XQL proporciona funcio-

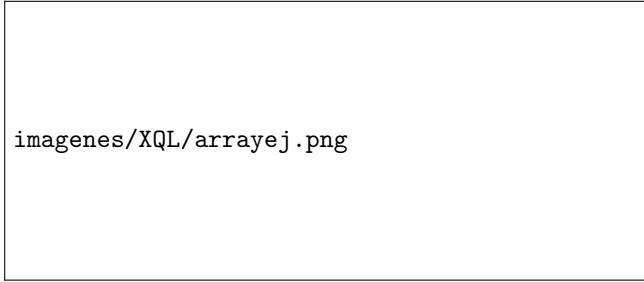
nes para la conversión de tipos. Algunos ejemplos incluyen `to_boolean()`, `to_float()` y `to_string()`.



`imagenes/XQL/DataConversor.png`

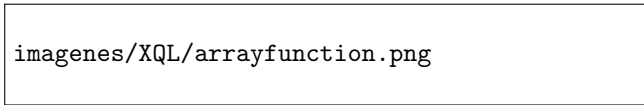
Figura 74: Caption

- Los datasets de Cortex XSIAM no son bases de datos relacionales. Por lo tanto, los campos no son “atómicos” y pueden contener múltiples valores. Este tipo de campos también se denomina campos **multivaluados**.



`imagenes/XQL/arrayej.png`

Figura 75: Caption

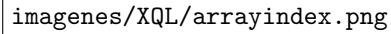


`imagenes/XQL/arrayfunction.png`

Figura 76: Caption

Por ejemplo, la función **arrayindex()** de XQL devuelve el valor almacenado en una posición específica de un arreglo, indicada por el argumento de índice.

`arrayindex(<array>, <index>)`



imagenes/XQL/arrayindex.png

Figura 77: Caption

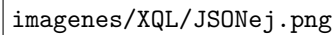
- El **procesamiento de JSON** es un área importante en la que XQL proporciona sintaxis nativa, como la notación de “azúcar sintáctico” (syntactic sugar), y funciones especializadas.



imagenes/XQL/JSONFunctions.png

Figura 78: Caption

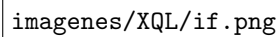
Aquí, la sintaxis `ax1->user` se denomina formato de **azúcar sintáctico**. El azúcar sintáctico es una construcción dentro de un lenguaje de programación diseñada para facilitar la lectura o la expresión del código.



imagenes/XQL/JSONej.png

Figura 79: Caption

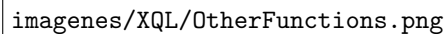
- Función `if()`.



imagenes/XQL/if.png

Figura 80:

- Otras funciones.



imagenes/XQL/OtherFunctions.png

Figura 81: Caption

5.4.2. Preguntas interesantes

1. What is the XQL-native format used to access JSON data?

Sugar

2. Which XQL query would cause a runtime error?

alter ret = arraycreate("10", "20", 30)

3. Which two XQL functions return an array?

regexextract() and split()

4. Which type of object does object_create() produce?

JSON

5.5. Manipulación de Objetos con JSON

Existen dos **fuentes de objetos JSON (JavaScript Object Notation)** en las consultas XQL:

- Campos JSON en datasets procesados (logs recopilados)
- Variables de tipo JSON creadas explícitamente dentro de las consultas XQL

JSON es un formato de archivo que consiste en pares atributo-valor serializables y legibles por humanos. La cantidad de metadatos se minimiza, lo que lo hace popular para la transmisión de datos.

En XQL, puedes acceder a objetos JSON utilizando uno de dos métodos alternativos: **funciones especializadas** de XQL para el procesamiento de JSON o la sintaxis nativa en formato de azúcar sintáctico (**syntactic sugar**).



imagenes/XQL/NotacionAzucar.png

Figura 82: Notación de azúcar sintáctico

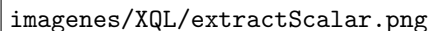
Un **JSON path** es una expresión que identifica de manera única un elemento específico dentro de un objeto JSON. Existen dos tipos de notaciones: con puntos y con corchetes ([]). El símbolo (\$) es el elemento raíz.



imagenes/XQL/punto.png

Figura 83: Notación de azúcar sintáctico

XQL admite **notaciones JSONPath** en las funciones de extracción JSON. La consulta contiene múltiples etapas alter, cada una con una llamada a *json_extract_scalar()*.



```
imagenes/XQL/extractScalar.png
```

Figura 84:

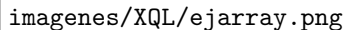
5.5.1. Accediendo a datos JSON con funciones de extracción

Las funciones de extracción JSON permiten extraer datos o valores específicos de un objeto JSON. Proporcionan una forma práctica de acceder a estructuras JSON basándose en criterios o rutas (paths) específicas. Existen tres tipos:

- Escalar: implica aislar los valores deseados de conjuntos de datos complejos mediante el análisis, el filtrado o el acceso a claves específicas. Extraer valores escalares ayuda a recuperar valores individuales para su análisis o manipulación.

```
| alter c1 = json_extract_scalar(root, "$.B.C")
```

- Array: recuperar elementos o valores específicos de arrays dentro de tus datos. Puedes extraer la información necesaria del array especificando el índice o una condición .



```
imagenes/XQL/ejarray.png
```

Figura 85: F=[50,60,70]

- Objeto JSON: los objetos hijos JSON están anidados dentro de otros objetos, formando una estructura jerárquica. XQL permite consultar datos de objetos hijos JSON para recuperar datos anidados específicos dentro de una estructura JSON.

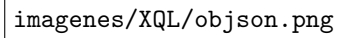
A rectangular box containing the text "imagenes/XQL/objjson.png".

Figura 86: Caption

5.5.2. Accediendo a datos de un fichero JSON usando el método **sugar**

El **azúcar sintáctico** es una notación abreviada que simplifica el acceso y la manipulación de objetos JSON. Permite manejar de forma más sencilla y concisa los elementos de arrays dentro de las consultas XQL.

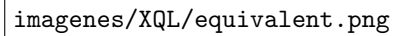
A rectangular box containing the text "imagenes/XQL/equivalent.png".

Figura 87:

Existen los siguientes tipos:

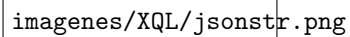
A rectangular box containing the text "imagenes/XQL/jsonstr.png".

Figura 88:

- Para extraer escalares:

```
alter a = root -> B.C
```

- Para extraer arrays:

```
alter b = root -> B.F[]
```

- Para extraer objetos JSON:

```
alter c = root -> B{}
```

Preguntas interesantes

1. What would be a valid expression addressing the value 30 for the given JSON object?

```
{ "root": { "B": { "D": [{ "E": 30 }, { "E": 40 } ] } } }
```

—

```
root->B.D[0].E
```

2. Which two would be valid expressions addressing the element D for the given JSON object? (Choose two.)

```
{ "root": { "B": { "D": [{ "E": 30 }, { "E": 40 } ] } } }
```

```
root->B.D[] and json\_extract\_array(root, "$.B.D")
```

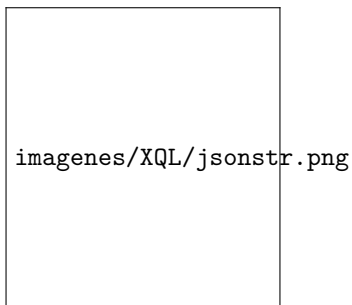


Figura 89:

3. Which two function calls can output the numeric value 50?

```
json_extract_scalar (root, "$.B.F[0]")  
json_extract(root, "$.B.F")->[0]
```

4. Which syntactic sugar format can reference element B?

```
root->B{}
```

5. What does the `json_extract(root, "$['B']['D'][1]['E']")` function call return?

40

6. Which JSON path references the element with a numeric value 40?

```
$.B.D[1].E
```

7. Which syntactic sugar format can reference the value 70?

```
root->B.F[2]
```

5.6. Tipos de datos

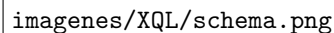
Los **multivalued fields (MVF)** son campos que pueden almacenar múltiples valores dentro de un mismo registro.

Por ejemplo, si deseas almacenar las direcciones IP de un endpoint en una tabla, un solo endpoint puede tener una o varias direcciones IP, ya que cada tarjeta de red posee su propia pila TCP/IP.

Los datasets de XSIAM contienen datos relacionados con seguridad, como alertas y logs, a diferencia de datos estructurados tradicionales (por ejemplo, registros de libros en una biblioteca). Las alertas y los logs provienen de múltiples fuentes. Antes de almacenarlos, XSIAM normaliza los valores y los nombres de los campos para garantizar consistencia. Tienen las siguientes características:

- Son bases de datos no relacionales (NoSQL).
- Almacenan datos en formatos no tabulares.
- Un campo puede contener múltiples valores, lo que se conoce como campo multivaluado (MVF).

Un **schema** es información descriptiva sobre un dataset, y se almacena en otro dataset. En esencia, un schema dataset proporciona la descripción de todos los campos (atributos) de un dataset determinado.



imagenes/XQL/schema.png

Figura 90:

5.6.1. Data Types in Alter Stage Assignments

XQL utiliza el signo igual (=) tanto para asignación (**alter**) como para comparación (**filter**).

En una consulta XQL, la etapa **alter** se utiliza para crear y actualizar variables y campos, ya sea asignando nuevos valores o modificando los existentes.

Los tipos de datos son los de siempre, string, booleano, int, float, resultado de una función, objetos JSON...

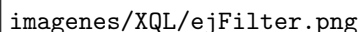


Figura 91:

XQL utiliza arreglos **arrays** para almacenar campos multivaluados en conjuntos de datos procesados. También puedes crear arreglos explícitamente en XQL utilizando funciones que devuelven valores de tipo arreglo, como `array_create()`, `split()` y `json_extract_array()`.

5.6.2. Data Types in Filter

Un **tipo enum** (también llamado tipo enumerado) es un tipo de dato que consiste en un conjunto de valores predefinidos dentro de los esquemas de los datasets. En otras palabras, todos los valores posibles de un campo **enum** se conocen de antemano y pueden enumerarse.

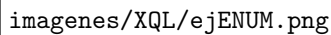


Figura 92:

5.6.3. Preguntas interesantes

1. *Given that the DS1 dataset has 20 fields, how many columns do you see in the result table of the query below? (Ignore columns that are automatically added to the result set like `_time`.)*

Query: `dataset = DS1 | fields fld1 | alter var1 = json_extract(fld1, "$.type") | filter fld1`

2

Explicación: se coge la columna `field1` y `var1`.

2. Which two data types require special functions to create new variables?

Datetime and JSON

3. Which value is known as an untyped constant in XQL?

null

4. Which two data types can be used in alter stages for assignment?

boolean and JSON

5. Given that the DS1 dataset has 20 fields, how many columns are in the result table of the query below? (Ignore columns automatically added)

```
Query: dataset = xdr_data | fields fld1, fld2 | fields * | limit 4
```

2

6. Given that the DS1 dataset is not empty, which value appears in column F1 in the result table?

```
Query: dataset = DS1 | alter f1 = "ABC" | filter f1 = "AB" | alter f1 = "ABCD"
```

null

Explicación:

1. En esta consulta, primero se asigna el valor **ABC** a la columna **f1** para todas las filas del dataset.
2. Luego se aplica un filtro que conserva únicamente las filas donde **f1** sea exactamente igual a **AB**, pero como en ese momento todos los registros tienen el valor **ABC**, ninguna fila cumple la condición y el resultado queda vacío.
3. El último paso, que reasigna **f1** a **ABCD**, ya no se ejecuta sobre ningún registro porque no quedan filas tras el filtro. Por lo tanto, en la tabla de resultados no aparece ningún valor en la columna f1.

7. Which feature on the XQL Search page of the Cortex XSIAM console displays the enum values for enum fields?

Autocomplete

5.7. Operadores

5.7.1. Operadores de operación y booleanos

Los **operadores** son construcciones similares a funciones en los lenguajes de programación. Al igual que las funciones, los operadores reciben argumentos llamados operandos, aplican una operación sobre ellos y devuelven el resultado al invocador. En XQL, los operandos pueden ser variables (campos) o valores.

Por ejemplo: `concat(str1,str2) = str1 + str2`.

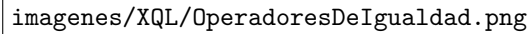


Figura 93:

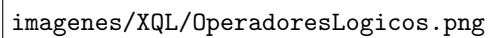


Figura 94:

5.7.2. Operadores de string y rangos

Los **operadores de rango** son útiles para filtrar y realizar operaciones condicionales que verifican si un valor se encuentra dentro de un rango determinado.

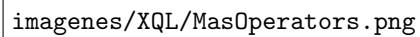


Figura 95:

El valor **in** realiza verificaciones de pertenencia con XQL y determina si un valor coincide con alguno de los valores dentro de un conjunto determinado.

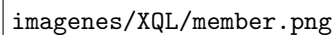


Figura 96:

Los **operadores de cadena (string)** facilitan la manipulación y comparación eficiente de valores de texto en consultas, incluyendo la coincidencia de patrones y la extracción de información.

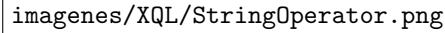


Figura 97:

El operador `+` solo vale para concatenar strings, no para sumar números.

5.7.3. Preguntas interesantes

1. *What is the returned result when using the equality (=) sign in an XQL filter query?*

A Boolean that returns true or false

2. *Which two options are valid XQL operators?*

In/ OR

3. *Which operator tests if a string matches a regular expression?*

$\equiv$

4. *What is the primary XQL stage where XQL operators are used?*

Filter

5. *Which XQL operator has two different functions that differ depending on the stage in which it is used?*

=

6. *Which data type do almost all XQL operators return?*

Boolean

5.8. Visualizar los resultados de una query

Cortex XSIAM coloca los resultados de la ejecución de una consulta XQL en un **conjunto de resultados (result set)**. Existen varias formas de mostrar el contenido de este conjunto de resultados.

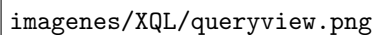


Figura 98:

Existen tres modos de display:

- Table
- Graph
- Advanced

El modo Advanced es idéntico al modo Table, con una diferencia clave:

- En Advanced, las filas de la tabla de resultados se convierten a un formato similar a un log.
- Los nombres de los campos y sus valores se concatenan y se separan con dos puntos (:).
- Todos los pares nombre-valor se colocan en una lista separada por comas.
- Esta lista se muestra en una columna llamada EVENT.
- La tabla también mantiene la información de tiempo en la columna _TIME.

El uso principal del **Fields Pane** es analizar los valores de un campo mediante un histograma. Está disponible en las vistas de Table y Advanced.

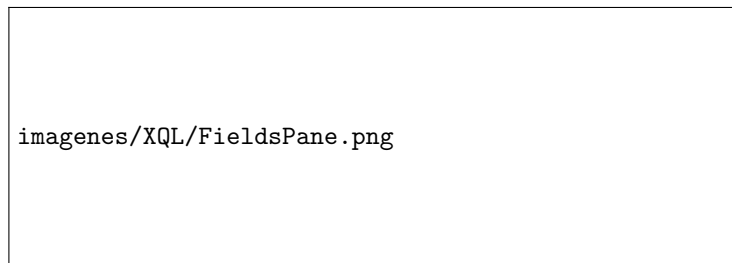


Figura 99: Caption

Un **histograma** es simplemente una tabla de tres columnas: Value, Count y Percentage. Estas columnas son las mismas para todos los campos de la tabla de resultados y no cambian. Ten en cuenta que se crea una tabla de histograma para el campo seleccionado; las tres columnas están relacionadas con ese campo en particular.

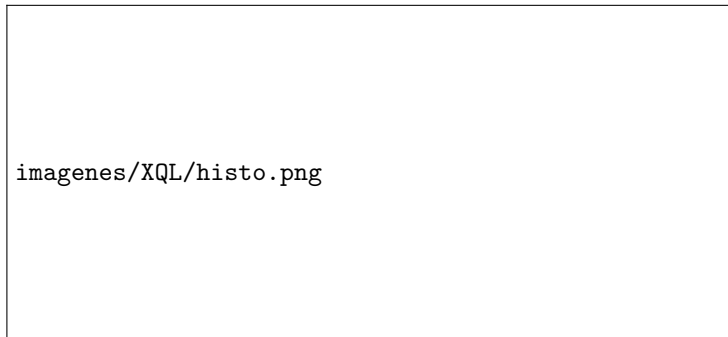


Figura 100: Caption

5.8.1. Preguntas interesantes

1. Which two fields are automatically added to a results table by the Table mode? (Choose two.)

_product y _insert_time

2. Which two fields does the Advanced display mode show in a results table?

_Time and Event

3. Which two field types can you analyze using a histogram on the Query Results tab?

String and ENUM

4. What is the primary use of the Advanced display mode on the Query Results tab?

Easily copying query results as log entities

5. In which two log formats can the Advanced mode display XQL query results?

Tree and JSON

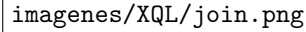
6. Which three columns does a histogram table show in the Fields pane of the Query Results tab?

Value, Count and Percentage

5.9. Dataset Join

La etapa **join** combina datos de múltiples fuentes basándose en una condición o clave especificada. Al definir la condición de unión, puedes consolidar y correlacionar datos de diferentes orígenes, lo que permite realizar análisis más completos, enriquecer la información y obtener un mayor contexto en los resultados.

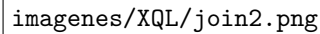
Es decir, **join** en XQL permite asociar diferentes datasets. Esta etapa combina los conjuntos de resultados en un único conjunto de resultados. El conjunto combinado se utiliza posteriormente en las siguientes etapas de la consulta principal.



imagenes/XQL/join.png

Figura 101:

Las **cláusulas** son bloques de construcción o componentes constitutivos de las etapas; pueden ser obligatorias u opcionales.



imagenes/XQL/join2.png

Figura 102:

La sintaxis de **join** en XQL tiene cláusulas obligatorias y opcionales. Una etapa **join** mínima debe incluir una consulta para el join, una cláusula **as** y una cláusula de condición (también conocida como predicado de unión).

Este ejemplo muestra una consulta XQL con una etapa **join** mínima. Como se describió anteriormente en esta sección, se requieren tres cláusulas: **query**, **as** y **condition**. La consulta del join es (`dataset = my_event_desc`), la cláusula **as** es **as e**, y la condición del join es **e.type = event_type**.

```
dataset = xdr_data
| join (dataset = my_event_desc) as e e.type = event_type
```

La **flow** de XQL abarca varios pasos, que incluyen la ejecución, la recuperación y la presentación de los resultados de la consulta.

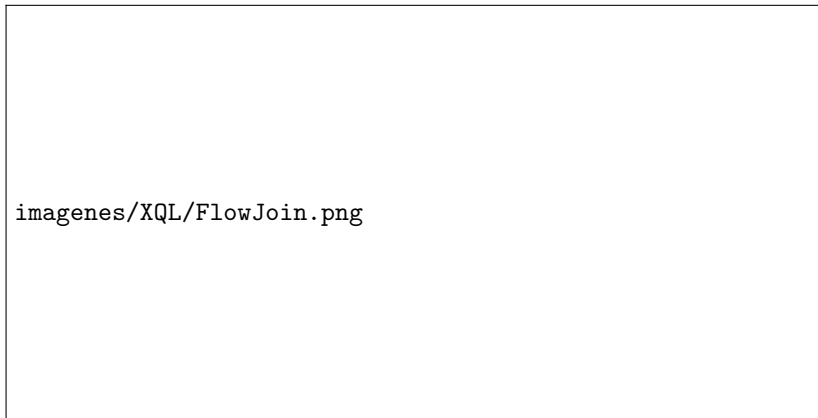


Figura 103:

5.9.1. Tipos de Join

Los **joins** combinan datos de múltiples tablas basándose en columnas relacionadas. Las operaciones de **cross-join**, también conocidas como productos cartesianos, son importantes en XQL para analizar datos provenientes de diferentes tablas.

Comprender el producto cartesiano es fundamental para entender los tipos de join en XQL. En este contexto, el término producto se refiere al resultado de una multiplicación y no tiene relación con productos comerciales.

Si consideramos A y B como dos tablas de resultados en XQL, el **producto cartesiano** se crea al combinar todas las filas de la tabla A con cada una de las filas de la tabla B.



Figura 104:

Los joins en los lenguajes de consulta pueden entenderse conceptualmente como productos cartesianos reducidos. Aquí, *reducidos* significa que se excluyen los registros que no cumplen la condición de unión dentro del producto cartesiano, de modo que no se incluyan en el conjunto de resultados combinado.

Para entender los tipos de join en XQL, consideremos los dos siguientes conjuntos de datos simples:

- Left Table: es el dataset que actuará como el dataset principal en la consulta XQL
- Right Table: es el dataset que actuará como el dataset de la consulta join

Cartesian Join: dadas dos tablas, LT y RT, el Cartesian join se crea emparejando cada fila de la tabla LT con todas las filas de la tabla RT. Si las dos tablas tienen n y m filas respectivamente, el Cartesian join tendrá $n \times m$ filas.

Comprender las diferencias entre los tipos de join en los lenguajes de consulta (QL) puede ser complejo. Una forma común de compararlos es mediante diagramas de Venn.

- El primer diagrama representa un Cartesian join entre LT y RT.
- El segundo diagrama muestra un inner join.

Observa la diferencia visual entre ambos diagramas: el Cartesian join incluye todas las combinaciones posibles, mientras que el inner join solo incluye la intersección (las coincidencias según la condición de unión).

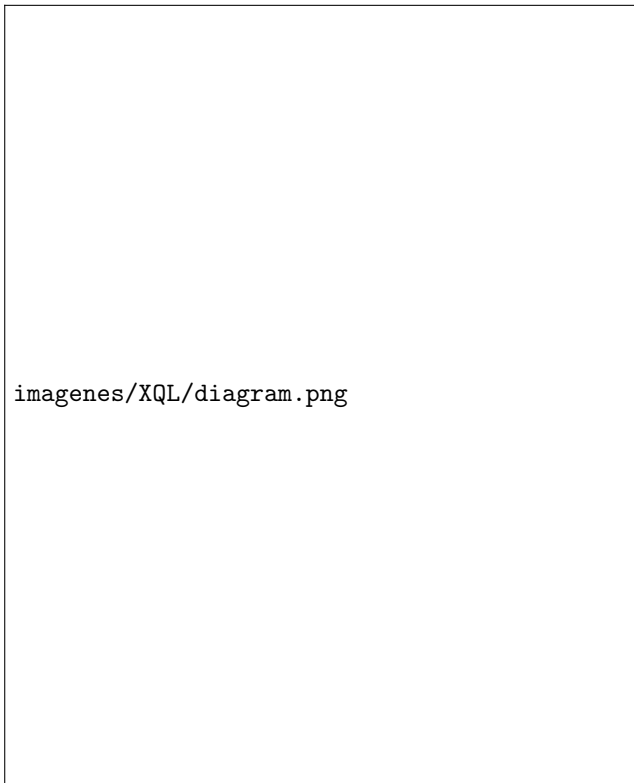
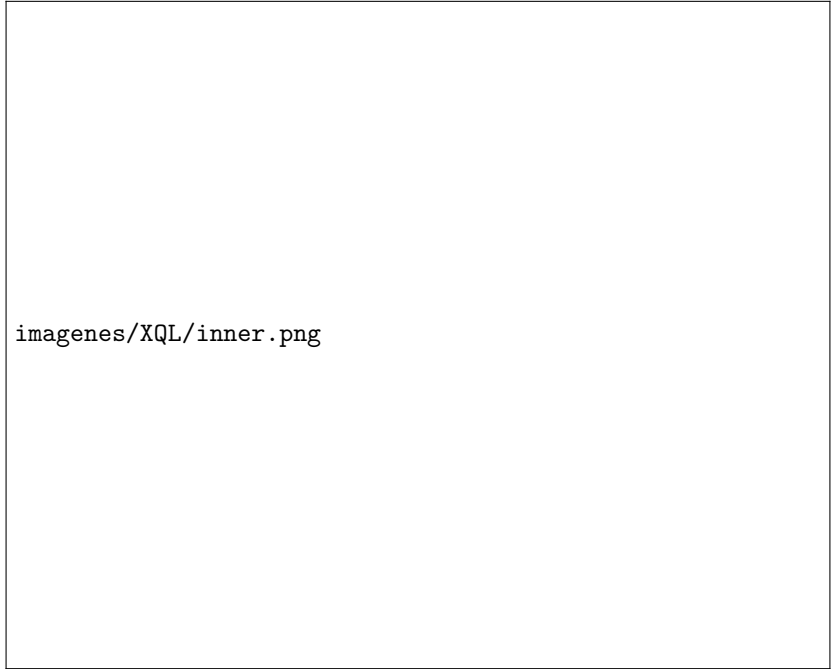


Figura 105:

En la etapa join de XQL existen tres tipos de unión:

- inner: devuelve todos los registros que coinciden en los valores de ambos conjuntos de resultados, el izquierdo y el derecho.

```
dataset = LT | join type=INNER (dataset = RT) as RT2 (RT2.R1 = L1)
```



`imagenes/XQL/inner.png`

Figura 106:

- left: devuelve todos los registros del conjunto izquierdo, así como los registros coincidentes del conjunto derecho.



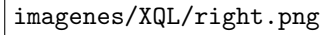
imagenes/XQL/left.png

Figura 107:

```
dataset = LT | join type=LEFT (dataset = RT) as RT2 (RT2.R1 = L1)
```

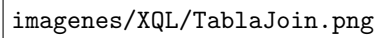
- right: devuelve todos los registros del conjunto derecho, así como los registros coincidentes de la tabla izquierda.

```
dataset = LT | join type=RIGHT (dataset = RT) as RT2 (RT2.R1 = L1)
```



`imagenes/XQL/right.png`

Figura 108:



`imagenes/XQL/TablaJoin.png`

Figura 109:

5.9.2. Preguntas interesantes

1. *How many rows does the following XQL query return?*

```
dataset = A | limit 3 | join type=right (dataset = B | limit 4) as B true=true
```

12

Explicación:

1. La consulta primero limita el dataset A a 3 filas y el dataset B a 4 filas.
2. Luego se realiza un right join, que garantiza que todas las filas del conjunto derecho (B) aparezcan en el resultado.
3. Sin embargo, como la condición del join es `true=true`, no hay ningún filtro real y cada fila de B se combina con todas las filas de A. Esto genera una combinación tipo producto cartesiano entre ambos conjuntos, por lo que cada una de las 4 filas de B se asocia con las 3 filas de A. Como resultado, el total de filas devueltas es 12.

2. *How many rows does the following XQL query return?*

```
dataset = A | limit 3 | join type=right (dataset = B | limit 2) as B true=false
```

2

Explicación:

1. La consulta limita primero el dataset A a 3 filas y el dataset B a 2 filas.
2. Luego se ejecuta un right join, lo que significa que todas las filas del dataset derecho (B) deben aparecer en el resultado.
3. Sin embargo, la condición del join es true=false, lo cual nunca se cumple, por lo que no hay coincidencias entre A y B. Aun así, en un right join se conservan todas las filas de B, rellenando con valores nulos los campos de A cuando no hay match. Por lo tanto, el resultado final contiene únicamente las 2 filas de B.

3. *How many rows does the following XQL query return?*

```
dataset = A | limit 3 | join type=left (dataset = A ) as A2 (A2.ID = ID)
```

3 Explicación:

1. Primero, el dataset A se limita a 3 filas.
2. Luego se realiza un left join con otro dataset A (A2), usando la condición A2.ID = ID.
3. En un left join, todas las filas del conjunto izquierdo (A limitado a 3 filas) se conservan en el resultado, independientemente de si encuentran coincidencias en el conjunto derecho (A2). Dado que ambos provienen del mismo dataset y no se indica ninguna restricción adicional que cambie el número de coincidencias por fila, el número de filas del resultado sigue siendo el del lado izquierdo.

4. *How many rows does the following XQL query return?*

```
dataset = A | limit 4 | join type=inner (dataset = A | limit 3) as A2 (true=false)
```

0

Explicación:

1. El dataset A se limita primero a 4 filas en la parte izquierda y a 3 filas en la subconsulta del join (A2). Luego se aplica un inner join con la condición true=false, que es siempre falsa.
2. En un inner join, solo se devuelven filas cuando la condición del join se cumple. Como true=false nunca es verdadero, no existe ninguna coincidencia entre los dos lados del join. Por lo tanto, no se conserva ninguna fila en el resultado, independientemente de que haya 4 filas a la izquierda y 3 a la derecha.

3. En consecuencia, la consulta devuelve 0 filas.

5. *How many rows does the following XQL query return?*

```
dataset = A | limit 3 | join type=right (dataset = A ) as A2 (true=true)
```

30, suponiendo que A tiene 10 filas.

Explicación:

1. La consulta limita el dataset A a 3 filas en el lado izquierdo, mientras que en el subquery del join el dataset A del lado derecho se ejecuta completo, sin aplicar ese límite.
2. Al tratarse de un right join, todas las filas del dataset derecho se conservan en el resultado final.
3. Como la condición true=true siempre se cumple, cada fila del dataset derecho se combina con todas las filas del lado izquierdo, generando un producto cartesiano.
4. Si el dataset A original contiene 10 filas, el lado derecho aporta esas 10 filas, y cada una se combina con las 3 filas del lado izquierdo, lo que da un total de 30 filas en el resultado.

6. *How many rows does the following XQL query return?*

```
dataset = A | limit 3 | join type=right (dataset = A ) as A2 (A2.ID = ID)
```

10

Explicación:

1. La consulta limita el dataset A a 3 filas en el lado izquierdo, pero en el subquery del join el dataset A del lado derecho se ejecuta completo, sin aplicar ese límite.
2. Al tratarse de un right join, el resultado final conserva todas las filas del dataset derecho, independientemente de lo que ocurra en el izquierdo.
3. La condición A2.ID = ID simplemente empareja registros correspondientes entre ambos lados, pero no elimina filas del lado derecho. Por lo tanto, como el dataset A completo contiene 10 filas, esas 10 filas se mantienen en el resultado final, dando como resultado 10 filas.

5.10. Parseando reglas (revisar)

Una **regla de parsing** procesa una entrada de log en bruto (raw log), aplica la lógica de la regla a los campos del log analizado y luego prepara y devuelve una o más filas para agregarlas a los datasets. El objetivo principal es eliminar partes irrelevantes de los logs en bruto entrantes y organizarlos antes de almacenarlos.

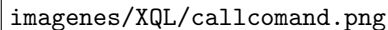
En Cortex XSIAM se puede acceder a las reglas de parseo desde **Configurations >Data Management >Parsing Rules**.

5.10.1. Preguntas interesantes

1. *What are three possible reasons to use XSIAM parsing rules?*
Saving storage space, Adjusting log time and Labeling data
2. *Which three XQL stages are supported in XQLP?*
Alter, Fields and Filter
3. *Which Parsing Rules section is required?*
INGEST
4. *Which two components can run XSIAM parsing rules? (Choose two)*
Broker VM and XDR Collector
5. *Which two Cortex XSIAM roles can access the Parsing Rules page in the management console?*
Account Administrator and Instance Administrator

5.11. Call Function Usage

La etapa **call** inicia una consulta desde la Query Library, incorporando de manera efectiva consultas guardadas dentro de una consulta activa. Para utilizar parámetros, debe existir previamente una consulta que los defina y los utilice.



imagenes/XQL/callcomand.png

Figura 110:

El comando **call** puede utilizarse junto con las etapas **join** y **union** para combinar datos de distintos datasets. Sin embargo, la etapa **join** solo es compatible en las secciones **CONST**, **INGEST** y **RULE**, y no en la sección **COLLECT**. Además, el comando **call** no puede hacer referencia a una sección **RULE** de las Default Rules dentro de la sección de User Defined Rules.

Consideremos un escenario en el que necesitas comparar los datos de hoy con un promedio móvil de 30 días. En este caso, crearías una consulta, la guardarías y luego la usarías dentro de otra consulta. Este proceso demuestra la eficiencia y efectividad de la etapa **call** para optimizar las tareas de análisis de datos.

Realmente, la etapa **call** lo que hace es llamar una consulta guardada dentro de tu consulta activa.

5.11.1. Preguntas interesantes

1. *Which of the following is true when using the CALL command?*
The query must already exist in the Query Library.
2. *Which three functions support using CALL functions in the JOIN stage?*
CONST, **INGEST** and **RULE**
3. *Which sentence is true regarding the use of a CALL command on RULES?*
You cannot call a **RULE** section that exists in Default Rules from the User Defined Rules Section.

4. Which syntax is the correct syntax for a *CALL* command?
— join (call "30 day agent") as averager agent_id = averager.agent_id
5. Which of the following best describes the *CALL* command?
A way to insert a saved search query as if it were in-line in the active query.

5.12. Cortex Cloud: Búsqueda por gráficos

Los datos de seguridad de una organización suelen estar fragmentados en distintos sistemas, como inventarios unificados, gestión de casos y herramientas de seguimiento de incidencias, lo que dificulta obtener una visión integral del panorama de seguridad.

Cortex Cloud Graph Search ofrece una plataforma única e intuitiva para visualizar la postura de seguridad de todo el stack y simplificar la gestión de riesgos.

El gráfico permite a los usuarios priorizar las acciones de remediación, por ejemplo, corrigiendo vulnerabilidades en máquinas virtuales (VM) expuestas a internet.

En la siguiente captura se observan los componentes que lo conforman:

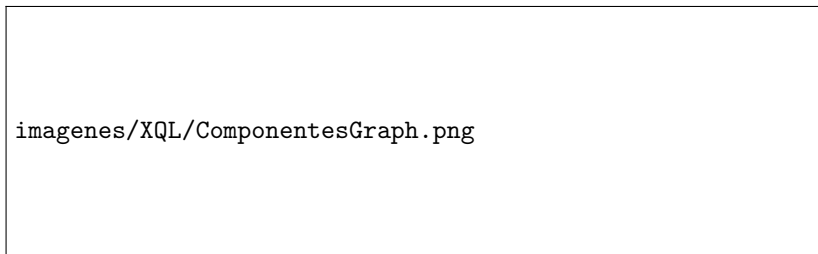
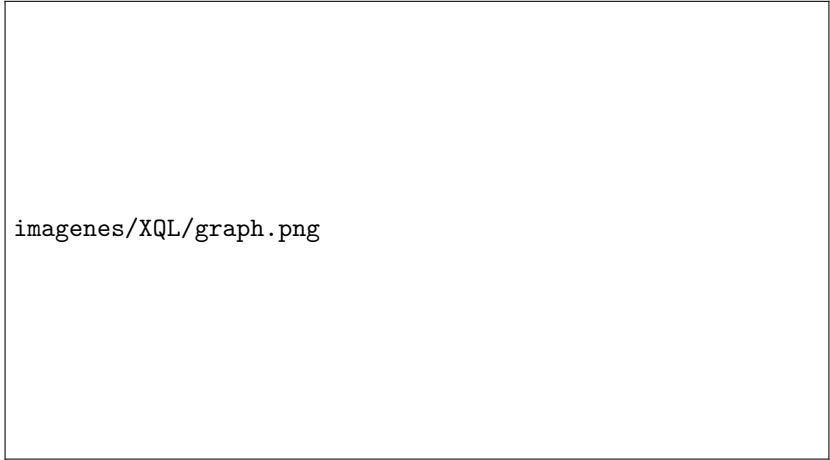


Figura 111:

Dado que Graph Search utiliza la misma lógica que el Query Builder, los usuarios pueden pasar fácilmente a sus capacidades de exploración visual.



imagenes/XQL/graph.png

Figura 112: Falta **Graph Database**

Graph Search requiere permisos de Control de Acceso Basado en Roles (RBAC) de View y Edit para el Query Center y la Personal Query Library, que son los mismos permisos necesarios para el lenguaje Cortex Query Language (XQL).

Las consultas en **Graph Search** se construyen utilizando el Query Builder. Están compuestas por activos (assets), hallazgos (findings) y las relaciones que los conectan, todos representados como nodos y aristas (edges). Las rutas se determinan a partir de datos contextuales. Las consultas se estructuran siguiendo un patrón específico e incluyen objetos de datos predeterminados que el usuario define.

Hay dos métodos para empezar la query:

1. Custom: se compone de tres elementos esenciales (FIND, WHERE, THAT).
2. Out-of-the-Box (OOTB) Queries: librería pre-construidas

Los resultados puedes salir en formato de gráfico (por defecto) o tabla.



imagenes/XQL/Graphsearch.png

Figura 113: Caption

Para que el gráfico sea visualmente intuitivo, Cortex Cloud utiliza formas distintas para dos tipos diferentes de nodos. Los **Assets nodes** tiene forma circular y azul, mientras que los **Finding nodes** de rombos rojos.

El recorrido de los datos dentro de **Cortex Cloud Graph Search** sigue un proceso continuo, transformando la información de seguridad en bruto en conocimientos accionables.

Un Graph Database es una base de datos diseñada para almacenar y consultar información como un grafo, es decir nodos (entidades) y relaciones/aristas (conexiones entre entidades).

5.12.1. Preguntas interesantes

1. *What is the primary benefit of using a single, normalized data model in Cortex Cloud's Graph Search?*

It simplifies investigations by making the underlying data source and cloud provider agnostic.

2. *In the Graph Search visualization, what is the key visual distinction between an Asset Node and a Finding Node?*

Asset nodes are visualized as circles, while finding nodes are visualized as diamonds.

3. *Which of the following describes a Core component of the Graph Search feature, as opposed to a Conditional component?*

The Graph Database, which is essential for storing nodes and relationships

6. Enterprise Runtime Security

6.1. Protección y administración de un endpoint

Un **endpoint** es un dispositivo informático remoto que se comunica de forma bidireccional con la red a la que está conectado. Por ejemplo, un ordenador, smarthphone, portátil...

Para combatir ataques en los que un atacante aprovecha un exploit o una vulnerabilidad de software, Cortex utiliza los **Endpoint Protection Modules (EPM)**. Cada EPM está diseñado para abordar un tipo específico de exploit dentro de la cadena de ataque.

Para garantizar una seguridad integral, los distintos perfiles de seguridad aplican una combinación de módulos de seguridad. Estos módulos actúan como guardianes de los endpoints, desplegando automáticamente protecciones específicas según:

- La naturaleza del ataque
- La configuración de la política de seguridad
- El sistema operativo (OS) del endpoint

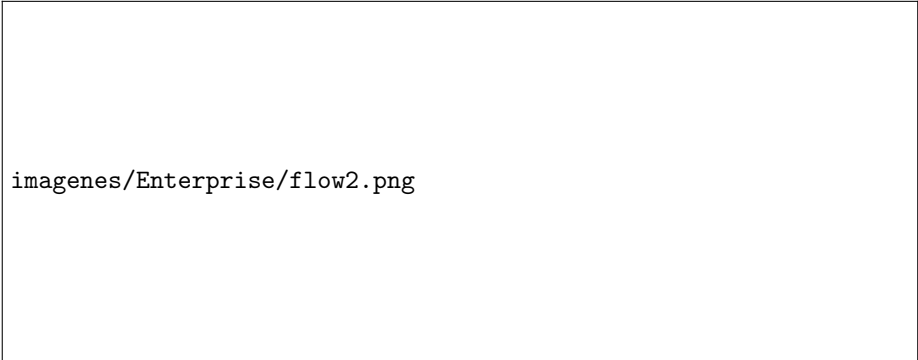
Esta orquestación constituye la primera línea de defensa frente a las amenazas cibernéticas.

Cortex ofrece **perfiles de seguridad predeterminados** diseñados para habilitar protección inmediata en los endpoints. Estos perfiles permiten adaptar y reutilizar configuraciones en distintos grupos de endpoints, mejorando la personalización y la eficiencia de la seguridad. Cuando el agente de Cortex detecta un comportamiento que coincide con una regla de seguridad definida, aplica el perfil de seguridad asociado para realizar una evaluación adicional. Algunos perfiles son:

- Restriction profile: limitar que archivos se pueden ejecutar
- Exploit profile: bloquean los intentos de explotar vulnerabilidades en navegadores y OS
- Agent Settings profile: customizar el agente de cortex
- Malware profile: previene que se ejecute malware como troyanos o virus
- Exceptions profile: proporcionan un medio para anular políticas de seguridad de forma selectiva

6.1.1. Protección a los endpoints

El **flujo de análisis y protección** de archivos en Cortex es un mecanismo esencial que garantiza una seguridad integral en los endpoints mediante técnicas avanzadas de protección multimétodo, diseñadas para defenderse contra malware conocido y desconocido, así como contra exploits de software.



imagenes/Enterprise/flow2.png

Figura 114:

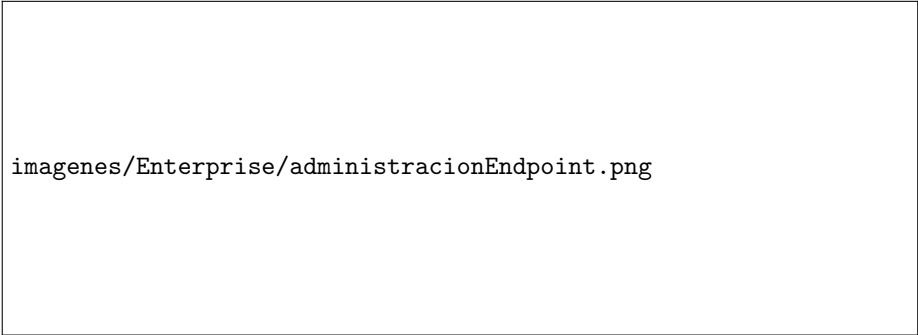
La **comunicación efectiva entre Cortex y los agentes de Cortex es fundamental** para mantener actualizadas las políticas de seguridad y responder oportunamente al estado de los endpoints. Esta comunicación bidireccional garantiza que los agentes cuenten con la información más reciente, al mismo tiempo que permite recopilar datos importantes desde los endpoints.

Este proceso, compuesto por:

- Comunicación iniciada por el agente (Agent-Initiated Communication) cada cinco minutos mediante un mecanismo de *heartbeat*. Este intercambio regular de datos incluye información esencial sobre los agentes y los datos recopilados de los endpoints.
- Comunicación iniciada por el servidor (Server-Initiated Communication) mediante una conexión de web socket mantenida. Esta capacidad mejora el tiempo de respuesta y ayuda a evitar retrasos en acciones críticas, como poner archivos en cuarentena o aislar equipos.

6.1.2. Administración de un endpoint

En la consola de administración de Cortex, un endpoint gestionado es cualquier sistema en el que esté instalado y registrado un agente de Cortex. Una vez instalado el agente en un endpoint, este se conecta a la instancia de Cortex, solicita una licencia y se registra como un producto con licencia (*Inventory > Endpoints > All Endpoints*).



imagenes/Enterprise/administracionEndpoint.png

Figura 115:

Las acciones de endpoint, como la gestión de agentes, la aplicación de medidas de seguridad, la recopilación de datos o cambios en la configuración. Estas acciones permiten a los administradores mantener una postura de seguridad sólida, responder rápidamente a amenazas y garantizar que los endpoints cumplan con las políticas de la organización.



imagenes/Enterprise/Action.png

Figura 116:

Los **grupos de endpoints** te permiten aplicar fácilmente reglas de políticas a un conjunto específico de endpoints. Hay dos tipos, estáticos o dinámicos (según las características del endpoint).

6.1.3. EndpointAgents

La implementación del **agente de Cortex** ofrece diversas opciones y consideraciones para satisfacer las necesidades de distintas organizaciones. Estas opciones abarcan aspectos como:

- Escalabilidad
- Compatibilidad
- Modelos de despliegue

El proceso de instalación del agente de Cortex en los endpoints comienza con la creación de un **paquete de instalación del agente**, un paso fundamental para garantizar la seguridad de los dispositivos.

Este paquete, adaptado a las necesidades específicas de cada organización, facilita el despliegue del agente y permite mantener el control y la visibilidad sobre la seguridad de la red.

Un aspecto fundamental de la gestión de la seguridad de todos los endpoints es **mantener los agentes de Cortex actualizados**. Después de la instalación inicial del agente de Cortex y su correcta registración con Cortex, puedes actualizar el software del agente de forma sencilla. Este proceso de actualización varía según la plataforma del endpoint, lo que garantiza flexibilidad y facilidad de operación.

Si se elimina un agente, este pasa a estado *Deleted* y se borra de manera definitiva pasados 90 días. Hasta ese momento, se puede acceder a los datos del endpoint igualmente.

La desinstalación del agente de Cortex puede ejecutarse de forma rápida y eficiente a través de la consola de gestión de Cortex, ofreciendo la capacidad de administrar múltiples endpoints simultáneamente. Este proceso inicia una serie de eventos bien definida, asegurando que el endpoint vuelva rápidamente a un estado sin protección.

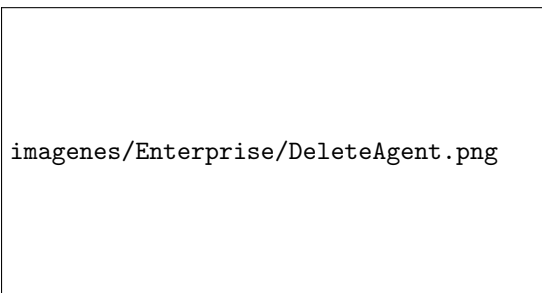


Figura 117:

6.1.4. Endpoint Support

Varias funcionalidades de Cortex ayudan a respaldar la gestión de endpoints y las tareas administrativas, entre ellas:

- Etiquetas de endpoint (endpoint tags)
- Tokens de agente (agent tokens)
- Generación y recuperación de archivos de soporte (generate/retrieve support files)

Los **grupos de endpoints** proporcionan una forma práctica de administrar y aplicar reglas de política a endpoints específicos dentro del ecosistema de Cortex. Se pueden crear de manera dinámica o estática.

6.1.5. Preguntas interesantes

1. What are the components in a network that serve as the user interfaces to access data and applications?

Endpoints

2. How are XDR agents installed on endpoints?

Using tailored installation packages

3. True or false? File analysis and protection flow ensures comprehensive endpoint security by using advanced multi-method protection techniques to safeguard against known and unknown malware and software exploits.

True

4. How are Dynamic Groups in Cortex populated?

Automatically based on endpoint characteristics such as tags, hostname, and agent version

5. What is one of the key considerations for a successful Cortex deployment?

Scalability and compatibility

6. What is the main purpose of Exploit Security Profiles in Cortex?

Protecting against vulnerabilities in browsers and operating systems

7. How do different security profiles in Cortex work together to protect endpoints?

They deploy specific protections based on the nature of the attack and security policy configuration.

8. How does Cortex handle the deletion of agents, and what happens to the associated data?

Data is retained for 90 days

6.2. Cortex Runtime Security

6.2.1. Introducción de agentes

El **agente de Cortex XDR** es el componente en tiempo de ejecución o de endpoint de la solución Cortex. Este agente proporciona protección multimétodo

contra exploits y malware en los endpoints. También puede instalarse en los hosts en la nube de la organización para ofrecer una protección integral.

Las funcionalidades clave del agente de Cortex XDR incluyen:

- Protección multimétodo contra exploits y malware
- Recopilación de información relevante del endpoint o del host en la nube
- Envío de los datos recopilados a la instancia de Cortex para un análisis avanzado de detección

Los agentes pueden actualizarse de forma manual o automática a través de la consola de administración de Cortex.

El agente de Cortex XDR está disponible para Windows, macOS, Linux, Android e iOS, con capacidades y componentes que varían según la plataforma.

Puedes interactuar con el agente de Cortex XDR en los endpoints utilizando la **consola gráfica del agente de Cortex** o la aplicación de línea de comandos llamada **Cytool**. La consola del agente está disponible en Windows, macOS, iOS y Android, mientras que Cytool está disponible en Windows, macOS y Linux.

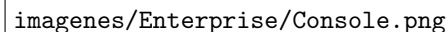
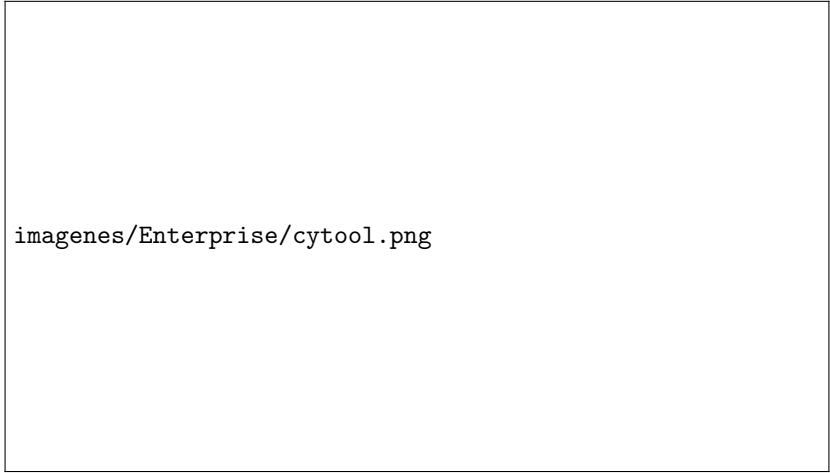
The image is a placeholder for a screenshot of the Cortex agent console. It is represented by a rectangular box containing the text 'imagenes/Enterprise/Console.png'.

Figura 118: consola gráfica del agente de Cortex



imagenes/Enterprise/cytool.png

Figura 119: cytool

La comunicación entre las instancias de Cortex y los agentes se realizan mediante **HTTPS** (para el heartbeat) y **WebSocket**.

Los agentes de Cortex pueden subir dos tipos de datos: **issues** o **logs**.

Una instancia de Cortex entrega la **actualización de contenido a los agentes en fragmentos**, no como un único archivo. Las actualizaciones parciales permiten que los agentes reciban solo las nuevas incorporaciones y actualizaciones.

Flujo de despliegue del agente: después de que tu tenant de Cortex sea activado, puedes desplegar el agente Cortex XDR en tus endpoints. A continuación se muestra una descripción general de alto nivel del flujo del proceso de despliegue.

1. Crear un paquete de instalación
2. Descargar el paquete de instalación
3. Ejecutar el paquete en el endpoint

6.2.2. Conceptos clave y administración sana

Cortex utiliza dos identificadores para distinguir de forma única el software y el hardware asociados a un agente de Cortex XDR:

- Endpoint ID: Identifica de manera única la instalación del agente (instancia de software) en un endpoint.
- Machine ID: Identifica de forma única el dispositivo físico o virtual (hardware) donde está instalado el agente.

Realizar **verificaciones completas** del estado del agente es una práctica fundamental en Cortex. Estas incluyen una serie de evaluaciones y optimizaciones esenciales para mantener la salud, eficiencia y preparación de seguridad de la infraestructura de Cortex en una organización.

Las comprobaciones de estado permiten:

- Validar que los agentes estén activos y correctamente conectados.
- Confirmar que las políticas y contenidos estén actualizados.
- Detectar fallos de comunicación o configuración.
- Identificar problemas de rendimiento o protección deshabilitada.

Evaluar la versión del agente es uno de los aspectos clave dentro de las verificaciones de estado del agente. Es fundamental porque impacta directamente en la seguridad y eficiencia de la infraestructura de seguridad de la organización.

Al analizar la versión del agente, se deben considerar las siguientes áreas:

- Verificación de versión: Confirmar que los endpoints ejecuten la versión aprobada o recomendada.
- Evaluación de fin de vida (EOL): Identificar versiones que hayan alcanzado o estén próximas a alcanzar el EOL.
- Impacto operativo: Analizar cómo la versión instalada puede afectar el rendimiento o la compatibilidad.
- Actualización oportuna: Garantizar que las actualizaciones se apliquen de manera rápida y controlada.
- Minimización de vulnerabilidades: Reducir la exposición a fallos de seguridad presentes en versiones antiguas.

Dentro del contexto de las **verificaciones de estado del agente** en Cortex, la evaluación del **estado operativo** es fundamental porque influye directamente en el rendimiento general y en la preparación de seguridad de la infraestructura.

Evaluar las **brechas de contenido (content gap)** como parte de las verificaciones de estado es fundamental para mantener un entorno de Cortex sólido y resiliente. Esto garantiza que todos los endpoints estén actualizados con la información más reciente sobre amenazas y vulnerabilidades, lo que contribuye a mejorar la detección, prevención y preparación general en ciberseguridad.

Abordar los **registros duplicados y desactualizados** de endpoints como parte de las verificaciones de estado del agente es esencial para mantener la precisión de los datos, optimizar recursos, reducir falsos positivos y garantizar una respuesta a incidentes coherente.

6.2.3. Resolución de problemas: Metodologías y herramientas

Se suele seguir la regla **DIREC**:

1. **Define**
2. **Isolate**
3. **Resolve**
4. **Confirm**

Para resolver problemas (**troubleshooting**) se debe seguir el siguiente flujo:



Figura 120:

La aplicación **Cytool** es la interfaz de línea de comandos utilizada por los administradores para trabajar con el agente de Cortex XDR. Las funciones van

mucho más allá de lo que ofrece la consola del agente, ya que permite realizar tareas avanzadas de diagnóstico, configuración y resolución de problemas. Cytool forma parte del paquete de instalación del agente de Cortex XDR y se instala automáticamente cuando se instala el agente.

`cytool <option> [<option parameters>]`

Los **datos de configuración** del agente de Cortex XDR se distribuyen en varias ubicaciones y archivos dentro del endpoint.

Los componentes del agente utilizan datos clave-valor (key-value) almacenados en disco para mantener la persistencia de su información privada. Estos datos se guardan en archivos ubicados en la siguiente ruta en sistemas Windows:

`%PROGRAMDATA%\Cyvera\LocalSystem\Persistence`

Los componentes del agente de Cortex XDR escriben en el archivo **trapsd.log** para registrar sus acciones.

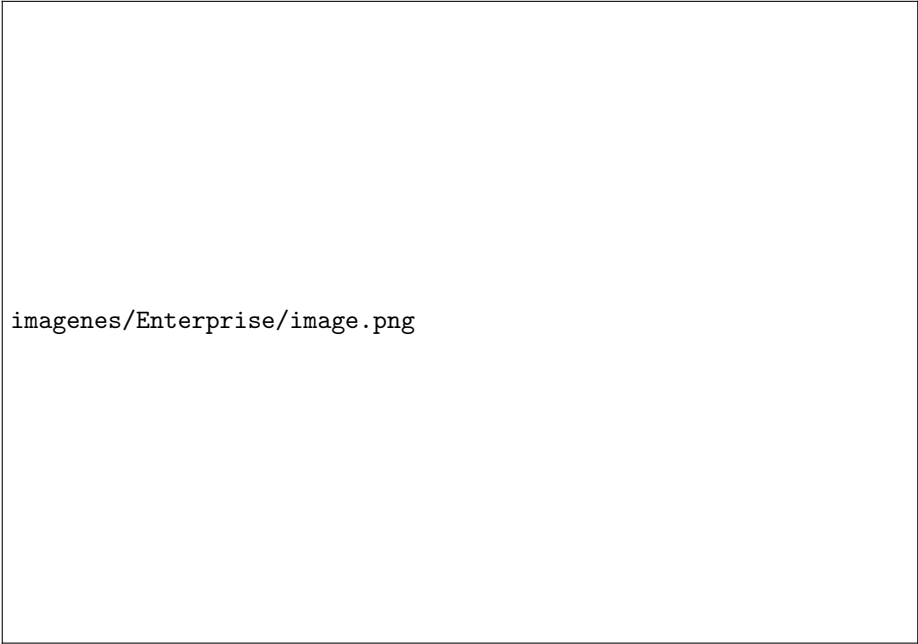
6.2.4. Trabajando con technical support

Un **archivo de soporte** es un archivo comprimido que recopila todos los registros (logs) de un endpoint.

Se genera bajo demanda para ayudar al equipo de Soporte Técnico de Palo Alto Networks a analizar, diagnosticar y resolver problemas del sistema.

Por lo general, este archivo se adjunta a los casos de soporte para facilitar la investigación y acelerar la resolución de incidencias.

Cortex permite crear, recuperar y utilizar **tokens de agente**. Este es útil en situaciones en las que un administrador no necesita conocer la contraseña del agente, pero aun así necesita acceder y realizar operaciones sobre el agente.



imagenes/Enterprise/image.png

Figura 121:

6.2.5. Preguntas interesantes

1. Which Cytool command sets the debug log-level for all the components?
cytool log set_level 7 all
2. Which Cytool command disables the XDR agent on next system startup?
cytool startup disable
3. What is the primary difference between the Endpoint ID and the Machine ID?

The Endpoint ID identifies the agent software, while the Machine ID identifies the hardware.

4. What is the primary purpose of generating a support file from an endpoint?
To aggregate all endpoint logs for troubleshooting by Technical Support
5. On a Windows endpoint, where would you look in the registry to find agent-related settings such as the list of trusted signers?

HKLM/SYSTEM/Cyvera

6. During an uninstall and reinstall operation, why does the Cortex XDR agent reuse the agent.id and hardware.id files?

To eliminate duplicate endpoint entries in the management console.

7. To conserve bandwidth when updating agents, what distribution method is enabled by default to allow agents to retrieve installer files from other agents on the same subnet?

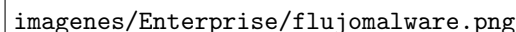
Peer-to-Peer (P2P) Distribution

6.3. Malware Protection

Los **Perfiles de Malware** contienen configuraciones de seguridad para los **Módulos de Protección contra Malware (MPM)**.

Estos módulos están diseñados para prevenir tanto malware conocido como desconocido, incluyendo troyanos, virus o gusanos.

Para añadir un perfil de malware: *Inventory > Endpoints > Prevention > Profiles > Add Profile*.



imagenes/Enterprise/flujomalware.png

Figura 122: Caption

Un file path puede añadirse a la lista de permitidos (Allow List) del perfil de Malware como una excepción global o basada en perfil. Una excepción global puede añadirse desde

- la página de Issues
- la vista de Causality
- las tablas de resultados XQL
- haciendo clic en el botón +New Action en el Action Center

Las excepciones basadas en perfil se añaden desde las Legacy Agent Exceptions.

La lista global de permitidos se encuentra en **Investigation and Response >Response >Action Center >Currently Applied Actions >Allow List**.

6.3.1. Portable Executables and DLL Examination

Cuando un archivo intenta ejecutarse, pasa por un flujo de examen diseñado para evaluar su nivel de riesgo antes de permitir su ejecución.

Durante este proceso, el examen de ejecutables portables (PE) y archivos DLL verifica distintos elementos de decisión, entre ellos:

- Fuentes de veredicto (por ejemplo, reputación o análisis previo del archivo).
- Listas de permitidos (allow lists).
- Listas de bloqueados (block lists).

Según el resultado de estas verificaciones, el sistema determina si el archivo se permite, se bloquea o se somete a un análisis adicional.

WildFire threat intelligence da dos servicios a Cortex, análisis de ficheros para crear veredictos de archivos y un servicio cloud para proporcionar los veredictos.

Por ejemplo, si el hash de un archivo ejecutable portable (PE) o de una macro no se encuentra en la caché del endpoint, Cortex consulta ese hash en WildFire. Este devuelve un veredicto basado en su base de datos y análisis previos. Según el resultado (malicioso, benigno o desconocido), el agente decide permitir, bloquear o aplicar medidas adicionales al archivo. Por ejemplo, si el veredicto es que el archivo es malware, este será puesto en cuarentena.

Cada agente de Cortex XDR mantiene localmente una tabla de consulta (**lookup table**) para almacenar registros de un análisis anterior.

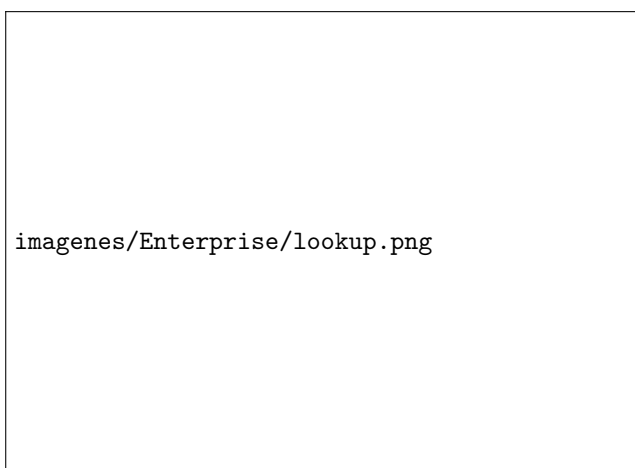


Figura 123:

Si el hash de un archivo ejecutable portátil o de una macro no se encuentra en la caché del endpoint, Cortex consulta ese hash en WildFire.

Los usuarios a menudo quieren saber cómo pueden confiar en las aplicaciones publicadas en Internet. La firma digital de código basada en certificados digitales proporciona una solución para resolver este problema de confianza. Los ejecutables firmados garantizan que su código no ha sido modificado desde el momento de la firma.

6.3.2. Comportamiento de protección de amenazas (BTP)

BTP (Behavioral Threat Protection) es un módulo de protección posterior a la ejecución que detecta de forma inteligente ataques sofisticados.

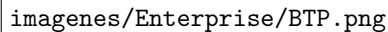
The image shows a rectangular box containing the text "imagenes/Enterprise/BTP.png". This likely represents a file path or a diagram element related to the BTP (Behavioral Threat Protection) system.

Figura 124:

Funciona mediante:

- La supervisión continua de la actividad del endpoint.
- La comparación de esa actividad con un conjunto de reglas predefinidas, conocidas como reglas BTP.

Cuando se identifica un comportamiento que coincide con estas reglas, el sistema puede generar alertas y aplicar acciones de protección según la política configurada.

BTP (Behavioral Threat Protection) está diseñado principalmente para detectar y prevenir ataques basados en scripts que requieren múltiples pasos para tener éxito.

BTP compara continuamente las operaciones en curso de los procesos sobre los recursos del sistema con su conjunto de reglas. Una **regla BTP** es un conjunto predefinido de operaciones, agrupadas lógicamente, que suelen ser aprovechadas por los atacantes. Por ejemplo, conectarse al puerto 443 o abrir la CMD.

6.3.3. Motor de inspección de paquetes de red

El **Motor de Inspección de Paquetes de Red (Network Packet Inspection Engine Capabilities)** analiza el tráfico de red en la capa de protocolo a medida que los paquetes fluyen en la red.

El análisis a nivel de red incluye:

- Inspección de paquetes TCP (Transmission Control Protocol).
- Inspección de paquetes UDP (User Datagram Protocol).
- Identificación de firmas de aplicaciones, como HTTP (Hypertext Transfer Protocol) y DNS (Domain Name System).
- Análisis de los encabezados de las aplicaciones.

Este enfoque permite detectar y bloquear actividades maliciosas directamente en el tráfico de red antes de que impacten al sistema.

6.3.4. Otros módulos de protección

Por ejemplo:

1. El agente de Cortex XDR puede prevenir que **macros maliciosas** incrustadas en archivos de Microsoft Office comprometan el endpoint.
2. La **Protección contra Procesos Hijos Maliciosos** bloquea procesos objetivo conocidos para evitar que inicien procesos hijos legítimos que puedan ser utilizados con fines maliciosos.
3. Protección frente a ransomware. Los agentes de Cortex XDR utilizan ficheros señuelos para atraer el ransomware.
4. Los agentes de Cortex XDR detectan y bloquean la ejecución de Mimikatz (herramienta que automatiza el proceso de revelación de credenciales en Windows).
5. Protección frente a webshell.
6. Módulo de protección contra la recopilación de credenciales. Cuando el agente de Cortex XDR detecta actividad diseñada para obtener contraseñas, puede bloquear dicha actividad o reportarla. Además, los archivos responsables pueden ponerse en cuarentena. Si las protecciones están activas, ciertos archivos y carpetas pueden designarse mediante una lista de permitidos.
7. Protección contra minería de criptos.

6.3.5. Endpoint Scanning

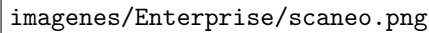
Puede escanear los sistemas de archivos locales en los endpoints para detectar:

- Archivos ejecutables portables (PE).
- Archivos de Microsoft Office que contengan macros.

Este escaneo permite identificar archivos potencialmente maliciosos almacenados en el equipo, incluso si aún no han sido ejecutados.

Los escaneos pueden ser bajo demanda o periódicos.

Los usuarios finales pueden hacer clic derecho en una carpeta en el Explorador de archivos y seleccionar Scan with Cortex XDR para iniciar un análisis. Luego, los usuarios pueden seguir el estado del análisis en curso desde la consola del agente de Cortex XDR.



imagenes/Enterprise/scaneo.png

Figura 125:

6.3.6. iOS Malware Protection Modules

Filtrado de URL en iOS: el objetivo de la configuración de filtrado de URL en iOS es funcionar como una política que permite al administrador configurar manualmente una lista de permitidos (Allow List) y una lista de bloqueados (Block List).

Los servicios de Mensajes de Texto/Mensajería Multimedia (SMS/MMS) y el filtrado de URL ahora tienen módulos separados (Network Protection, Safari Browser Security y la función SMS/MMS). Cuando la extensión de seguridad inspecciona el tráfico de red, primero revisa la Allow List y Block List configuradas manualmente para el filtrado de URL. Luego, el módulo permite o bloquea el tráfico saliente de la aplicación que accede a la URL (por ejemplo, el acceso a una API de una app). Ten en cuenta que este comportamiento de bloqueo difiere del de los módulos de Safari Browser y Network/EDR.

El módulo de **Spam Reports** permite reportar números de teléfono y SMS no deseados a Cortex, que luego puede utilizar esta información para fines de bloqueo. El bloqueo de llamadas y mensajes (Call and Message Blocking) permite a la plataforma Cortex bloquear llamadas y mensajes de remitentes de spam conocidos.

6.3.7. Preguntas interesantes

1. *Which verdict source provides official file verdicts?*
WildFire
2. *Which protection module uses decoy files?*
Rasonware protection
3. *Which Windows application can the Password Theft Protection module detect and block from running?*
Mimikatz
4. *What is the name of the XDR agent component that provides static analysis of files that are attempted to be run?*
Local Analysis
5. *Which option is inspected by the Network Packet Inspection Engine?*
HTTP
6. *What options compose a Behavioral Threat Protection Rule?*

A name and action, such as block

7. *How are Malware Protection Modules (MPMs) configured for specific endpoints?*

By configuring a Malware Profile added to a Policy associated with the endpoints

8. *When a file is attempting to run, in which order does the examination flow occur?*

Allow List: Path ¿WildFire ¿Local Analysis

9. *At which stage in the execution of applications does WildFire Lookup occur?*

Pre-execution prior Local Analysis

6.4. Exploit Protection

Un exploit típico utiliza una secuencia de técnicas de explotación.

Una **técnica de explotación (exploit technique)** es un método de programación que aprovecha un tipo específico de vulnerabilidad o error de software y permite avanzar el ataque hacia la ejecución del código del atacante. Una misma técnica de explotación puede utilizarse en cientos de exploits diferentes, ya que está basada en un tipo de fallo común y no en una vulnerabilidad específica.

Te puedes proteger de los exploits bloqueando las técnicas de explotación, no un ataque individual, que es lo que hace Cortex.

6.4.1. Técnicas de explotación y mecanismos de defensa

Un proceso es creado por el sistema operativo en el momento de la ejecución para contener los componentes básicos relacionados con la ejecución, tales como:

- Hilos (threads) para la ejecución del código.
- Heap y stack para la gestión de datos.
- Variables globales.
- Carga de otras bibliotecas (librerías) dentro de un espacio de direcciones virtual.

El proceso actúa como un contenedor aislado que permite que el programa se ejecute de manera organizada y controlada por el sistema operativo.

Los atacantes utilizan el ataque de **desbordamiento de búfer (buffer overflow)** para aprovecharse de datos críticos y alterar el flujo normal de ejecución de un programa con fines maliciosos. Al escribir más datos de los que el búfer puede almacenar, pueden sobrescribir información sensible (como direcciones de retorno en la pila), lo que les permite:

- Modificar el comportamiento del programa.
- Ejecutar código arbitrario.

- Obtener acceso no autorizado o elevar privilegios.

Los **stack canaries** ayudan a proteger contra ataques de desbordamiento de búfer al detectar modificaciones no autorizadas en la pila antes de que se ejecute código malicioso. Funcionan colocando un valor especial (canario) entre los datos locales del stack y la dirección de retorno. Si un desbordamiento intenta sobrescribir la dirección de retorno, también alterará el valor del canario.

Data Execution Prevention (DEP) ayuda a proteger contra exploits al impedir que la CPU ejecute código desde páginas de memoria a menos que estén marcadas como ejecutables.

Los atacantes utilizan **ROP (Return-Oriented Programming)** para hacer un uso ilegítimo de funciones y rutinas legítimas presentes en las bibliotecas del sistema. En lugar de inyectar código malicioso nuevo, el atacante:

- Reutiliza pequeños fragmentos de código existentes llamados **gadgets**.
- Encadena estos fragmentos mediante direcciones de retorno manipuladas en la pila.
- Construye una secuencia que ejecuta acciones maliciosas.

Address Space Layout Randomization (ASLR) defiende contra este tipo de ataques. Implementa un espacio de direcciones en el que los componentes de un proceso se colocan de forma aleatoria en cada ejecución. La ubicación de los segmentos de código y datos en la memoria del proceso también se aleatoriza. Esta práctica hace que los ataques basados en la suposición de que estos componentes se encuentran en una ubicación conocida fallen.

6.4.2. Endpoint Protection Module

Un **Endpoint Protection Module (EPM)** está diseñado para identificar y bloquear una técnica de explotación específica.

Cada EPM se enfoca en un tipo concreto de exploit (por ejemplo, corrupción de memoria, ROP, desbordamientos de búfer, entre otros) y aplica mecanismos de protección especializados para:

- Detectar el comportamiento asociado a esa técnica.
- Interrumpir el flujo del ataque.
- Prevenir la ejecución de código malicioso.

6.4.3. Perfiles de prevención

Los **Prevention Profiles** contienen grupos de configuraciones que determinan qué EPMs se habilitan en determinados procesos y en el kernel, con el fin de prevenir que amenazas exploten vulnerabilidades o fallos de software. Cortex no permite habilitar directamente un EPM específico.

En su lugar, los Prevention Profiles agrupan los EPMs de forma funcional en secciones, según el tipo de componente vulnerable en el endpoint (por ejemplo, aplicaciones, procesos del sistema, kernel, etc.).

Cada sección:

- Habilita múltiples EPMs.
- Los aplica a distintos procesos según corresponda.

Si dos secciones se superponen sobre el mismo proceso e incluyen un EPM en común, ese EPM se aplica solo una vez al proceso, evitando duplicidad y manteniendo la eficiencia del sistema

El **Exploit Profile** protege de:

- Browser exploits
- Known Vulnerable Processes
- Operating System Exploit
- Logical Exploits

6.4.4. Trabajando con procesos protegidos

Puedes utilizar la aplicación Process Explorer del paquete SysInternals Suite para obtener la lista de las **DLLs que Cortex ha inyectado en un proceso**.

Puedes utilizar la aplicación **Cytool** con la opción **enum** para obtener la lista actual de procesos protegidos en un endpoint.

Se puede utilizar **driverquery.exe** para ver los drivers de Cortex en el Kernel.

Cortex utiliza excepciones de EPM y exclusiones de issues para personalizar la protección de endpoints. Las excepciones modifican lo que los módulos de prevención bloquean o permiten. Las exclusiones de issues controlan la visibilidad al suprimir problemas no críticos en la consola de gestión. Ambas funciones proporcionan flexibilidad operativa mientras se mantiene la visibilidad de las amenazas.

6.4.5. Preguntas interesantes

1. Which option is a kind of exploitation technique?

Heap spray

2. What is the primary reason Palo Alto Networks' Cortex focuses on blocking exploitation techniques rather than individual exploits?

A small number of new techniques are invented each year.

3. Which of the following best describes the purpose of a Prevention Profile in Cortex?

It defines which groups of endpoint protection modules (EPMs) are active for certain processes.

4. *What is one technique used by many attackers to attempt to overcome the difficulty of placing shellcode at known memory locations?*

NOP sled

5. *Which threat vector can be vulnerable on an Endpoint?*

Libraries and loading mechanisms

6. *Which command will list process IDs (PIDs) that are protected by Cortex XDR on an Endpoint?*

cytool enum

7. *Which technique takes illegitimate advantage of known-legitimate library functions?*

Return-Oriented Programming

6.5. Cortex Profiles, Policy Rules, and Optimization

6.5.1. Perfiles de prevención

Desde *Inventory > Endpoints > Policy Management*, Cortex ofrece tres secciones para administrar reglas mediante perfiles y políticas:

- **Prevention:** Permite configurar los perfiles de prevención que controlan los EPMs y las protecciones contra exploits y malware. Permite crear o gestionar perfiles, policy rules y excepciones
- **Extensions:** Permite gestionar módulos y capacidades adicionales que amplían la funcionalidad del agente
- **Settings:** Permite definir configuraciones generales del agente y del endpoint

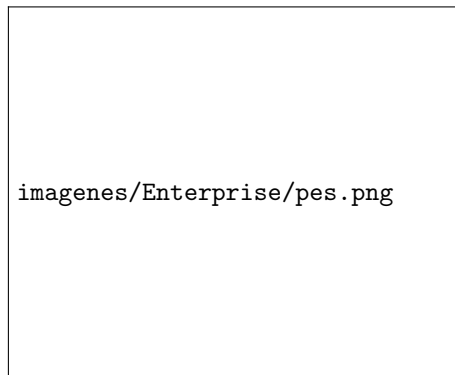


Figura 126: C

Existen unos perfiles preconfigurados.
Los cinco perfiles de prevención son:

- **Agent Settings:** contiene ajustes que especifican cómo operan normalmente los agentes de Cortex XDR, como establecer los límites de espacio de registro en los endpoints, habilitar la recopilación de datos mejorados del endpoint (EED) o definir una nueva contraseña de supervisor.
- **Exploit:** contiene configuraciones relacionadas con la protección contra exploits. Los perfiles de exploit configuran la protección frente a kits de explotación, ejecución ilegal de código y otros intentos de aprovechar vulnerabilidades de procesos y del sistema.
- **Malware:** contiene configuraciones relacionadas con la protección anti-malware. Los perfiles de malware protegen contra la ejecución de software malicioso, incluidos troyanos, virus, gusanos y grayware.
- **Restrictions:** limitan desde dónde pueden ejecutarse los archivos ejecutables en un endpoint. Por ejemplo, puede restringir la ejecución de archivos desde carpetas locales específicas o desde medios extraíbles. Por ejemplo, el perfil de Restricciones puede bloquear los intentos de ejecutar cualquier archivo desde una unidad USB o desde carpetas conocidas, como C:/Temp.
- **Exceptions:** se crea para ajustar de forma granular algunos parámetros en otros perfiles, como deshabilitar un módulo de protección contra exploits para un proceso específico que fue habilitado globalmente en un perfil de Exploit.

Para añadir, importar o exportar un perfil, navega a *Inventory > Endpoints > Policy Management > Prevention > Profiles*.

6.5.2. Control de dispositivos y control de excepciones

De forma predeterminada, Cortex permite todos los dispositivos externos y trabajos de impresión en endpoints con Windows y macOS. La funcionalidad de Device Control permite:

- Restringir dispositivos USB
- Restringir dispositivos Bluetooth (solo se pueden conectar los dispositivos que son permitidos explícitamente. Se puede crear una regla de este tipo)
- Controlar otros dispositivos removibles
- Gestionar distintos tipos de trabajos de impresión

Se puede realizar una configuración de perfil de dispositivo y de excepciones de dispositivo.

Si bien la tecnología Bluetooth ofrece comodidad, también presenta riesgos de seguridad, ya que dispositivos no autorizados podrían acceder a datos sensibles o comprometer los endpoints. Cortex aborda esta vulnerabilidad permitiendo un control granular sobre qué dispositivos Bluetooth pueden conectarse, abarcando tanto dispositivos Bluetooth Classic como Bluetooth Low Energy, lo

que proporciona una solución de seguridad integral. Este enfoque proactivo te permite elegir activamente qué dispositivos están autorizados a conectarse, en lugar de depender de una configuración predeterminada que permite todos los dispositivos Bluetooth.

6.5.3. Policy rules

Utilizas **reglas de política (policy rules)** para asociar perfiles a los endpoints. Los cinco perfiles asociados a una regla de política determinan las configuraciones que se aplicarán a los endpoints objetivo.

En otras palabras, la regla define qué endpoints reciben la política, y los perfiles asociados definen qué configuraciones específicas se aplican.

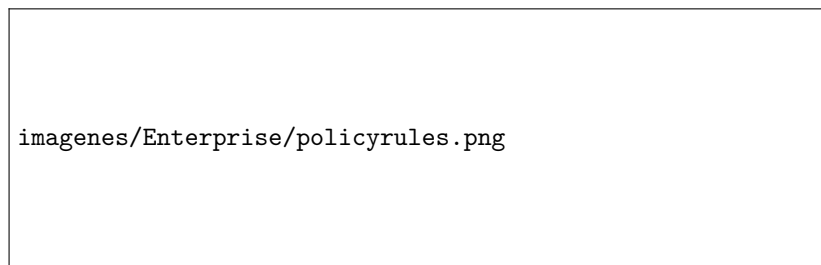


Figura 127: Caption

Cortex trae por defecto algunas políticas, pero también se pueden añadir navegando a *Inventory > Endpoints > Policy Management > Prevention > Policy Rules*.

6.5.4. Agent Settings Profiles

El **perfil Agent Settings** contiene configuraciones que afectan la forma en que los agentes de Cortex XDR operan en los endpoints. Estas configuraciones pueden considerarse ajustes de seguridad **indirectos**, en comparación con los que se encuentran en otros tipos de perfiles, como los perfiles de Exploit o Malware, que aplican protecciones directas contra amenazas. En Windows, proporciona una lista grande de diferentes perfiles.

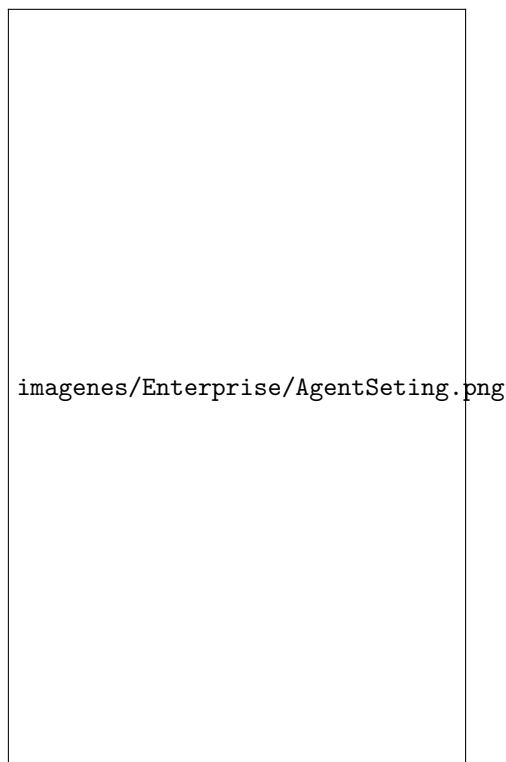


Figura 128:

La sección de **Seguridad del Agente**, en el perfil de Configuración del Agente, contiene ajustes que previenen el acceso no autorizado o la manipulación de los componentes del agente de Cortex XDR. Cuando esta protección está habilitada, Cortex protege los componentes del agente para que no sean modificados, detenidos ni alterados de ninguna manera.

XDR Pro Endpoints: puede utilizar los perfiles de Configuración del Agente para determinar qué endpoints adquieren qué tipos de licencia.

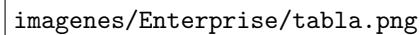
6.5.5. Restrictions Profiles

Los **perfiles de Restricciones** limitan la superficie de ataque en los endpoints al definir dónde y cómo los usuarios pueden ejecutar archivos. Las opciones disponibles pueden variar según el sistema operativo (SO) del perfil. Este tipo de perfil proporciona control sobre escenarios de ejecución potencialmente maliciosos que no implican explotación. Por ejemplo, el agente de Cortex XDR puede impedir la ejecución de archivos desde la carpeta Temp de Windows o evitar la ejecución de un tipo de archivo específico, o incluso de todos los tipos de archivos, directamente desde una unidad USB.

La siguiente tabla describe cómo el agente implementa cada modo de acción, indicando:

- Si el archivo intentado puede ejecutarse
- Si se envía una notificación al usuario
- Si se envía un reporte a Cortex

Para archivos ejecutables, el modo de acción se aplica a los archivos y carpetas especificados en la lista de bloqueo (block list).



imagenes/Enterprise/tabla.png

Figura 129:

6.5.6. Tuning and optimization

Tunning se refiere al proceso de adaptar y refinar las medidas de seguridad y las configuraciones del sistema para garantizar que se alineen con los requisitos específicos de seguridad de una organización, sus necesidades operativas y su panorama de amenazas. Su objetivo es hacer que las medidas de seguridad sean más precisas, enfocadas y sensibles a las amenazas, al mismo tiempo que se minimizan los falsos positivos y se asegura que las operaciones legítimas no se vean afectadas. Implica modificar configuraciones, reglas y parámetros para mejorar la eficacia y eficiencia de la infraestructura de seguridad.

La **optimización** implica el proceso de mejorar el rendimiento y la eficiencia general de la infraestructura de seguridad. Su objetivo es garantizar que los componentes, políticas y configuraciones de seguridad funcionen de la mejor manera posible, lo que resulta en una mejor detección de amenazas, una respuesta a incidentes más ágil y un uso más eficiente de los recursos.

6.5.7. Preguntas interesantes

1. *Which profile allows you to disable specific protections on certain processes?*

Exceptions

2. *What needs to be created in the management console in order to apply the security settings in profiles to endpoints?*

Policy rules

3. Which profile type can you use to limit executions from the Downloads folder?

Restrictions

4. Where in the management console can you set the Global Uninstall Password?

Configurations ; General ; Agent Configurations

5. Which profile type can you use to enable the Pro features of XDR agents?

Agent settings

6. What permission can be specifically granted to Disk Drives when configuring Device Exceptions?

Read only

7. Which Cortex feature allows you to define which host, user, or IP address values will have a flag in their associated Name field on the Issues table when they appear?

Featured Fields

8. Which Cortex feature associates profiles with selected endpoints?

Policy Rules

9. Which profile cannot be deleted?

Default Settings

10. Which of the following prevents the Cortex XDR agent from being tampered with or maliciously modified?

Agent Security

11. Which of the following sections from the Policy Management Page limits the attack surface on the protected Endpoint?

Extensions

7. Data Ingestion

7.1. Data Source

Cortex **ingiere datos** de múltiples fuentes. Esto abarca desde datos locales (on-premises), como bases de datos y endpoints, hasta proveedores en la nube, así como datos provenientes de los módulos de Palo Alto Networks.

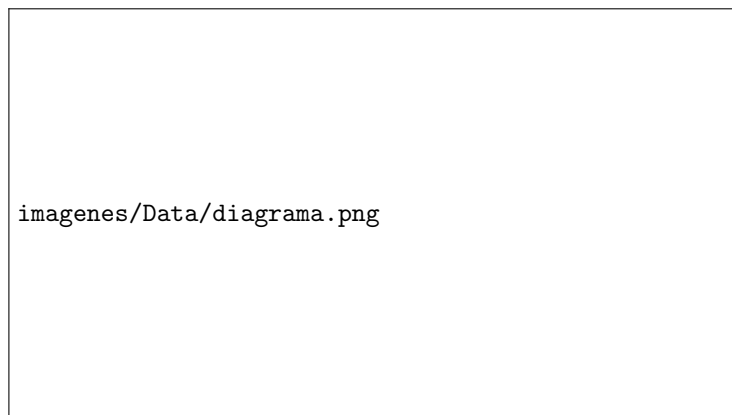


Figura 130:

Cortex recopila datos de cualquier fuente, lo que te permite ampliar el alcance de la búsqueda de amenazas en todo tu entorno. Combina automáticamente datos de endpoints, red, nube e identidad para detectar ataques con precisión y simplificar las investigaciones.

Diferentes partes de la recolección de datos:

- **Cortex Console:** consola central de administración y análisis que ofrece visibilidad del estado de seguridad, acceso a paneles, reportes, reglas, endpoints y activos. También es el lugar donde los analistas investigan incidentes, gestionan casos y aplican configuraciones y políticas.
- **Broker VM:** máquina virtual que actúa como intermediaria entre Cortex XDR y fuentes de datos o recursos internos, facilitando la integración segura con entornos on-premise.
- **XDR Agent:** agente instalado en los endpoints que recopila telemetría, aplica políticas de seguridad, previene amenazas y permite acciones de respuesta local.
- **XDR Collectors:** componentes encargados de recolectar y enviar datos desde distintas fuentes hacia Cortex XDR para su análisis e investigación.
- **Engines:** motores de análisis y procesamiento que ejecutan tareas de detección, correlación, automatización o análisis avanzado dentro de la plataforma.

- **CLCS**: servicio de control y comunicación en la nube que ayuda a gestionar la conectividad y coordinación entre agentes, servicios y la plataforma Cortex.
- **ASM/TI**: capacidades de *Attack Surface Management* y *Threat Intelligence*, orientadas a identificar exposición externa, riesgos visibles y enriquecer la detección con inteligencia de amenazas.

7.1.1. Tipos de fuentes de datos

Las Broker VM de Cortex admiten varios métodos de ingesta para recopilar y procesar datos de diferentes fuentes. Al configurar el broker, estableces una conexión segura mediante la cual puedes enrutar tus endpoints y recopilar y reenviar registros y archivos para su análisis.

La Broker VM admite múltiples opciones para incorporar datos. Por ejemplo, los datos pueden recopilarse desde Kafka, Syslog, bases de datos y archivos. También permite recopilar lotes (batches) y crear consultas (lookups) dentro del sistema, no solo registros. Ten en cuenta que no admite el protocolo Simple Network Management (SNMP).

Cortex proporciona una configuración de **XDR Collectors** dedicada a la recopilación de datos on-premise en equipos Windows y Linux. El XDR Collector incluye:

- Un instalador dedicado
- Configuración para la actualización del collector
- Actualizaciones de contenido
- Gestión de políticas

Esta arquitectura permite administrar de forma centralizada la recopilación de datos locales para su análisis dentro de Cortex. Para administrarlos: *Settings > Configurations > XDR Collectors > Administration*

El **Marketplace** es el lugar donde se instala y gestiona contenido, como playbooks, integraciones, automatizaciones, campos, entre otros. Los content packs del Marketplace son paquetes preconfigurados que incluyen:

- Integraciones
- Playbooks
- Automatizaciones
- Campos
- Todas las dependencias necesarias

Estos paquetes están diseñados para respaldar casos de uso específicos de orquestación de seguridad, facilitando una implementación rápida y estructurada.

7.1.2. Data Onboarder

El **Data Source Onboarder** está disponible de forma gratuita en todas las implementaciones de Cortex y está diseñado para simplificar el proceso de incorporación de nuevas fuentes de datos.

Las fuentes de datos pueden provenir de:

- Marketplace
- Custom Collectors
- Integrations

Estas pueden incluir distintos tipos de entradas, como:

- Logs
- Alertas
- Data feeds de diversos sistemas y dispositivos, tanto internos como externos

Esta herramienta facilita y estandariza la integración de nuevas fuentes dentro del entorno Cortex. También centraliza la administración y monitorización de estos onboarded data source.

El Onboarder ofrece una página simplificada de configuración de integración que:

- Instala automáticamente los content packs necesarios del Marketplace
- Recomienda contenido adicional relevante para la fuente de datos seleccionada, como playbooks o dashboards

Para añadir una fuente de datos, navegar a *Settings > Configurations > Data Collection > Data Sources*.

7.1.3. Preguntas interesantes

1. *What are pre-built bundles of integrations, playbooks and automations that are available from Marketplace?*

Content Packs

2. *What is a key difference between Broker VM and Engines?*

Broker VM is only for data collection

3. *What is a lightweight software agent that is installed on endpoint and servers to collect security data and protect them from threats?*

XDR Agent

4. *What are two modules Cortex can access to get additional data? (Choose two.)*

ASM and TI

5. *What are three common log formats for Cortex? (Choose three.)*

Json, CEF/LEEF and Delimited logs

6. *What are three benefits of using the Data Source Onboarder? (Choose three.)*

Efficient data analysis, Automation and Easy integration of new data sources

7.2. Trabajando con dominios

7.2.1. Componentes clave

Los **triggers de playbooks** son una funcionalidad potente en Cortex que permite automatizar respuestas ante condiciones específicas dentro de casos e issues. Al definir triggers, puedes:

- Agilizar los flujos de gestión de casos
- Estandarizar procesos operativos
- Garantizar que acciones críticas se ejecuten de forma oportuna y consistente

Esto mejora la eficiencia operativa y reduce la dependencia de intervenciones manuales en situaciones clave.

El **case scoring** es un enfoque sistemático utilizado en las operaciones de seguridad para cuantificar la gravedad y el impacto potencial de un caso.

Los **Starred Issues (marcado de incidencias)** permiten marcar issues específicos para acceso rápido y priorización.

Los **issue layouts** son fundamentales para organizar y priorizar los issues entrantes, lo que permite responder de manera rápida y efectiva a posibles incidentes.

Las **reglas de exclusión** de issues ayudan a gestionar issues que no representan una amenaza y que se identifican durante el triage o la resolución de casos.

La **notificación por reenvío (notification forwarding)** es una funcionalidad que permite enviar alertas, reportes y registros de auditoría desde Cortex hacia plataformas externas como Slack, un receptor syslog o una cuenta de correo electrónico.

7.2.2. Case Domains

Los **Case Domains** actúan como pilares organizativos dentro de Cortex, permitiendo gestionar y priorizar de manera eficiente los flujos de trabajo operativos. Estos dominios proporcionan un marco contextual, adaptando la experiencia según cada caso de uso operativo específico.

Cuando se generan issues, Cortex los asigna automáticamente a un dominio, lo que agiliza la gestión de casos. Los dominios integrados, como Security, IT y Hunting, están diseñados para distintos enfoques operativos, asegurando que los casos e issues se clasifiquen adecuadamente para una respuesta eficaz.

Para gestionar un Case Domain hay que navegar a *Navigate to Configurations > Object Setup > Cases > Domains*.

Los **Security Domains** desempeñan un papel fundamental en Cortex, ya que proporcionan un enfoque específico para las actividades de respuesta a casos orientadas a detectar, prevenir y bloquear amenazas.

Estos dominios funcionan como espacios dedicados para gestionar issues y casos relacionados con la seguridad, garantizando la protección de los activos organizacionales frente a posibles riesgos y vulnerabilidades.

Al centralizar la gestión de amenazas en un entorno especializado, se mejora la eficacia operativa y la capacidad de respuesta ante incidentes de seguridad.

Los **IT Domains** son espacios designados para actividades operativas orientadas a garantizar la disponibilidad y confiabilidad del rendimiento de los sistemas.

Estos dominios ofrecen un marco estructurado para gestionar casos e issues relacionados con operaciones de TI, tales como:

- Caídas de servidores
- Problemas de conectividad de red
- Incidentes de rendimiento en aplicaciones
- Tareas generales de soporte IT

De esta manera, permiten una gestión organizada y eficiente de los eventos operativos, asegurando la continuidad del servicio.

Los **Hunting Domains** están orientados a la identificación y mitigación de amenazas potenciales antes de que causen daño. Estos dominios ofrecen un espacio dedicado para realizar actividades como:

- Monitoreo del tráfico de red
- Análisis de logs
- Evaluaciones de vulnerabilidades

Su objetivo es anticiparse a riesgos emergentes de seguridad, permitiendo una postura proactiva frente a posibles amenazas.

7.2.3. Preguntas interesantes

1. *How does Cortex handle case and issues that do not match any custom rule?*

They are assigned to a default layout.

2. *Which feature in Cortex helps quickly locate and prioritize critical issues?*
Starred Issues

3. *In Cortex, which domain focuses on activities such as detecting, preventing, and blocking threats?*

Security

4. In Cortex, which domain focuses on activities such as monitoring network traffic and conducting vulnerability assessments?

Hunting

5. What feature does Cortex provide to help users manage incidents and alerts based on specific operational use cases?

Case Domains

6. What is the main benefit of using built-in domains in Cortex?

They ensure consistent and supported content management.

7.3. Trabajando con datasets

Al igual que las tablas en los sistemas de gestión de bases de datos relacionales, un **dataset** es un almacenamiento persistente que contiene pares atributo-valor. Cortex almacena los logs en datasets, y los motores de búsqueda de Cortex (es decir, Cortex Query Language (XQL) y Query Builder) ejecutan consultas sobre uno o más datasets. Los datasets de Cortex están sujetos a políticas de retención de datos.

Para administrar un dataset hay que navegar a *Settings > Configurations > Data Management > Dataset Management*.

Puedes gestionar y configurar el control de acceso granular a los datasets desde: *Settings > Configurations > Access Management > Roles*. Una vez que habilites la opción **Enable dataset access management**, deberás definir los permisos de acceso que deseas otorgar al rol para cada tipo de dataset. Las opciones disponibles varían según el tipo de dataset.

Los tipos de datasets son:

- System: los creados por Cortex, como `xdr_data`
- Raw: formados por, `NombreProducto_Proveedor_raw`
- User: creados por consultas XQL
- Correlation: creados mediante reglas de correlación

Retención de datos: la página Dataset Management muestra en la parte superior la duración de retención configurada para tu instancia de Cortex. Todos los tipos de licencia de Cortex incluyen, de forma predeterminada, las siguientes políticas de retención basadas en períodos:

- 31 días para todos los tipos de datos ingeridos (logs y alertas)
- 186 días para datos de alertas e incidentes

Estas retenciones se aplican según el tipo de dato almacenado.

Puedes hacer clic derecho sobre un dataset en la tabla Datasets y realizar las siguientes acciones:

- View Schema: Ver el esquema del dataset
- Set as default: Establecerlo como predeterminado

- Delete: Eliminar el dataset
- Download: Descargar el dataset

Puedes cargar archivos en formato CSV (valores separados por comas), TSV (valores separados por tabulaciones) o JSON en Cortex como **Lookup datasets**.

De forma predeterminada, el **control de acceso basado en roles (RBAC)** para datasets no está habilitado; todos los usuarios de la consola de administración tienen acceso a todos los datasets. Puedes habilitarlo y definir permisos de acceso para un rol personalizado por dataset o por tipo de dataset desde: *Settings > Configurations > Access Management > Roles*.

7.3.1. Parsing rules

Cortex proporciona varias **reglas de parsing predeterminadas** que puedes sobrescribir o ampliar fácilmente según sea necesario utilizando XQL y sintaxis adicional específica para la creación de reglas de parsing.

Palo Alto Networks recomienda utilizar modelos de datos (data models) en lugar de reglas de parsing. Sin embargo, pueden existir situaciones en las que se utilicen ambos, por ejemplo, cuando las reglas de parsing se emplean únicamente para extraer la marca de tiempo (timestamp).

Antes de crear Parsing rules, debe utilizar la herramienta de simulación para evaluar qué puede hacer una Parsing rules con los datos entrantes. Viendo el output después de una simulación el usuario decide si la regla de parseo es válida o no.

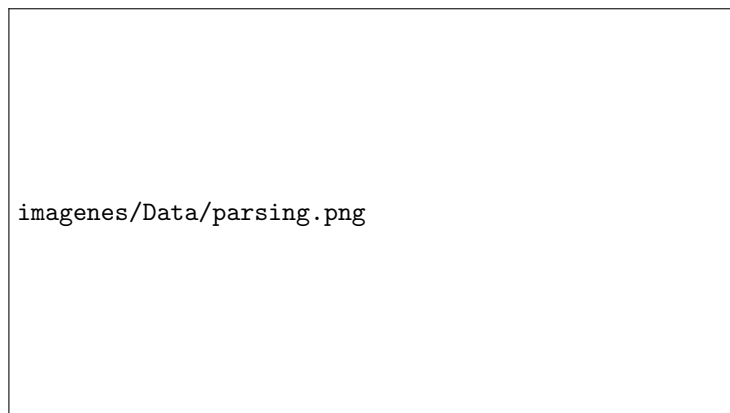


Figura 131:

7.3.2. Dataset Management View

El **Dataset Management View** le permite administrar sus datasets. También le permite conocer la duración general del almacenamiento de datos para

diferentes períodos de retención y conjuntos de datos, según sus licencias de almacenamiento en caliente y en frío y los complementos de retención que amplían su almacenamiento.



Figura 132:

Puede crear vistas de datasets basadas en resultados de consultas específicas, proporcionando una representación visual de estructuras de datos complejas de consultas XQL para facilitar la investigación y el análisis. Aplicadas mediante permisos de Control de Acceso Basado en Roles (RBAC), estas vistas ofrecen mayor seguridad de los datos al controlar el acceso a nivel de conjunto de datos, lo que permite a los administradores proporcionar a los usuarios exactamente los datos que necesitan.

7.3.3. Preguntas interesantes

1. *Which two data mapping types are in XSIAM? (Choose two.)*
Data models and parsing
2. *True or false? Using a unified data model provides a consolidated schema and a simpler way to interact with the data*
True
3. *What is the default data retention period for all ingested data types in Cortex?*
31 days for logs and issues
4. *What does the phrase “Parsing is forever” mean in Cortex?*
Parsing makes changes that can’t be reversed.
5. *What characteristic defines Hot Storage in Cortex?*
It is a fully searchable storage type

8. Broker VM

8.1. Broker VM resumen

Broker VM es una máquina virtual segura que conecta tu red con Cortex. Permite enrutar endpoints y recopilar y reenviar logs y archivos para su análisis. Además, Broker VM recibe actualizaciones y mejoras automáticas desde Cortex, lo que proporciona nuevas capacidades sin necesidad de realizar una nueva instalación.

Broker VM actúa como intermediario entre tus redes y las funcionalidades de Cortex entregadas desde la nube, facilitando la comunicación segura entre ambos entornos.

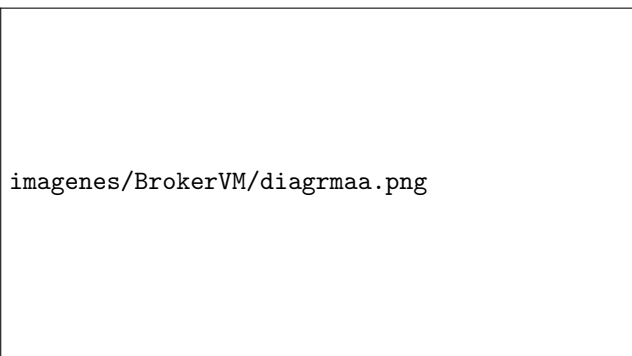


Figura 133:

Cortex requiere información de tus dispositivos y sensores de seguridad on-premise para ofrecer sus funcionalidades. Por ejemplo, permite a los analistas de seguridad realizar investigaciones y determinar la causa raíz de un caso. Broker VM proporciona una plataforma común que facilita el flujo de esta información entre el entorno local y Cortex.

Broker VM actúa como punto centralizado de las comunicaciones de los componentes de Cortex. Recoge toda la información y la hace disponible en Cortex.

8.1.1. Broker VM Applets and Services

Hay que distinguir entre Broker VM en sí mismo y Applets. Broker VM permite una comunicación segura entre los equipos locales y Cortex. Mientras que los **applets** son servicios que corren en el Broker VM.

Local Agent Settings Applet. Para dar soporte a entornos con altos requerimientos de ancho de banda, el Broker VM puede utilizarse para almacenar en caché:

- Paquetes de instalación de agentes

- Actualizaciones de agentes
- Actualizaciones de contenido

El Broker VM obtiene los instaladores y archivos de contenido más recientes desde Cortex cada 15 minutos y los almacena durante 30 días desde la última solicitud realizada por un agente.

El **applet Syslog Collector** permite que el Broker VM reciba logs de dispositivos Syslog de terceros o datos de sistemas SIEM (Security Information and Event Management) y los envíe a Cortex para:

- Detección analítica
- Correlación de logs

El **applet Windows Event Collector (WEC)** del Broker VM se comunica con los controladores de dominio (DCs) de Windows.

El **applet Network Mapper** identifica dispositivos no administrados dentro de una red intern

El **applet Transporter** del Broker VM permite la comunicación segura entre sistemas de control de versiones (VCS) autoalojados, como GitHub Server, y la plataforma Cortex mediante túneles WebSocket seguros y persistentes. Este applet puede conectarse a distintos sistemas VCS y habilita análisis de seguridad en los repositorios seleccionados para detectar:

- Secretos expuestos
- Configuraciones incorrectas en infraestructura como código (IaC)
- Vulnerabilidades
- Riesgos operativos de paquetes
- Problemas de cumplimiento de licencias

El Broker VM incluye un **applet CSV Collector**, que permite monitorear y recopilar archivos de registro en formato CSV (comma-separated values) desde un directorio compartido de Windows. Estos archivos pueden almacenarse en tu repositorio de logs para su posterior consulta y visualización.

Otros applets compatibles incluyen recolectores para:

- Apache
- Bases de datos
- FTP (File Transfer Protocol)
- Archivos y carpetas

Las funciones de Broker VM incluyen actualizaciones de Broker VM (pueden ser automáticas o no), acceso a la línea de comandos de Broker VM, interfaz de escucha del proxy y registros de PingFederate.

8.1.2. Preguntas interesantes

1. *How many WebUIs are used with Broker VM?*

One

2. *Which option is a source of information for Broker VM?*

Third-party alert services

3. *What is the role of Broker VM applets in Cortex?*

They bring information from customer infrastructure to Cortex analytics functionality.

4. *Between which pair of entities does Broker VM broker data?*

Endpoints and Cortex

4. *How does the Network Mapper applet within Broker VM contribute to Cortex's Asset Management feature?*

It conducts network scans to identify unmanaged devices within the network.

5. *Which applets are available in the Broker VM for ingesting data from third party sensors?*

Syslog Collector

6. *Which applet is available to collect data from agentless endpoints?*

Pathfinder

7. *Which statement applies to Broker VM communication with Cortex?*

It requires a connected Cortex XDR agent.

8. *Which three services are directly supported by the Broker VM applets in the Cortex system?*

Apache Kafka Collector, Database Collector, and Firewall Controller

8.2. Broker VM set up

Puedes obtener las imágenes de Broker VM desde la consola de gestión de Cortex, a la cual accedes iniciando sesión en tu tenant de Cortex. La imagen que debes utilizar depende de tu entorno de máquina virtual. Palo Alto Networks ofrece distintos tipos de imágenes de Broker VM para varios entornos estándar de hipervisor.

Puedes descargar distintas versiones de Broker VM, pero esta lección se centra en el uso de la opción OVA. Para descargar la imagen OVA de Broker VM desde la consola de gestión a tu equipo: *Settings > Configurations > Broker VM > Add Broker*.

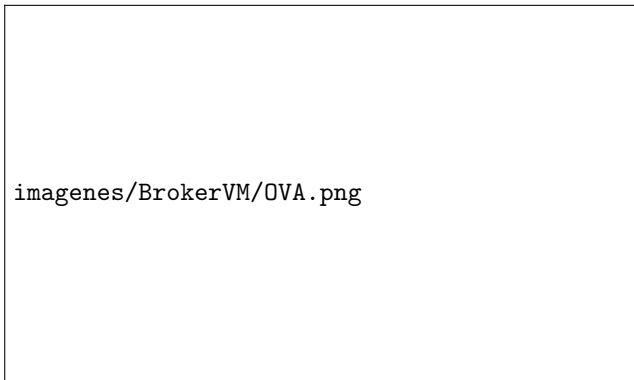


Figura 134:

8.2.1. Install Broker VM

Se utiliza un token. Mejor ver en esta sección de la teoría.

8.2.2. Configurar Broker VM

Mejor ver en esta sección de la teoría.

8.2.3. Activate Broker VM Applets

El menú de Broker VM para cada instancia muestra los applets disponibles. Se pueden activar en *Settings > Configurations > Data Broker > Broker VMs*.

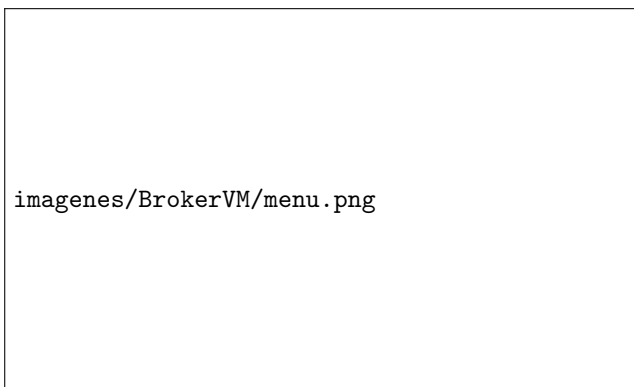


Figura 135:

8.2.4. Broker VM Clusters

Para **garantizar alta disponibilidad (HA)** de los servicios que se ejecutan en Broker VM, Cortex incluye ahora un **clúster HA** de Broker VM. Este

clúster proporciona redundancia de los componentes de Broker VM en la red, permitiendo la conmutación por error (failover) hacia la siguiente Broker VM disponible en caso de fallo.

En esta sección explica como implementarlo.

8.2.5. Preguntas interesantes

1. *For an inactive Broker VM applet, what is the single applet submenu option that is available?*

Activate

2. *How is a newly installed Broker VM associated with a Cortex tenant?*

It's registered using a token from the management console

3. *Which of the following is a requirement for activating the Local Agent Settings applet?*

SSH Configuration

4. *Which applet must be deactivated before creating a Broker VM Cluster?*

Pathfinder

5. *What is used to associate a Broker VM instance with a Cortex tenant?*

Tokens

6. *Which of the following can be used to access Broker VM instance configuration details?*

Cortex management console or Broker VM console

7. *How is a Broker VM instance registered with Cortex?*

A token generated by Cortex is entered locally into a Broker VM instance.

8. *When is applet activation required?*

Before the first use of an applet for a given Broker VM instance

9. *Which hypervisor uses a Broker VM OVA for installation?*

VMware ESXi

10. *Where can a Broker VM configuration be imported from?*

Another Broker VM

8.3. Cortex XSIAM: Broker VM Management

8.3.1. Broker VM Configuration Details

En Cortex XSIAM, puedes navegar a: *Settings > Configurations > Data Broker > Broker VMs*. En la pestaña Brokers podrás ver información detallada sobre las Broker VM registradas en tu entorno.

En la página **Broker VM Configurations**, los detalles de configuración están organizados por categorías. Puedes ver y editar las configuraciones asociadas a cada grupo. Los detalles de configuración pueden visualizarse incluso cuando la Broker VM no está conectada a Cortex XSIAM. Sin embargo, solo pueden editarse cuando la Broker VM está conectada a Cortex XSIAM.

Para acceder a la configuración de una Broker VM:

1. Haz clic derecho sobre la Broker VM que deseas configurar.
2. Selecciona Configure.

8.3.2. Broker VM Logs

Los logs se almacenan en la Broker VM y pueden visualizarse directamente allí. También pueden descargarse desde la página Broker VMs en la consola de gestión de Cortex XSIAM al dispositivo desde el cual accedes a la consola. Con frecuencia, los tickets de soporte requieren estos logs.

Los logs de Broker VM ayudan a supervisar el uso y funcionamiento de:

- Administración de Broker VM
- Rendimiento
- Red
- Applets
- Servicios internos

También son útiles para tareas de resolución de problemas (troubleshooting).

8.3.3. Reboot Broker VM

El curso explica los pasos para resetear un Broker VM.

8.3.4. Broker VM Live Terminal

Puedes acceder a la línea de comandos de Broker VM directamente desde la consola de gestión de Cortex XSIAM.

Desde la línea de comandos puedes:

- Acceder a los logs de Broker VM
- Realizar manipulación de archivos
- Iniciar, reiniciar, detener y verificar el estado de applets y servicios internos
- Restablecer la contraseña de la interfaz web (Web UI) de Broker VM
- Ejecutar comandos estándar de Linux, como los utilizados para capturar tráfico de red

8.3.5. Preguntas interesantes

1. *In which format are Broker VM logs available for download?*
tarball
2. *Where do you access a path to detailed Broker VM configuration views?*
Cortex XSIAM management console Settings (gear) icon
3. *Which two statements describe the use of Broker VM Live Terminal (BVLVT)? (Choose two.)*

BVLVT commands are executed using shift-enter and Commands are entered in the lower of two BVLVT windows.

4. Which is an expected consequence of rebooting a Broker VM instance from Cortex XSIAM?

The rebooted Broker VM instance is temporarily unreachable.

5. Which folder has Syslog Collector applet logs?

Anubis

9. Inventario

9.1. Descubrimiento y Gestión de Activos de Red

9.1.1. Inventario Unificado de Activos

Cortex ofrece un **inventario unificado** de activos que combina todos los activos locales (on-premises) y en la nube en un solo lugar.

Cortex recopila activos desde múltiples fuentes. Luego, estos datos se correlacionan y normalizan para crear un activo agregado, proporcionando una vista consolidada de todas las fuentes de datos asociadas a un mismo activo.

Puedes acceder al inventario de activos navegando a: *Inventory > All Assets*. Tiene la siguiente vista:

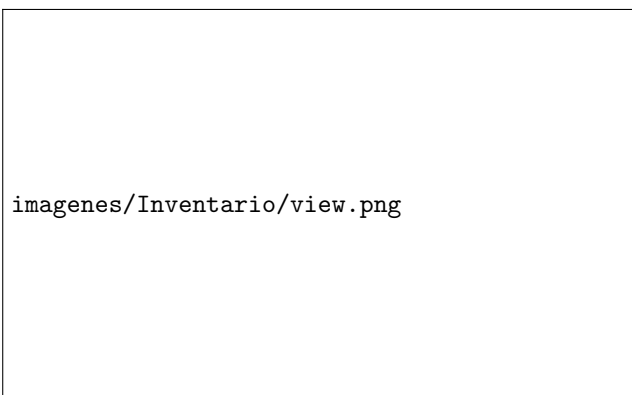


Figura 136:

La vista **Inventory** también ofrece diversas opciones para visualizar y administrar **endpoints**.

Un **activo de red** es cualquier nodo direccionable por IP dentro de una red informática. Por ejemplo un equipo host o un router. Existen dos tipos:

- Managed Assets: los que tienen instalado un agente de cortex XDR.
- Unmanaged Assets: no tienen instalado un agente de cortex XDR.

9.1.2. Configuración de red

Cortex descubre todos los activos de red dentro de tu red interna. Combina la configuración de red definida por el usuario con los resultados de descubrimiento automático, obtenidos mediante el análisis de los logs de red recopilados. Se pueden definir de dos maneras:

- Automática
- Manual: definir rangos de IPs manualmente.

La página **IP Address Ranges** en la consola de administración te permite definir los rangos de direcciones IP de tu red interna o externa.

La tabla IP Address Ranges incluye automáticamente los rangos privados IPv4 conocidos y el rango de Automatic Private IP Addressing (APIPA).

Cuando agregas un nuevo rango de direcciones IP, el número de activos activos y activos gestionados activos se completa automáticamente para ese rango.

9.1.3. Evaluación de Vulnerabilidades

La **Evaluación de Vulnerabilidades** es un componente del complemento Host Insights. Este componente identifica Common Vulnerabilities and Exposures (CVEs) que pueden existir en:

- Aplicaciones instaladas
- Kernels del sistema operativo (OS)

Las limitaciones de la Evaluación de Vulnerabilidades estándar es que en Windows solo analiza el kernel del sistema operativo, no las aplicaciones.

La Evaluación de Vulnerabilidades en la consola de administración genera un issue (incidencia) cuando se detecta un nuevo CVE.

Para acceder a la página de evaluación de vulnerabilidades, hay que acceder a *Posture Management > Vulnerability Management*.

Enhanced Vulnerability Assessment es un componente opcional del complemento de licencia (add-on license) Host Insights y se ofrece de forma promocional.

9.1.4. Preguntas interesantes

1. *Which application or device can use the IP Address Ranges defined in the Cortex management console?*

Broker VM Network Mapper

2. *Which component is needed for Cortex Vulnerability Assessment to be enabled?*

Host Insights add-on

3. *The Cortex Vulnerability Assessment component regularly searches Common Vulnerabilities and Exposures (CVE) databases. How often does it correlate these CVE databases with the application and kernel patch lists to detect new vulnerabilities?*

Every four hours

4. *How is an unmanaged asset specifically characterized within Cortex?*

An endpoint without the Cortex XDR agent installed

5. *In addition to the distributed network scan in the XDR Agent Settings profile, what discovery method is also used by Cortex?*

Broker VM Network Mapper

6. *What specific action does the Network Mapper perform to detect devices within selected IP address ranges?*

Scans the network to detect unmanaged hosts

7. *What is the consolidated view in Cortex that integrates all on-premises and cloud assets called?*

Unified Asset Inventory

10. Licencias y Add On

Palo Alto Networks Cortex es una plataforma avanzada de operaciones de seguridad diseñada para simplificar, automatizar y coordinar la seguridad en toda la organización.

A continuación, una descripción general de los principales productos de la suite Cortex:

- **Cortex XDR:** la solución fundamental para la seguridad de endpoints. Comienza con prevención líder en la industria y se amplía con capacidades avanzadas de: detección y respuesta en endpoints (EDR), analítica impulsada por inteligencia artificial (IA) y análisis automatizado de causa raíz.
- **Cortex Cloud:** una plataforma integral CNAPP (Cloud Native Application Protection Platform) diseñada para proteger aplicaciones e infraestructura en la nube. Es modular e incluye: Cloud Posture Security, Cloud Runtime Security y Application Security (AppSec).
- **Cortex XSIAM** (Extended Security Intelligence and Automation Management) es una plataforma moderna de SOC impulsada por IA. Integra datos de múltiples fuentes para ofrecer una solución unificada de: Detección de amenazas, Investigación y Respuesta.
- **Cortex XSOAR** (Extended Security Orchestration, Automation, and Response) es una plataforma de automatización y orquestación de seguridad. Ayuda a los equipos de seguridad a: Optimizar procesos, Automatizar tareas repetitivas, gestionar inteligencia de amenazas y acelerar la respuesta a incidentes
- **Cortex Xpanse** descubre, evalúa y ayuda a mitigar la superficie de ataque externa de una organización. Proporciona visibilidad crítica sobre: activos expuestos a Internet y posibles vulnerabilidades y exposiciones

10.0.1. Módulos de seguridad en Cortex Cloud

Este módulo se centra en la **gestión de la postura de seguridad en la nube (CSPM)**, garantizando que los entornos en la nube estén configurados de forma segura y se mantengan en cumplimiento.

Permite identificar y remediar riesgos tanto en el código como en los entornos cloud, ayudando a reducir la exposición y fortalecer la postura de seguridad.

Cloud Runtime Security: este módulo se centra en la protección de cargas de trabajo en la nube (CWPP). Protege a hosts, contenedores y funciones serverless mientras están en ejecución, proporcionando visibilidad completa y capacidades avanzadas de análisis para detectar y responder a amenazas en tiempo real.

10.0.2. Módulos de Cortex XDR

Cortex XDR Prevent es la licencia fundamental para la protección de endpoints, enfocada en la prevención de malware conocido y desconocido, exploits y ransomware. Proporciona capacidades avanzadas de protección para bloquear amenazas antes de que comprometan el endpoint. No se pueden añadir *Add-Ons*.

Cortex XDR Pro es la licencia completa de Extended Detection and Response (EDR), que incluye todas las capacidades de Prevent, además de funciones avanzadas de: recolección ampliada de datos, analítica avanzada y herramientas de búsqueda proactiva de amenazas (threat hunting).

10.0.3. Módulos Cortex XSIAM

XSIAM NG-SIEM es la licencia fundamental de XSIAM, que proporciona: ingesta de datos, motor de analítica y motor de automatización. Constituye la base para la detección, investigación y respuesta dentro de la plataforma XSIAM.

XSIAM Enterprise. Esta licencia incluye todas las capacidades de NG-SIEM, Extended Threat Hunting y Host Insights, e integra de forma nativa la seguridad de endpoints. Proporciona una plataforma unificada que amplía la visibilidad, mejora la detección avanzada y fortalece la investigación y respuesta ante amenazas.

XSIAM Premium. Esta licencia incluye todas las capacidades de XSIAM Enterprise y añade funciones avanzadas de: seguridad integral en la nube y gestión de la superficie de ataque. Proporciona una cobertura ampliada que integra operaciones de seguridad, protección cloud y visibilidad externa en una única plataforma.

El resto del módulo son comparaciones entre las diferentes licencias.

10.0.4. Preguntas interesantes

1. *What is the primary difference between Cortex XDR Prevent and Cortex XDR Pro?*

XDR Pro includes all Prevent capabilities plus advanced data collection, analytics, and threat-hunting tools.

2. *The Cloud Posture module in Cortex Cloud focuses on what key area of cloud security?*

Ensuring cloud environments are configured securely and remain compliant

3. *Which feature is included in the XSIAM Premium license but not in the XSIAM Enterprise license?*

External Attack Surface visibility

4. *Which Cortex product would be the most suitable for an organization that needs to standardize processes, automate repetitive tasks, and manage security incidents across various tools?*

Cortex XSOAR

5. *Which of the following is available as an optional add-on for Cortex XDR Pro?*

Vulnerability Management

6. Which feature is included in the XSIAM NG-SIEM license?

Proactive Threat Hunting Tools

7. What is the main purpose of the Cortex Xpanse module?

To provide a complete view of an organization's global internet-facing assets and identify risks.

10.1. Crtex ITDR

10.1.1. Identity Threat Protection

Los ataques relacionados con la **identidad** son una de las principales causas de brechas de seguridad, lo que los convierte en un área clave de enfoque para las organizaciones.

Cortex incluye ciertas capacidades de protección de identidad diseñadas para detectar intentos de acceso inicial.

Sin embargo, para identificar:

- Cuentas ya comprometidas
- Riesgos internos (insider risk)
- Otros comportamientos maliciosos de usuarios

Cortex ofrece el módulo **ITDR (Identity Threat Detection and Response)** como un complemento adicional de protección (de pago).

Este módulo:

- Perfila el comportamiento de los usuarios
- Detecta anomalías indicativas de un ataque
- Construye líneas base estadísticas de actividad dentro de la organización y entre organizaciones
- Aprende automáticamente el comportamiento de las entidades utilizando un esquema unificado para todas las fuentes

Además, emplea técnicas de normalización, correlación (stitching) y asociación de datos para generar un contexto analítico enriquecido y sin duplicaciones, mejorando así la detección y respuesta ante amenazas basadas en identidad.

Funcionamiento de ITDR. ITDR detecta automáticamente ataques basados en identidad mediante el uso de machine learning.

Para ello:

- Recopila datos de múltiples fuentes para perfilar el comportamiento típico de los usuarios.
- Compara de forma continua la actividad histórica de un usuario o dispositivo.

- Analiza también los perfiles de usuarios pares y otras entidades.

Los analistas utilizan ITDR para detectar amenazas de identidad mediante **dashboards** y **puntuación de activos (asset scoring)**.

- El **Risk Management Dashboard** emplea analítica avanzada para identificar y resaltar comportamientos anómalos que posteriormente pueden investigarse.



Figura 137: Es toda la captura

- Las **puntuaciones de activos** asignan un valor numérico al nivel de riesgo de usuarios y hosts, facilitando la priorización de amenazas.

Este enfoque permite identificar rápidamente las entidades con mayor riesgo y enfocar los esfuerzos de respuesta donde más se necesitan.

Cortex analiza continuamente usuarios y endpoints, y los clasifica automáticamente según sus actividades en **roles de activos**, por ejemplo:

- Domain Controller
- Administrator
- Executive User

En cualquier momento, puedes editar los activos asociados a un rol, agregar nuevos activos o ajustar y afinar la asignación según las necesidades de tu organización.

En *Assets > Asset Roles Configuration* se pueden ver los roles.



Figura 138:

10.1.2. ITDR Use Cases

Cortex ITDR está diseñado para detectar una amplia variedad de amenazas, entre ellas: credenciales comprometidas, exfiltración de datos y operaciones sospechosas de administradores.

10.1.3. Preguntas interesantes

1. *What is a key difference of ITDR over Identity Analytics?*
Reactive detection
2. *Which dashboard provides a comprehensive view of identity threats in ITDR?*
Risk Management Dashboard
3. *Which of the following does Identity Analytics primarily focus on as a proactive identity protection?*
Initial access use cases like session hijacking
4. *What approach does ITDR primarily take in detecting identity attacks?*
Profiling behavior and detecting anomalies
5. *What is the function of the ITDR Profiling Engine?*
To analyze user and device activity against various profiles
6. *What does the Peer Profile component of the ITDR Profiling Engine establish a baseline of?*
Activity based on the user's and device's peers
7. *What does the Score Trend Timeline on the Risk Management Dashboard display?*
The organizational risk score trend over time

8. *How do fine-tuned asset roles aid Cortex Analytics?*

By improving analytics accuracy

9. *What type of user activity might indicate a data exfiltration attempt, as detected by ITDR?*

Possible internal data exfiltration over a USB storage device

10.2. Advanced Email Security

Los desafíos actuales en la seguridad del correo electrónico, como la aceleración de los ataques basados en email impulsados por la IA generativa y los modelos de lenguaje de gran tamaño (LLMs), han generado la necesidad de adoptar un nuevo enfoque de protección.

Cortex tiene un módulo para protegerse de estos tipos de ataque llamado **Advanced Email Security Module**.

10.2.1. Arquitectura y Flujo de Datos

Inicio: Integración con Microsoft 365 mediante API (Microsoft Graph) que envía datos al collector SaaS de Cortex, sin necesidad de journaling ni cambios en el MTA.

Procesamiento Los datos pasan por tres capas:

- Ingesta y enriquecimiento
- Detección
- Generación de alertas

Motor multicapa que combina:

- Heurística tradicional
- Modelos LLM (análisis de contenido, tono e intención)
- Análisis de URLs (Palo Alto Networks)
- Escaneo de malware (WildFire)

Datos recopilados

- Metadatos (headers, remitente, asunto)
- Contenido, URLs y adjuntos
- Contexto del usuario (grupos, privilegios)
- Resultados de autenticación

Recolección continua e incremental.

Motores de detección

- **Artifact-Based:** hashes y reputación de URLs.
- **Metadata Analytics:** detección de spoofing, suplantación y patrones anómalos.
- **LLM:** identificación de phishing según tono e intención.

Correlación de Incidentes

Agrupar correos en casos mediante:

- Remitente
- Artefactos (hash, URL, dominio)
- Usuario

Permite investigar campañas completas de forma centralizada.

Respuesta

- Automática: ejecución de políticas y playbooks.
- Manual: intervención del analista.

Objetivo: Reducir el tiempo de respuesta y mejorar la eficiencia.

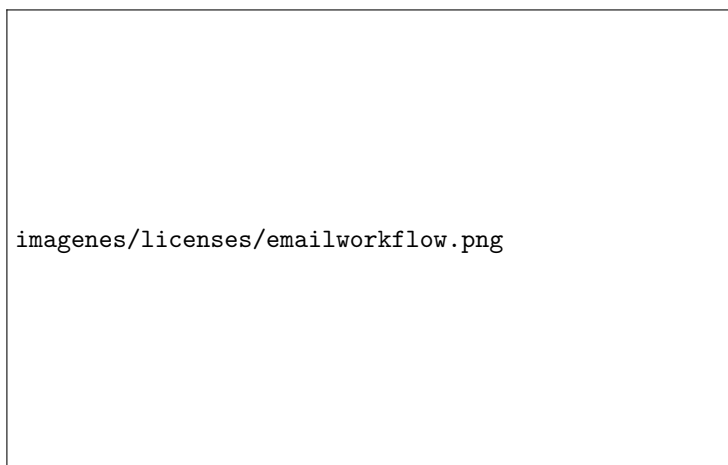


Figura 139:

10.2.2. Issue Generation

Advanced Email Security utiliza un **marco de detección multicapa** e identifica amenazas en diferentes categorías de detección.

10.2.3. Preguntas interesantes

1. *An administrator is investigating a malicious email that was sent to multiple users. How does the module facilitate a centralized investigation of this campaign?*

IOC-based issue and artifact-based engine

2. *Which of the following best describes the role of the Cortex Advanced Email Security module in a security architecture that already includes a Secure Email Gateway (SEG)?*

It acts as a complementary layer, catching threats that bypass the SEG.

3. *A security administrator wants to stop issues from being generated for emails from a trusted sender. Which feature should the administrator configure?*

Allow list

4. *An email contains a known malicious URL and is sent to an executive. What is the most likely detection method for this email?*

IOC-based issue and artifact-based engine

When an email contains a known malicious URL that matches an internal blocklist, which detection category is most likely to be triggered?

IOC-Based issue

Which statement about the Cortex Advanced Email Security module's data collection method is correct?

It uses a continuous, API-based method for data collection

What is the primary purpose of the allow list in the Cortex Advanced Email Security module?

To prevent a detection rule from generating an issue for a trusted indicator

What is the primary enhancement provided by the LLM-based engine for detecting sophisticated phishing emails?

It detects linguistic anomalies and tone manipulation that bypass static indicators.

Which statement describes the relationship between block lists and detection rules?

A block list acts as a data source for a specific type of detection rule.